ARGUS

Assurance, Risk & Governance Unified System

User manual: the full flow, from first request to board report

Version 1.2.7 · November 2026 · for ARGUS 1.7.4 · Prepared by Andrew Lawrence

This manual explains ARGUS, the Assurance, Risk & Governance Unified System: what it is for, how to use the live site, and how a piece of work flows through it from the first request to the board report. It is written for assurance, risk and governance professionals, not for developers. Screenshots use the fictional demo engagement (Northshore Financial Group) on the live site, so you can follow along as you read (section 4).

Contents

Part 1. Introduction

What's new in this edition

1. What ARGUS is

2. Key ideas

3. Roles and permissions

Part 2. Getting started

4. Opening ARGUS

5. Finding your way

6. Connecting an AI model

Part 3. Setting up an engagement

7. Creating an engagement

8. People and roles

9. The knowledge base

10. The AI inventory

Part 4. The full flow of a use case

11. Stage 1: Intake

12. Stage 2: Classify risk

13. Stage 3: Design controls

14. Stage 4: Collect evidence

15. Stage 5: Test controls

16. Stage 6: Remediate

17. Stage 7: Validate

18. Stage 8: Board report

Part 5. Registers and pages

19. Overview and the board

20. The risk register

21. Standards and controls

22. Testing

23. Evidence

24. Issues

25. Incidents

26. AI Testing and Monitoring

27. Readiness assessment and report

Part 6. The AI in the harness

28. The seven agents

29. Grounding: why the agents cite sources

30. The assistant

31. Checking the AI

Part 7. How the harness governs itself

32. Controls on the harness

Part 8. Administration

33. Workspace administration

34. Client workflows

Appendices

A. Troubleshooting

B. What isn't built yet

C. Glossary

Part 1. Introduction

What's new in this edition

This edition (1.2.7) follows edition 1.2.6 and covers ARGUS 1.4.1 to 1.7.4. Every screenshot was retaken for 1.2.4. New in 1.2.7 (ARGUS 1.7.4):

- **Every Requirement.** The complete list of requirements for each framework, so you can see when a framework is fully met (section 21.2).
- **Clearer sources and Verifier.** Each source says what it is and which frameworks it draws on; the Verifier says what to do in plain words (sections 12 and 31.1).
- **Client steps your way.** A use case can follow no client workflow, and an engagement can make that the default. Steps without a proof are shown as context only. Checks can run on a schedule, and a workflow can require its steps before sign-off (section 34.2).
- **Client tools and workflows is a module.** Engagements that work only in ARGUS don't see client workflows, connected tools, pipelines or write-back (section 7.1).

New in 1.2.6 (ARGUS 1.7.3):

- **Client steps on each use case.** Each client step can say what proves it was done, and ARGUS checks it in the client's tools for every use case (section 34.2).
- **Write-back.** When switched on, ARGUS posts to Teams or Slack, creates Jira tickets or ServiceNow records, or calls a webhook on set events (section 34.3).
- **Pipelines push evidence.** Build pipelines send evaluation results, fairness metrics or an SBOM straight in (section 23.3). Connectors can also read AWS S3, Azure Blob Storage, GitHub, GitLab and Bitbucket.
- **Healthcare frameworks.** FDA Good Machine Learning Practice and HIPAA (section 21.1).
- **Across Frameworks.** Map a control once and it counts for every framework (section 21.3).

New in 1.2.5 (ARGUS 1.7.2):

- **Connected tools.** Connectors are set up in **Settings > Connected tools**, beside the tools the client uses, or in place from a workflow step; **Tests and Evidence > From Client Tools** shows them read-only (sections 23.2 and 34.1).
- **How does the client work?** An optional step when adding an engagement drafts a client workflow and records the client's tools (section 7).
- **Approval gates** is the new name for the Settings tab that was called Workflow (section 7.1).

The main changes in 1.2.4:

- **The dashboard look.** Each working page opens with a row of tiles showing the numbers that matter there (section 5.1). Tabs and switches are pill-shaped.
- **Agents that reason.** Agents look things up before they draft, check their own draft, and can ask you a question; the use case then shows **Question for You** (sections 28.1 to 28.3).
- **A smarter Use Case Planner.** It knows the client, the board and the Knowledge Base, suggests use cases when asked, and won't file a test message as an answer (section 11).
- **The assistant works in the open.** You see its steps while it works, its answers link to the pages and records they mention, you can tag a record with @, and you can rate an answer

(section 30).

- **Better search and a Retrieval check.** Uploaded documents are split at their headings, and **Checking the AI > Retrieval** scores how well the Knowledge Base finds the right passage (sections 29 and 31.4).
- **Client workflows.** Draw the client's own process around ARGUS's governance gates, place each step in the client's business tools (Microsoft 365, ServiceNow, Jira, Google Workspace, Slack and others), and let ARGUS read those tools through read-only connectors (section 34).
- **Errors that say what to do.** When a model provider refuses a key, doesn't know a model or is out of quota, the message says how to fix it.

1. What ARGUS is

Organisations are adopting AI faster than they can govern it. Boards and regulators ask four questions: which AI do we use, what could go wrong, what stops it going wrong, and can we prove it? ARGUS (Assurance, Risk & Governance Unified System) is an AI-powered workbench that answers those questions for an assurance team running client engagements. AI agents draft the work at every step, from writing up a new use case to the board summary; named people decide every item; and every action is recorded so it can be proven afterwards.

The name comes from Argus, the hundred-eyed watchman of Greek myth, and the Great Argus pheasant, whose wing feathers carry rows of eye-spots. The logo is the pheasant in display.

For each client engagement it keeps, in one place:

- every AI **use case**, with its risk tier and the risks it carries;
- the **controls** that treat those risks, and the **standards** they help meet;
- the **tests** of those controls and the **evidence** behind each result;
- the **issues** found, and the **incidents** when something goes wrong in live use;
- **evaluations** that test the AI systems themselves, on a schedule if needed;
- a **readiness assessment** and a **board report**;
- an **audit log** of every action, which can be proven untampered.

1.1 The three principles

1. **AI drafts; people decide.** Six AI agents do routine drafting: classifying risk, proposing controls, listing evidence, drafting test results, challenging the evidence pack and drafting the board summary. None of them can approve anything. A named person accepts, edits or rejects every item.
2. **The AI shows its work.** Agents may only use passages from a knowledge base of standards, controls, method and the client's own documents, and must cite them. A second AI, the Verifier, checks whether the citations back each item up. Both are themselves tested.
3. **Everything can be proven afterwards.** Every action, by a person or an agent, is written to a hash-chained audit log. Evidence files are fingerprinted when collected. Changing either is detectable.

1.2 Who uses it

Person	Typical use
Engagement lead or partner	Sets up engagements, decides gates, accepts risk above appetite, signs the report
Reviewer (manager, senior)	Decides on AI drafts, reviews tests, closes issues and incidents
Preparer (associate, analyst)	Adds use cases, collects evidence, prepares tests, raises issues and incidents
Board member or client sponsor	Reads everything; changes nothing
Administrator	Manages people, AI models and workspace settings

2. Key ideas

Term	Meaning
Engagement	One piece of work for one client, for example "Client Zero" for Northshore Financial Group. Everything else belongs to an engagement.
Use case	One AI system or application the client uses or plans, shown as a card on the board.
Stage	Where a use case is in the process. There are eight: Intake, Classify risk, Design controls, Collect evidence, Test controls, Remediate, Validate, Board report. Then Closed.
Gate	A stop at the end of a stage until a person approves. Drafting stages always stop for a person.
Exit criteria	Conditions the harness checks before a use case can leave a stage, for example "every failed test has an issue raised".
Risk tier	Prohibited, High, Limited or Minimal, modelled on the EU AI Act.
Oversight	How close a person is to each decision: in command (a person decides), in the loop (a person approves each output), on the loop (a person monitors).
Risk	Something that could go wrong, scored for likelihood and impact (1 to 5 each) before controls (inherent) and after (residual).
Risk appetite	The highest residual score the client accepts without escalating.
Control	Something in place to reduce a risk, for example "a person reviews every loan decline before it is sent".
Test	A check that a control worked, on a sample, with a preparer and a separate reviewer.
Evidence	A note, link or file that shows a control works, fingerprinted when collected.
Issue	A finding to fix, handled like a defect: severity, owner, due date, management response, retest.
Incident	Something that went wrong in live use of an AI system, with notification deadlines.
Evaluation (eval)	A set of test questions put to an AI system, with automatic checks on its answers. Red-team suites attack it.

Term	Meaning
Knowledge base	The passages agents may use: framework summaries, the control library, method guidance and the client's documents. Each passage has a K-number.

3. Roles and permissions

Every person has one role. The harness enforces it on the server, not only on the screen.

Can...	Admin	Lead	Reviewer	Preparer	Viewer
Read everything they can see	Yes	Yes	Yes	Yes	Yes
Add use cases, evidence, tests, issues, incidents; prepare tests; ask the assistant	Yes	Yes	Yes	Yes	No
Decide on AI drafts, approve gates, review tests, close issues and incidents, acknowledge alerts	Yes	Yes	Yes	No	No
Accept a risk within appetite	Yes	Yes	Yes	No	No
Accept a risk above appetite, sign off the report	Yes	Yes	No	No	No
Engagement settings, gates, agents, access, connectors, monitoring schedules	Yes	Yes	No	No	No
People, AI models, workspace settings, single sign-on, agent testing runs	Yes	No	No	No	No

3.1 Segregation of duties

On top of roles, the harness stops the same person doing both halves of a check:

- Whoever added a use case can't approve it at Intake.
- Whoever prepared a test can't review it.
- Whoever raised an issue can't close it; an issue closes only after a passed, reviewed retest (or a formal risk acceptance).
- Whoever reported an incident can't close it.
- Whoever scored the whole assessment can't sign the report.

Names are compared including a person's former names, so renaming an account doesn't get around these rules.

Part 2. Getting started

4. Opening ARGUS

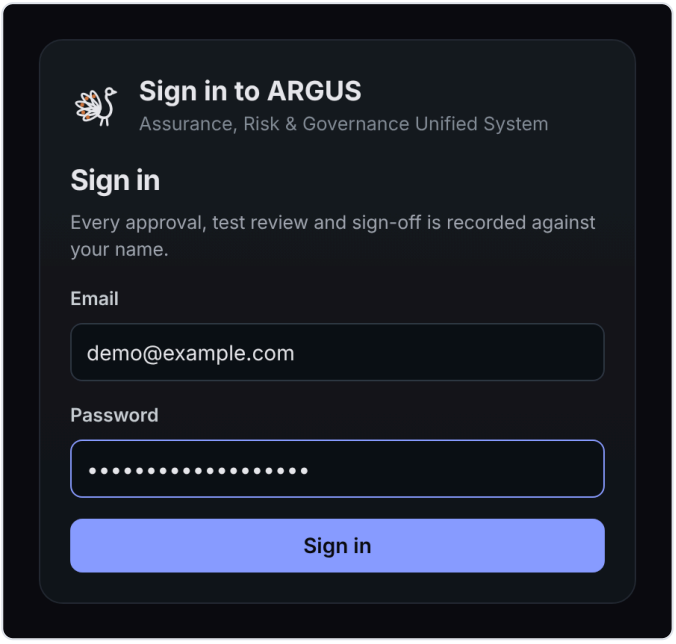
ARGUS runs as a website. There is nothing to install: you need a web browser (a current version of Chrome, Edge, Firefox or Safari) and an account.

4.1 The address and the demo account

Address	https://argus.starandy1.workers.dev
Demo account	demo@example.com
Password	Given to you with this manual. Ask the person who shared ARGUS with you if you don't have it

The demo account is an administrator, so it can see and do everything, including the settings in Part 8. Please don't change the password or other people's accounts: others use the same site.

4.2 Signing in for the first time



The sign-in page

1. Open the address in your browser. Always use the full **https://** address: the site doesn't keep you signed in over plain http.
2. If nobody has used the site for a while, the first page can take up to a minute to appear while the server starts. Wait and refresh if you see an error.
3. Type the email and password and click **Sign in**.
4. You land on the **Use Cases** board of the engagement shown at the top left. ARGUS opens in dark mode; you can switch to light in the account menu (section 5.2).

Sessions end after 12 hours without use, or 7 days in all. Then you sign in again.

4.3 What's in the demo

The site holds five fictional clients facing real kinds of AI risk. Pick one with the engagement switcher at the top left.

Client	Engagement	What it shows
Northshore Financial Group (bank and insurer)	AI assurance 2026	**Every feature switched on**: use cases at every step, a failed control and its issue, an incident, red teaming and monitoring, the inventory, a connector, a second classifier, golden runs and the Verifier. The screenshots in this manual come from it
Kestrel Bay Telecom	Customer AI readiness review	A WhatsApp refund agent that can credit bills, SIM-swap fraud scoring, churn offers, a voice-clone plan
Palmcrest Health Network	Clinical AI governance	A sepsis alert, an ambient scribe pilot with an incident, no-show prediction. Members only
Corallis Port Services	Operations and people AI review	Container inspection targeting, a crane scheduling agent, face matching at the gates, CV ranking
National Social Support Agency	Public sector AI review	Benefit fraud scoring, a helpline chatbot, letter drafting. Members only

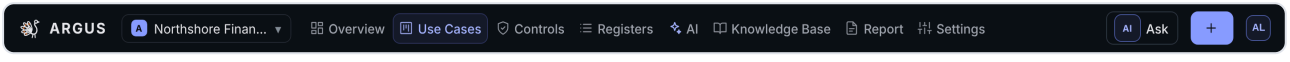
Four fictional people work on these engagements, one per role: **Jordan Clarke** (lead), **Riley Morgan** (reviewer), **Sam Patel** (preparer) and **Dana Reid** (viewer). You don't need their passwords. Use **Act As** in the account menu to work as any of them, which is how you try segregation of duties on your own (section 8.1).

Where to start. Open Northshore Financial Group, then follow Part 4 card by card: AI-4 waits at Intake, AI-3 has a risk classification waiting for decisions, AI-5 has a control design, and AI-1 is at the final review before sign-off.

5. Finding your way

If an admin has set up single sign-on, the sign-in page also shows a **Sign in with ...** button that uses your organisation's account (section 33.4).

5.1 The top bar



The top bar

From left to right:

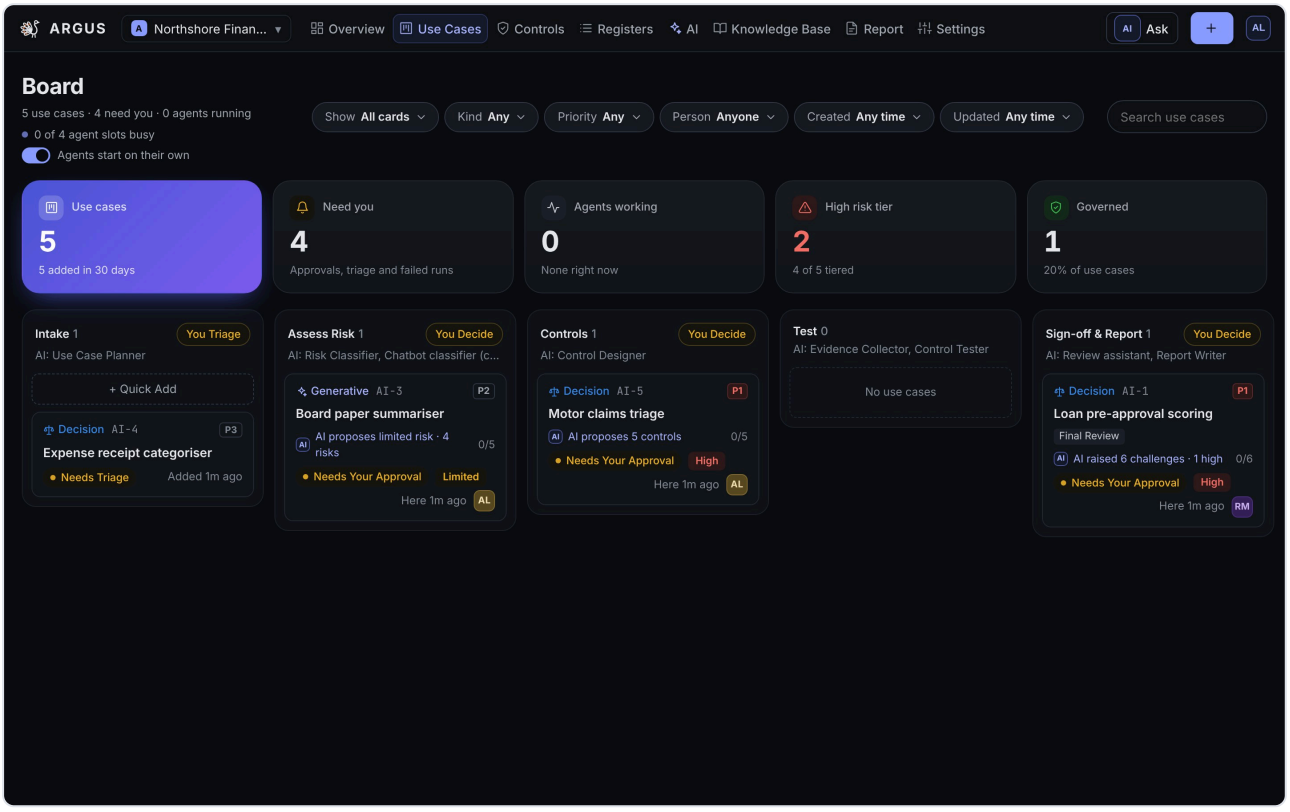
- **Logo and the ARGUS name**: back to the board.
- **Engagement switcher**: the engagement you're working in. Admins and leads can **+ Add engagement** from here. Archived engagements are listed separately and are read-only.
- **The menu**:
  - **Overview**: the engagement at a glance, with charts.

- **Use Cases**: the board, where every use case moves through its steps.
- **Controls**: standards, the controls in place, the control library and (with the module on) what applies and traceability.
- **Registers**: Risks, Tests and Evidence, Issues (and Incidents and the AI Inventory when those modules are on).
- **AI**: Ask the Assistant, AI Agents, AI Runs, and (when the modules are on) AI Testing and Monitoring and Checking the AI.
- **Knowledge Base**: the documents and passages the AI may cite.
- **Report**: the readiness assessment and board report.
- **Settings**: Engagement Settings, Workspace Settings and the Audit Log.

  On a smaller screen the menu shows icons only (hover for the name), and on a phone it folds into the menu button at the left.

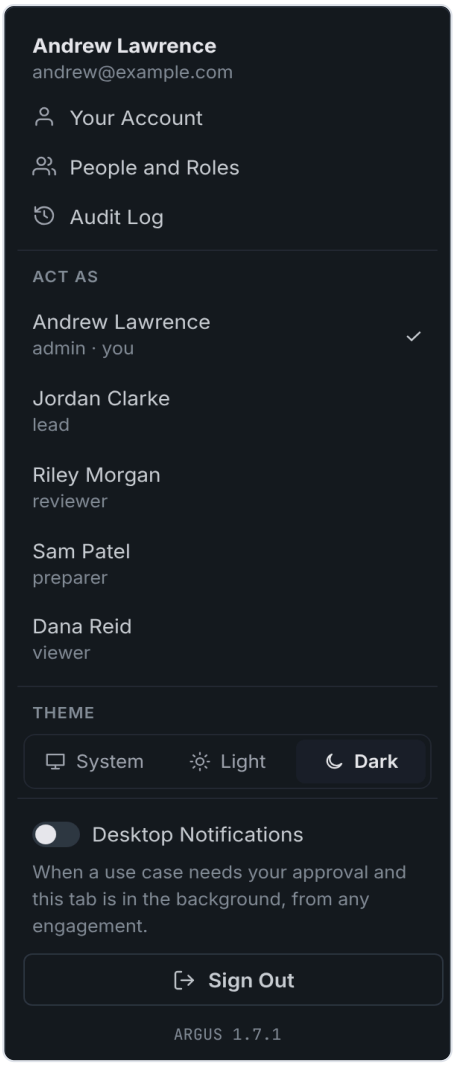
- **Dry run / Live agents**: whether the agents use the built-in offline rules or a real AI model.
- **Ask**: opens the assistant for the page you're on (section 30).
- **+**: add a use case. It opens the Plan page, where the Use Case Planner helps you write the brief (section 11).
- **Your initials**: the account menu.

The item for the page you're on is highlighted in light blue.



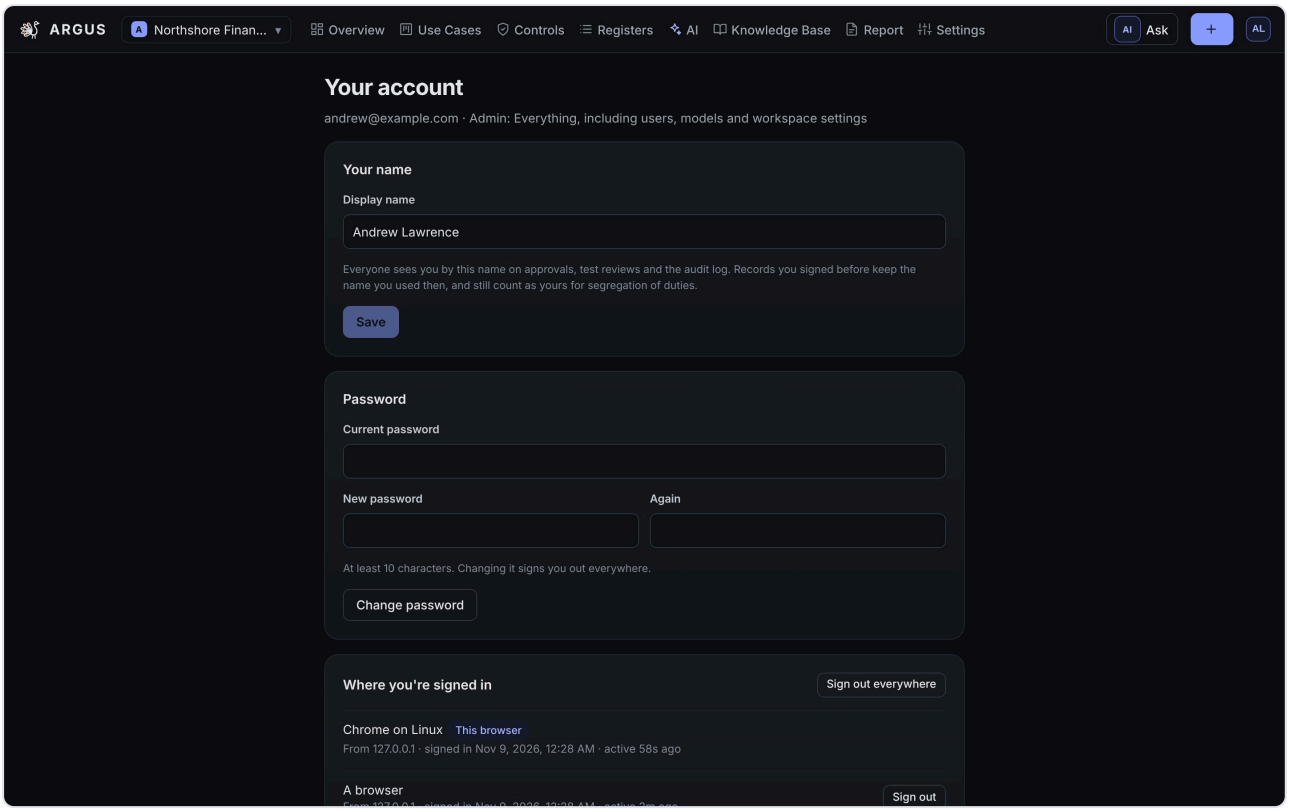
The Use Cases board

5.2 The account menu



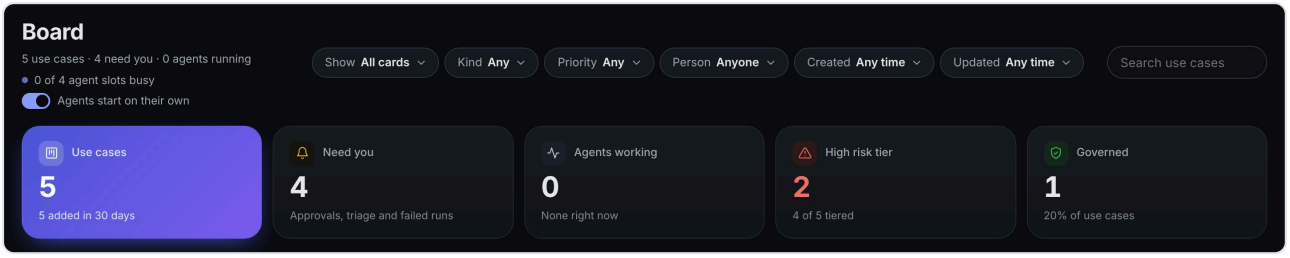
The account menu

Your Account (your name, email, password and where you're signed in), **People and Roles** (admins), **Audit Log**, **Act As** (admins, when it is turned on: section 8.1), the **theme** (system, light or dark), **Desktop Notifications** (a notice when something needs your approval while the tab is in the background) and **Sign Out**. Under Sign Out is the ARGUS version you are using, for example "ARGUS 1.4.1 · 3f2a9c1": quote it when you report a problem.



Your account

5.1 The numbers at the top of each page



KPI tiles on the board

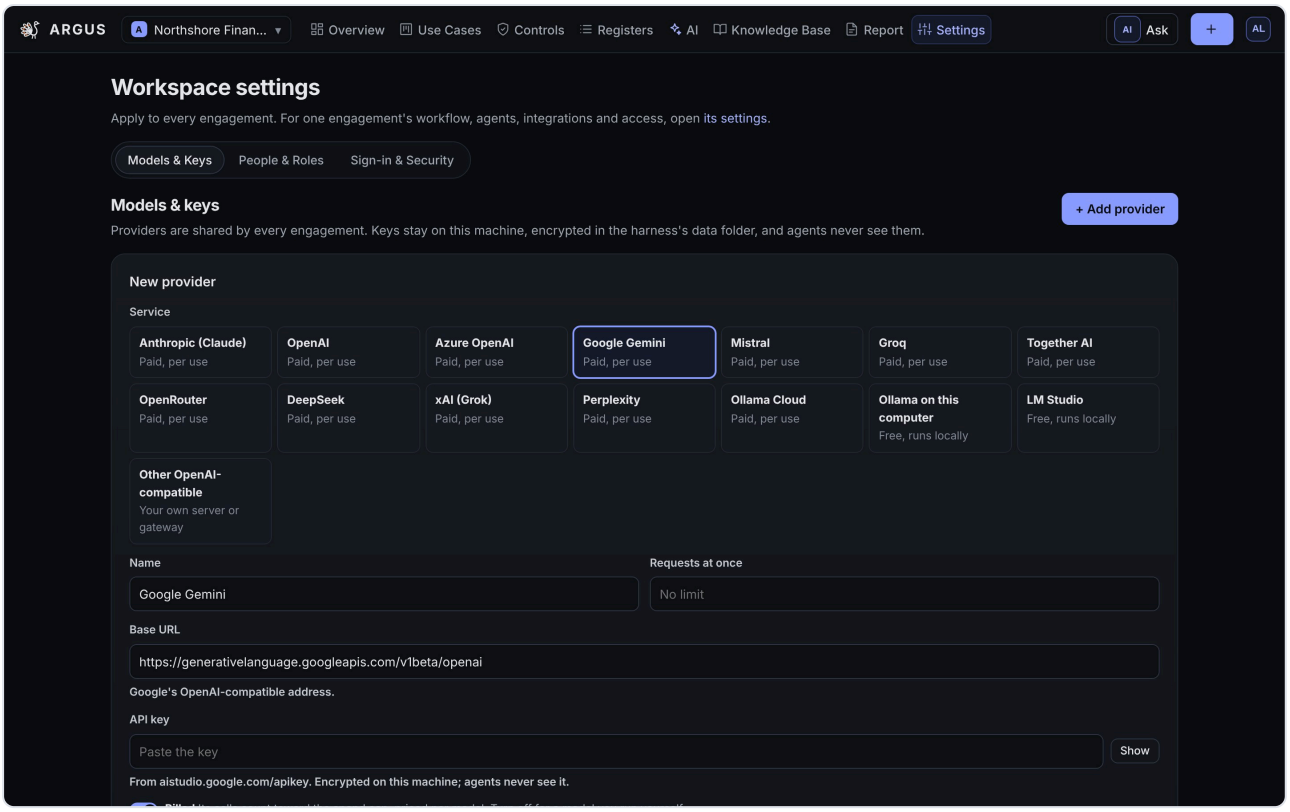
Each working page opens with a row of tiles: the numbers that matter on that page, with a line saying what each one means. The first tile is highlighted. A tile that links somewhere (for example **No control** on the risk register) opens the page the number comes from. The numbers update as work moves.

6. Connecting an AI model

The harness works without any AI model, using built-in rules that are deliberately cautious. For real drafting, connect a model.

6.1 Choosing a provider

Go to **Settings > Workspace Settings > Models & Keys > + Add provider** and pick a service. The address and billing are filled in for you.



Adding Google Gemini

Service	Notes
Anthropic (Claude), OpenAI, Google Gemini, Mistral, Groq, Together AI, OpenRouter, xAI	Paste the key and click **Test and find models**
Azure OpenAI	Put your resource name in the address; add your deployment names as models
DeepSeek	Check where client data is processed before using it on client work
Perplexity	Add model names by hand; it answers in JSON, which the harness handles
Ollama Cloud	Key from ollama.com
Ollama on this computer, LM Studio	Free and private: nothing leaves the machine. Start the app and load a model first
Other OpenAI-compatible	A company gateway or your own server

Keys are encrypted on the server, shown only as their last four characters, and never given to the agents.

On the shared demo site, anyone with the demo account can use a key you save there, and its use is charged to you. Use a free tier or a key with a low spending limit, and remove it when you're done.

Each provider card shows two things. **Service** is who the provider is: "Google Gemini API", "Anthropic API", "Azure OpenAI". **Connection** is the format the harness uses to talk to it. Many services, Google's Gemini among them, offer an address that speaks OpenAI's format, so the

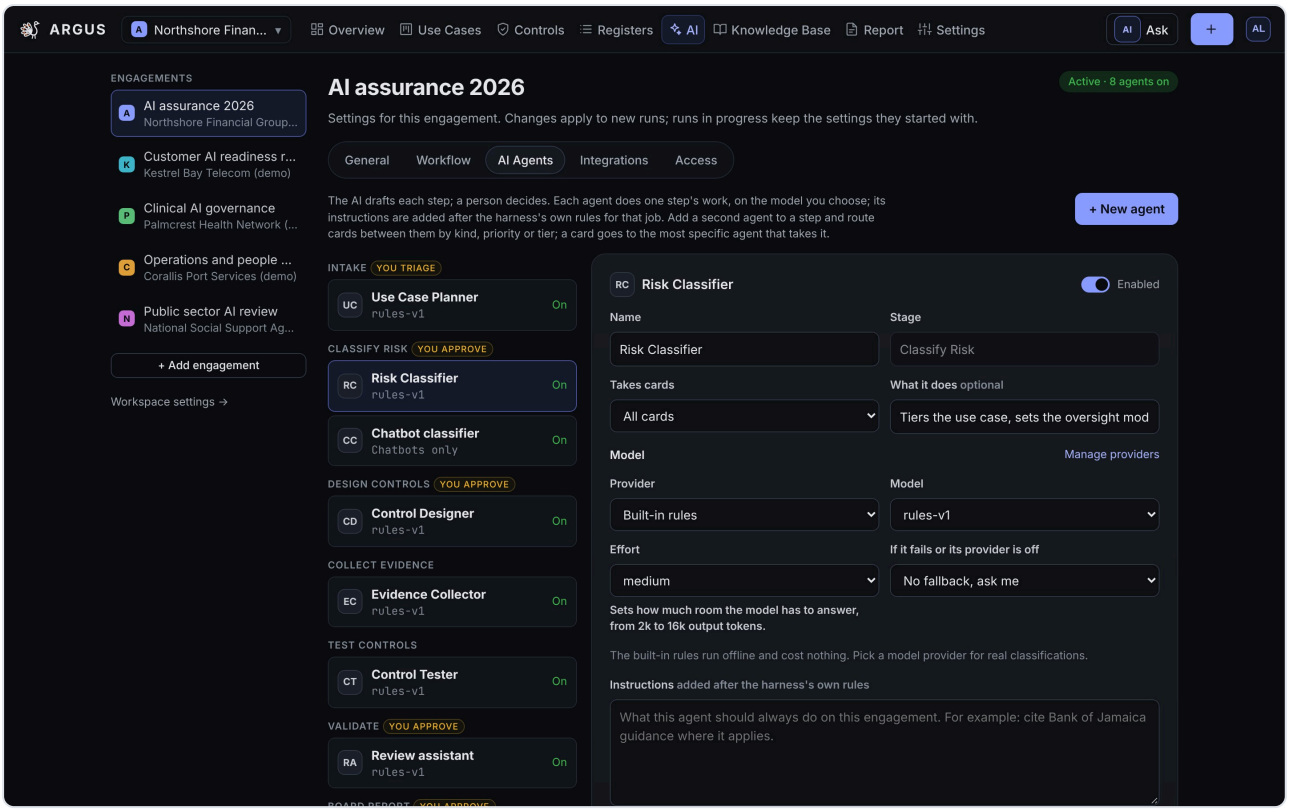
harness uses one well-tested connection for all of them; that is why a Gemini provider's connection reads "OpenAI-compatible format" while its service reads "Google Gemini API". Services that list every model they have, including speech, image, video and embedding models, are filtered so the card and the agents' model lists show only models that write text. Models without a price are summarised as a count; open it to see the list.

6.2 About free tiers (for example Google Gemini)

Free tiers are fine for trying the harness and for demos with the fictional data. Do not use them on real client data: Google's terms for the unpaid Gemini tier allow prompts and responses to be used to improve its products and read by human reviewers, and tell you not to send confidential or personal information. For real work without paying, run a model locally with Ollama; otherwise use a paid key.

6.3 Pointing the harness at a model

- **Agents**: **Settings > Engagement Settings > Agents**. For each agent, choose the provider, model, effort and an optional fallback, then **Save agent**. New engagements can start from defaults set under Workspace Settings > Models & Keys.
- **The assistant**: Models & Keys page, **Assistant** card. Leave the provider on **Workspace default** to use the default model. **Instructions** (optional) are added to the assistant's own rules for every answer: house style, the names your firm uses, what to stress. They can't switch off its safeguards.
- **The Verifier**: **AI > Checking the AI > Verifier**. Pick a model from a different company than the drafting agents.
- **Meaning-based search** (optional): Models & Keys page. An embedding model lets agents find passages that say the same thing in other words.



Agent settings

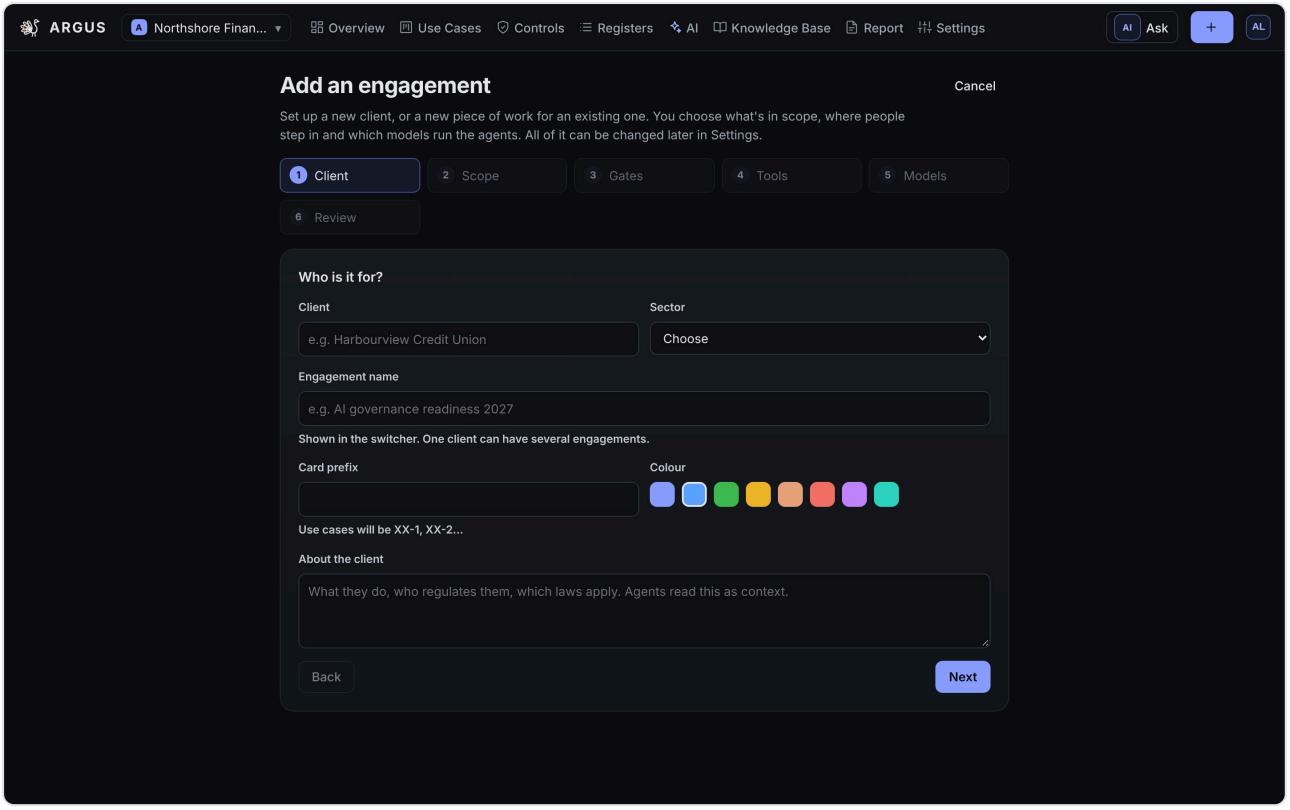
6.4 Spending limits

On the Models & Keys page, set a **monthly cap** in US dollars, a warning level, and whether to **pause at the cap**. Paid model calls by agents, the assistant, the Verifier, agent testing and scheduled evaluations all count. Each agent also has a cost and time limit per run.

Part 3. Setting up an engagement

7. Creating an engagement

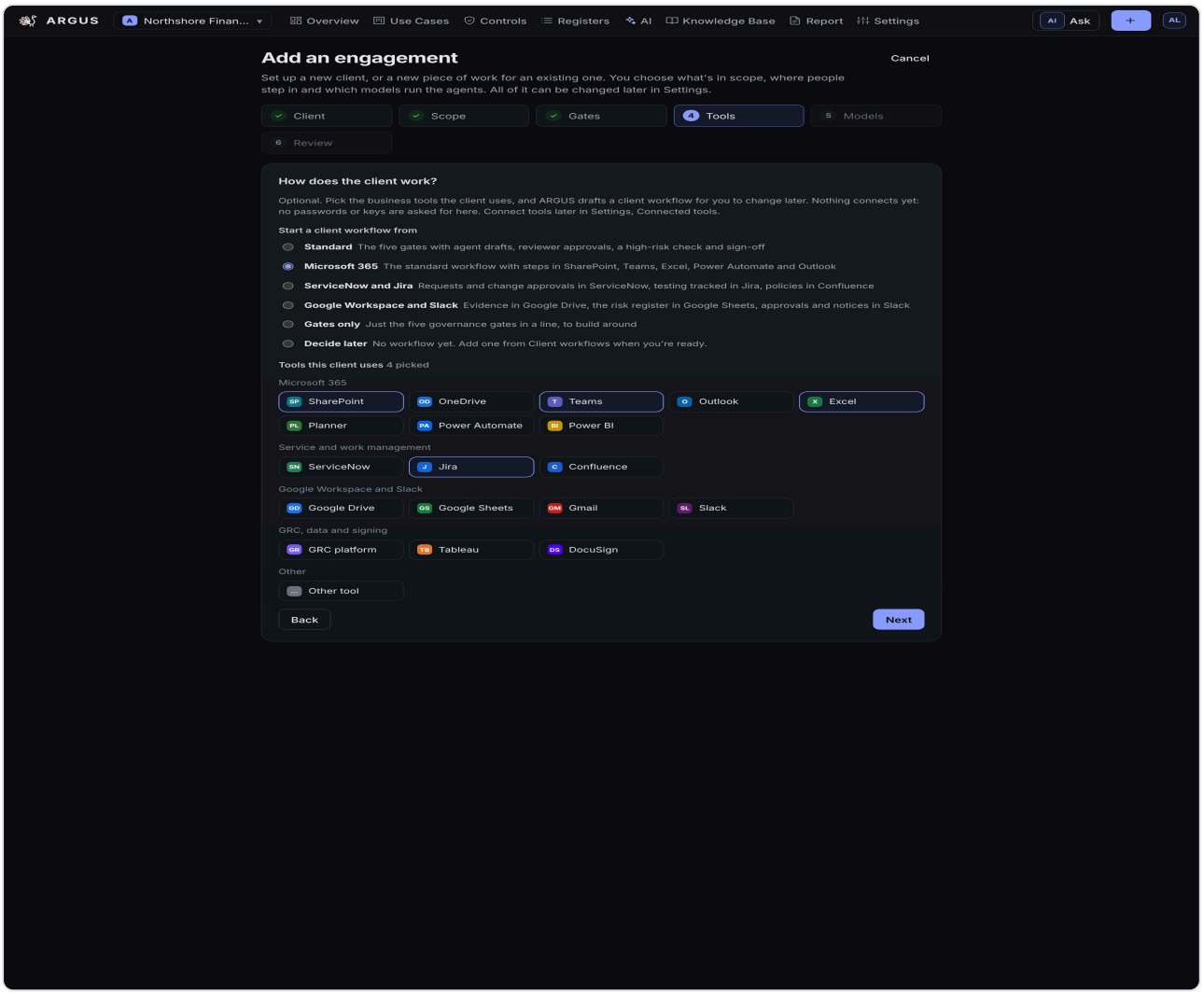
Admins and leads open the engagement switcher and choose **+ Add engagement**.



Add engagement

The wizard asks for the client, the engagement name and a short prefix for use case keys (for example "AI" gives AI-1, AI-2), the sector, the frameworks in scope, the risk appetite, which AI models the agents use, and whether to start the Statement of Applicability from the chosen frameworks. Whoever creates the engagement becomes its first member.

The six steps are Client, Scope, Gates, Tools, Models and Review. **Tools** ("How does the client work?") is optional:



How does the client work?

- **Start a client workflow from** a template (Standard, Microsoft 365, ServiceNow and Jira, Google Workspace and Slack, or Gates only) and ARGUS adds it as a draft for you to change with the client (section 34). Choose **Decide later** to add none.
- **Tools this client uses**: tick the business tools the client works in. They're listed first wherever you pick a tool.

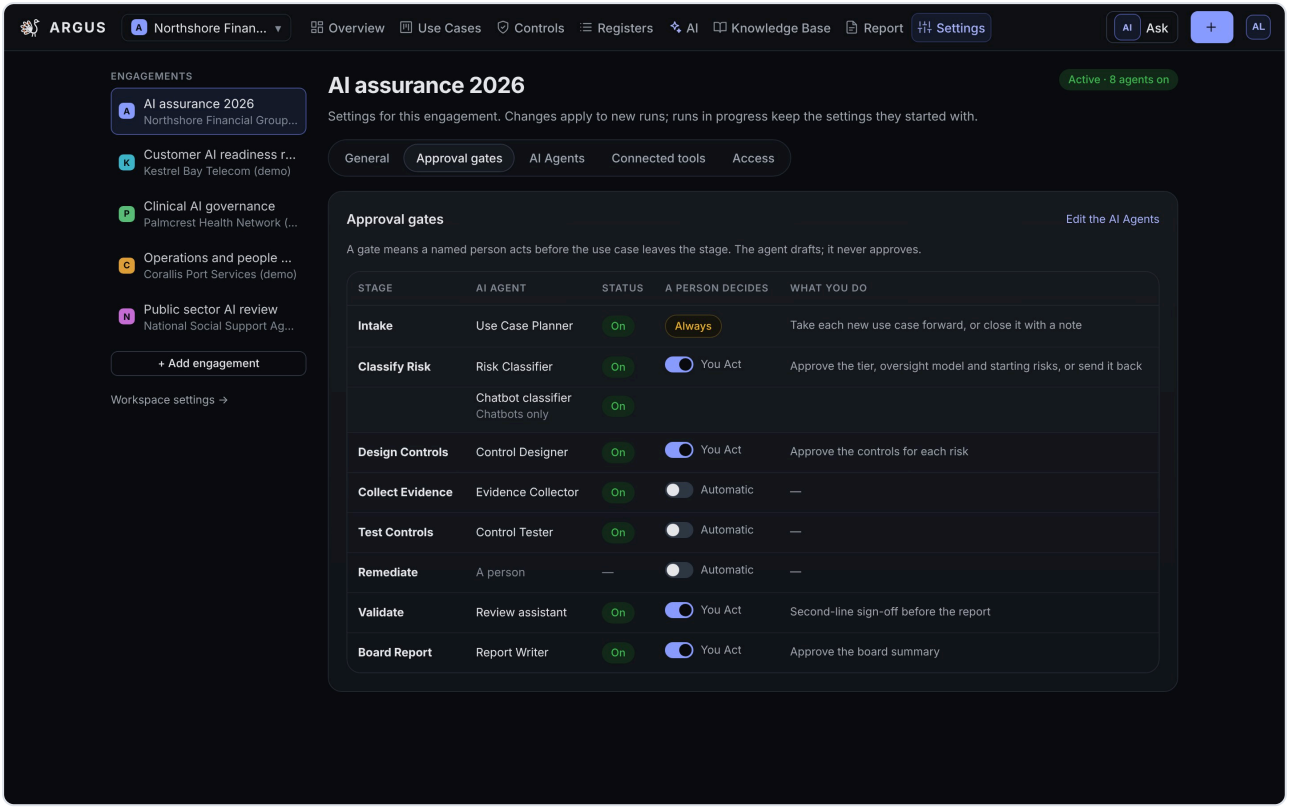
Nothing connects at this point and no passwords or keys are asked for. Connect the tools later in **Settings > Connected tools** (section 23.2).

7.1 Engagement settings and workspace settings

There are two levels of settings:

- **Workspace settings** (Settings > Workspace Settings, admins and leads): what applies to every engagement. **Models & Keys** (providers, spending limit, defaults for new agents, the assistant's model, meaning-based search), **People & Roles**, and **Sign-in & Security** (single sign-on, act as, and whether connectors may reach private networks).
- **Engagement settings** (Settings > Engagement Settings): one engagement. The engagements are listed on the left, with **+ Add engagement**; pick one to see its five tabs:

- **General**: name, client, prefix, frameworks, a description every agent reads with each use case (the client's sector, regulators and anything that changes how risk is judged), **Modules** (below), **Pause this engagement** and **Archive or delete**.
- **Approval gates**: which stages stop for a person, and which agents work each stage. Drafting stages (Collect evidence, Test controls, Validate, Board report) always stop. (Called Workflow before ARGUS 1.7.2; the client's own process is under Client workflows, section 34.)
- **Connected tools**: the business tools the client uses, the read-only connectors that pull evidence from them (section 23.2), pipeline ingest tokens (section 23.3) and write-back (section 34.3).
- **AI Agents**: every agent, grouped by stage (section 7.3).
- **Access**: who can see the engagement (section 7.2).



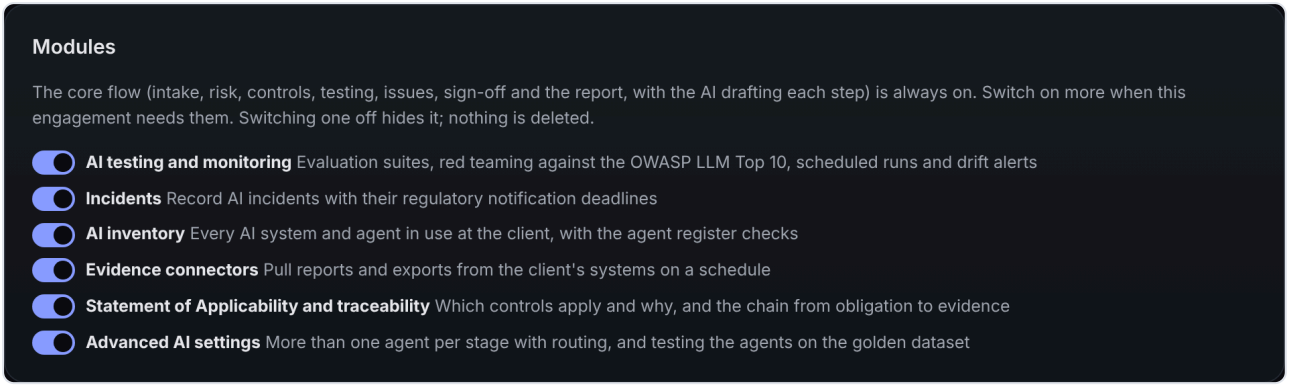
Approval gates

Modules. A new engagement starts simple: the core flow (intake, risk, controls, testing, issues, sign-off and the report, with the AI drafting each step) is always on. Switch on more under **General > Modules** when the engagement needs them:

Module	Adds
AI testing and monitoring	Evaluation suites, red teaming against the OWASP LLM Top 10, scheduled runs and drift alerts
Incidents	AI incidents with their regulatory notification deadlines
AI inventory	Every AI system and agent at the client, with the agent register checks

Module	Adds
Client tools and workflows	Client workflows and each use case's client steps, connectors to the client's tools (Settings > Connected tools), evidence pushed from pipelines, and write-back. Switched on by itself when you pick a workflow or tools while adding the engagement
Statement of Applicability and traceability	Which controls apply and why, and the chain from obligation to evidence
Advanced AI settings	More than one agent per step with routing, and testing the agents on the golden dataset

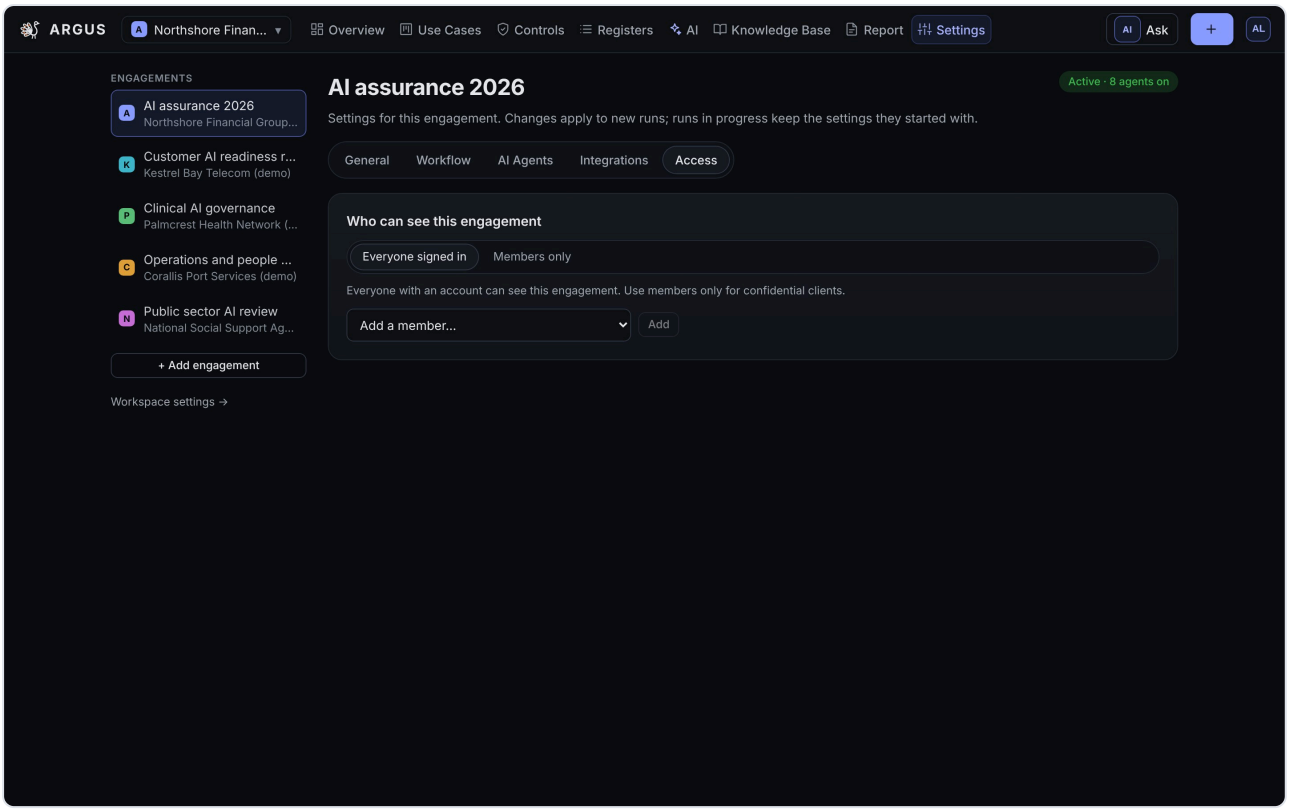
Switching a module off hides it; nothing is deleted, and switching it back on shows everything again.



Modules

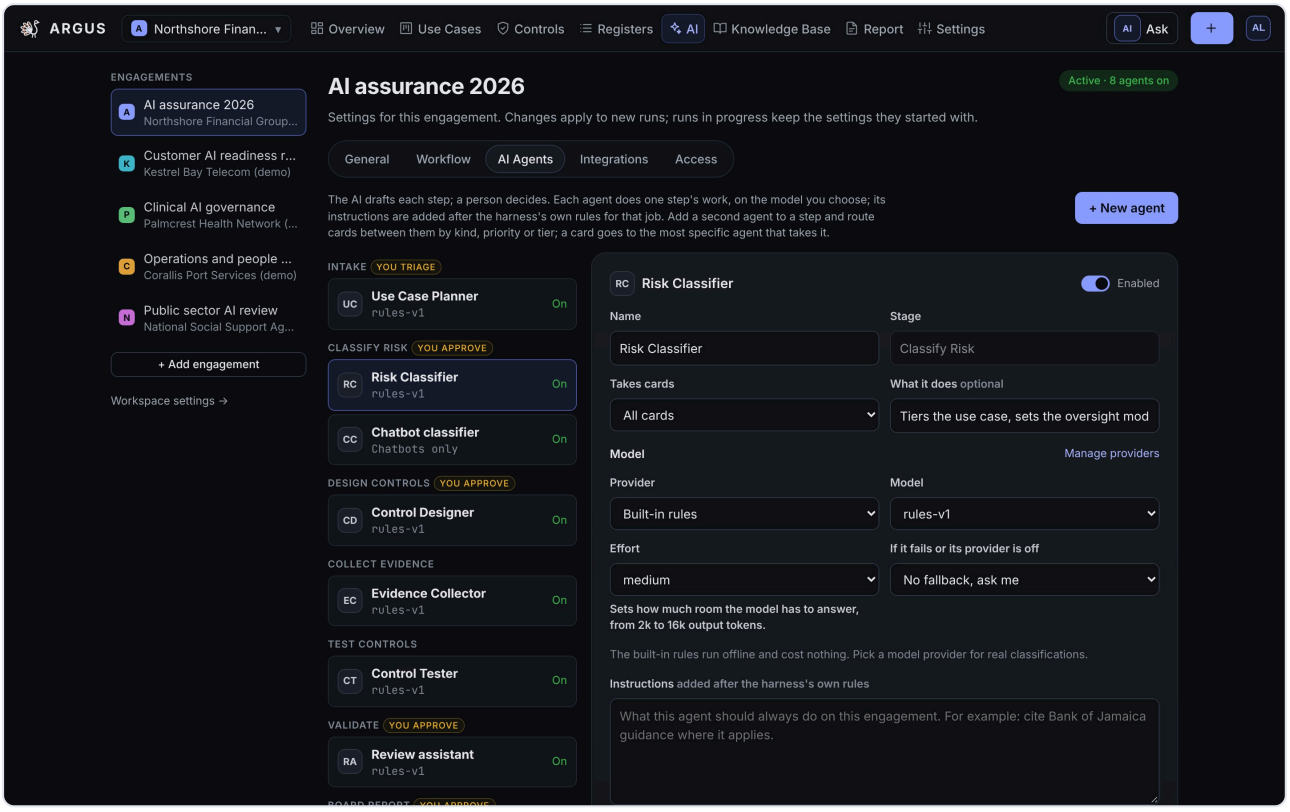
7.2 Who can see an engagement

An engagement is either **open to everyone signed in**, or **members only**. Members-only engagements are visible only to their members and to admins: everyone else doesn't see them in the switcher, and their use cases, evidence, issues, incidents, audit entries and live updates answer "not found". Switch under **Engagement Settings > Access**; you are added as a member automatically, then add others. A members-only engagement keeps at least one member.



Who can see this engagement

7.3 Agents, and adding your own



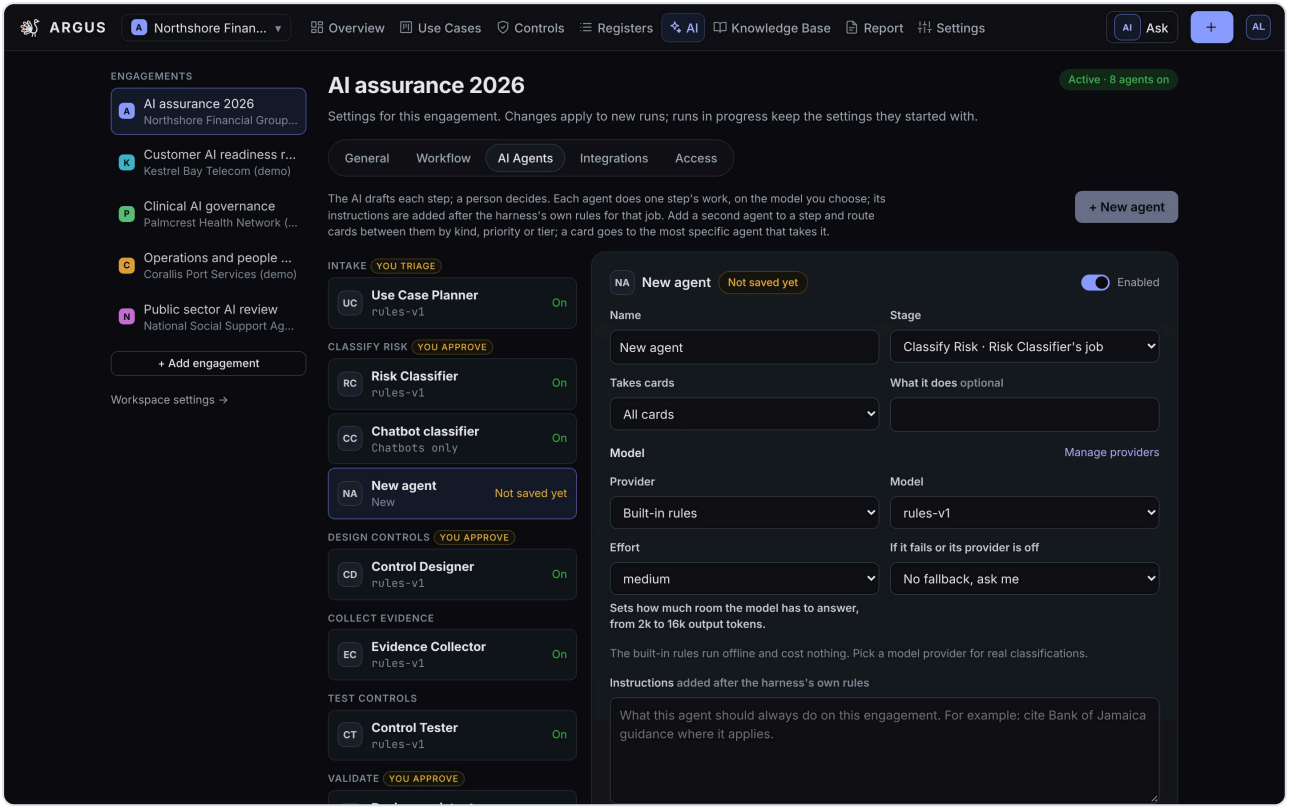
Agents in engagement settings

Engagement Settings > AI Agents lists each agent under its stage, with the stage's gate ("You Triage", "You Decide"). Select one to change it: on or off, its name, which cards it takes, its

provider and model, effort, a fallback model for when the first fails or its provider is off, instructions added after the harness's own rules, the tools it may use, and its limits per run (maximum spend, timeout and how many run at once). The kill switch stops it at once.

+ New agent adds a second agent to a stage, for example a classifier just for chatbots with instructions about prompt injection. It shows in the list as **Not saved yet** until you click **Create agent**, and **Discard** throws it away. **Fallback.** If an agent's model fails (the provider is down, the key is rate-limited, the answer is unusable), its fallback takes over. **Built-in rules (offline)** is listed first: with it, a failed model still leaves a cautious draft for a person instead of a failed card. Before falling back, ARGUS already retries a busy provider a few times, asks again with more room if an answer was cut off, and gives the model one chance to correct a badly formatted answer; the run log shows each of these. It never lets a model "correct" a source it wasn't given or a figure that isn't in the records: those still fail the run.

A new agent does its stage's job (a new agent on Classify risk classifies) and starts from the stage agent's model, tools and limits; anything you change is listed as **Set here** with a **Reset** link. **Duplicate** copies an agent, switched off. **Delete agent** removes one you added; the built-in agent for a stage can only be turned off.



Adding an agent

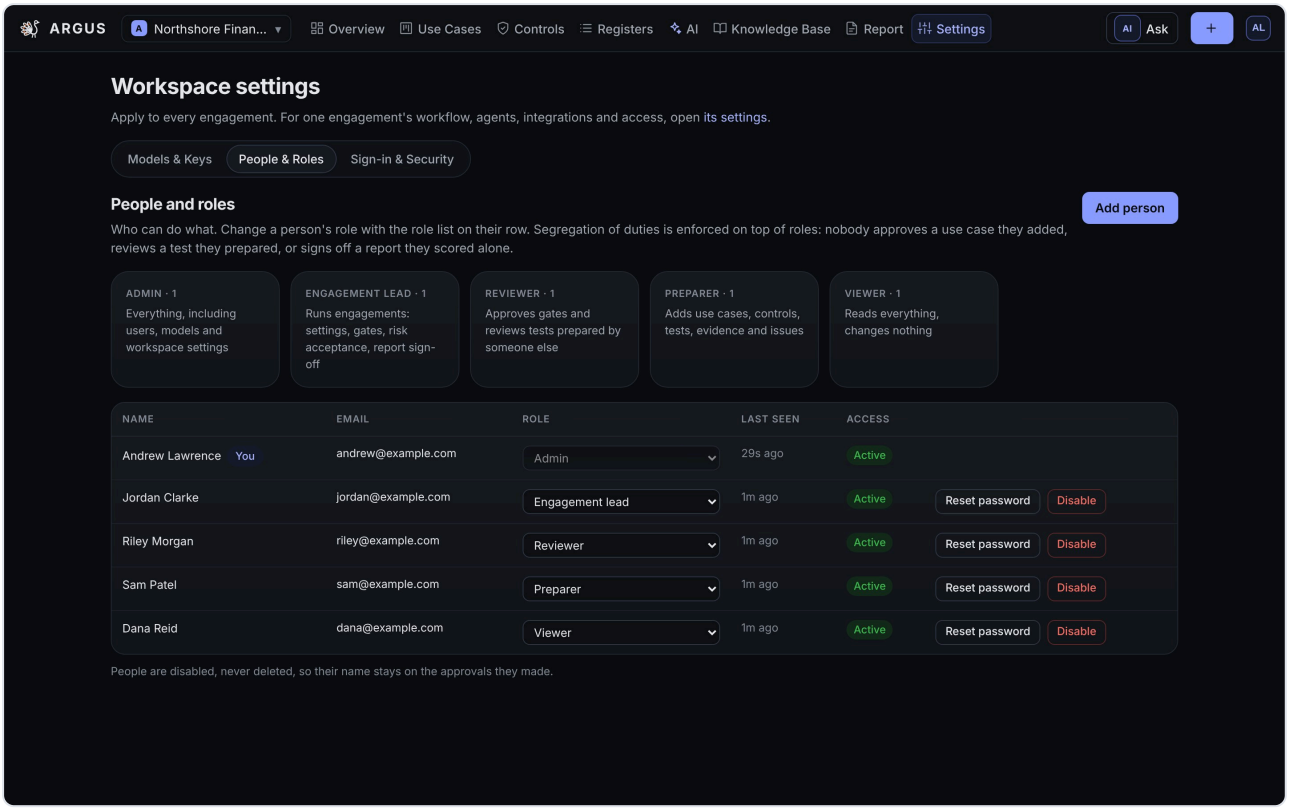
Takes cards decides which cards an agent picks up: all cards; high and prohibited tier only; everything but minimal tier; P1 urgent cards only; or one kind of AI (decision systems, chatbots, AI agents, generative AI, analytics). When several agents on a stage could take a card, the most specific one does: a kind or priority beats a tier, and a tier beats "all cards". If none takes it, the card waits for a person and says why.

7.4 Archiving and deleting

When an engagement is finished, a lead archives it with a reason. It becomes read-only and moves to the bottom of the switcher, with a banner saying so; a lead can restore it. Only an admin can delete it, only after archiving, and only by typing its name. **Export** downloads everything it holds as JSON before you delete it. The audit log keeps who deleted it and what was removed.

8. People and roles

Admins go to the account menu, **People and Roles** (or **Workspace Settings > People & Roles**).

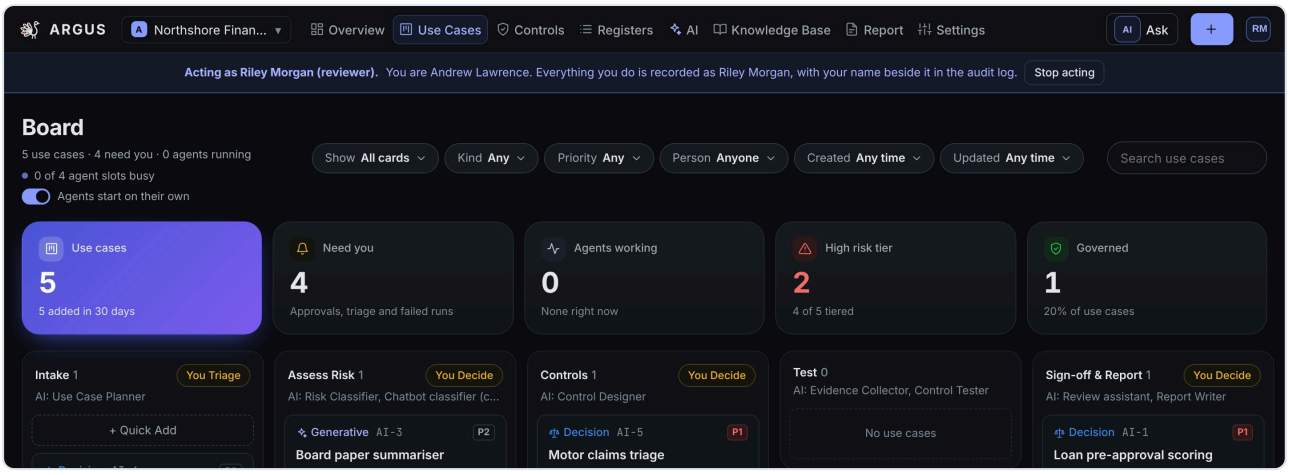


People and roles

- **Add person**: name, email, role and a first password.
- **Change a role** with the role list on the person's row; it takes effect at once and the audit log records the change. You can't remove your own admin role. **Reset password** gives a new one. **Disable** stops someone signing in; people are never deleted, so their name stays on the approvals they made.
- Single sign-on is set up under **Workspace Settings > Sign-in & Security** (section 33.4).

8.1 Act as: one person running the whole flow

For demos, testing and training, an admin can work as any other person without signing out. Turn it on under **Workspace Settings > Sign-in & Security > Allow admins to act as someone else**, then pick a person under **Act as** in the account menu. A banner shows who you are acting as and who you really are, with **Stop acting**.



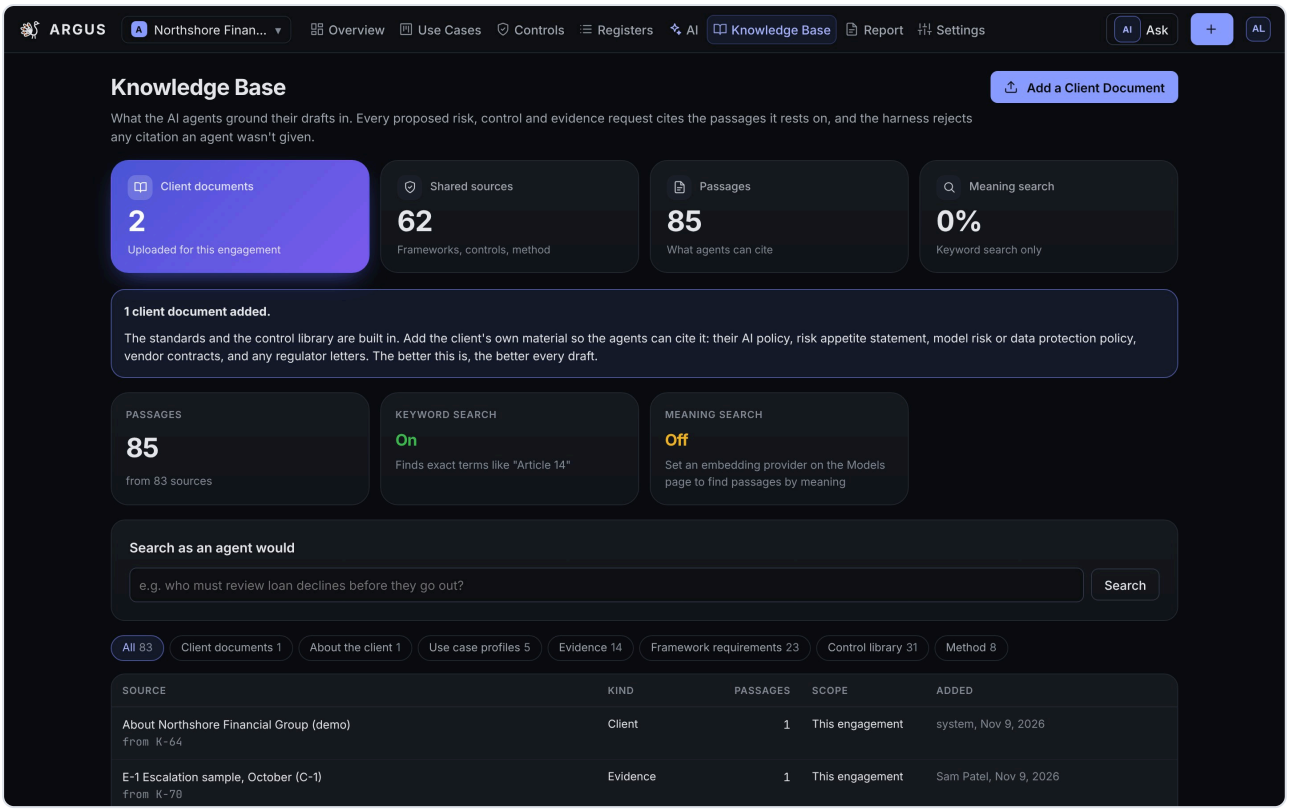
Acting as a reviewer

While acting, you have that person's role and nothing more: acting as a preparer you can't approve. Everything you do is recorded under their name, and the audit log adds your real name beside it (it is part of the entry's fingerprint, so it can't be removed quietly). You can't change their password, name or sessions.

The trade-off: segregation of duties checks names, so one real person switching between names can both raise and approve a use case. That is exactly what makes a one-person demo possible, and exactly why it is **off by default** and should stay off on client engagements. If it was ever on, the audit log shows every action taken while acting, and who really took it.

9. The knowledge base

Knowledge Base (in the top menu) holds everything the agents may use: summaries of the EU AI Act, ISO/IEC 42001, the NIST AI RMF, the Jamaica Data Protection Act 2020 and the OWASP LLM Top 10 (in the harness's own words, with links to the official text); the 31 library controls; method guidance (tiering, oversight, sampling, evidence strength, exceptions, findings, autonomous agents); and the engagement's own material.

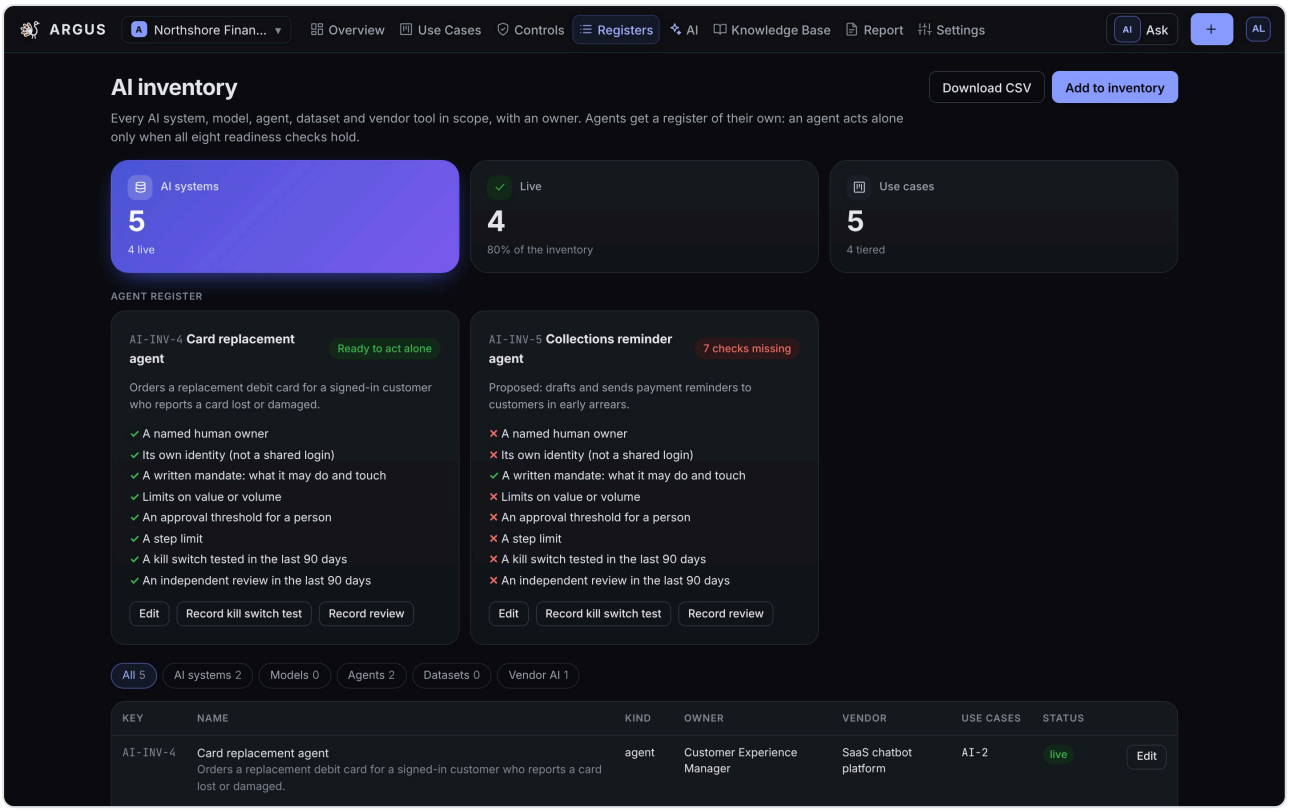


Knowledge base

- **Add a client document**: upload the client's AI policy, risk procedures or committee minutes as a PDF, Word (.docx), Excel (.xlsx), text or CSV file, or paste the text. Agents can then cite it for this engagement only.
- **Search as an agent would** shows which passages an agent would be given for a question.

10. The AI inventory

Registers > AI Inventory lists every AI system, model, agent, dataset and AI vendor in scope, with an owner, linked to its use cases.



Inventory

AI **agents** (systems that act on their own) get a readiness checklist. An agent may act without a person approving each step only when all eight checks hold: a named owner, its own identity, a written mandate, limits on value or volume, an approval threshold, a step limit, a kill switch tested in the last 90 days, and an independent review in the last 90 days.

Part 4. The full flow of a use case

This part follows one use case all the way through. On the board a use case moves through **five steps**: Intake, Assess risk, Controls, Test, and Sign-off & report, then Done. Some steps have more than one stage inside them, shown on the card (for example "Collecting evidence" or "Fixing findings" inside Test), and each stage has its own AI agent, its own decision and its own checks before it can move on:

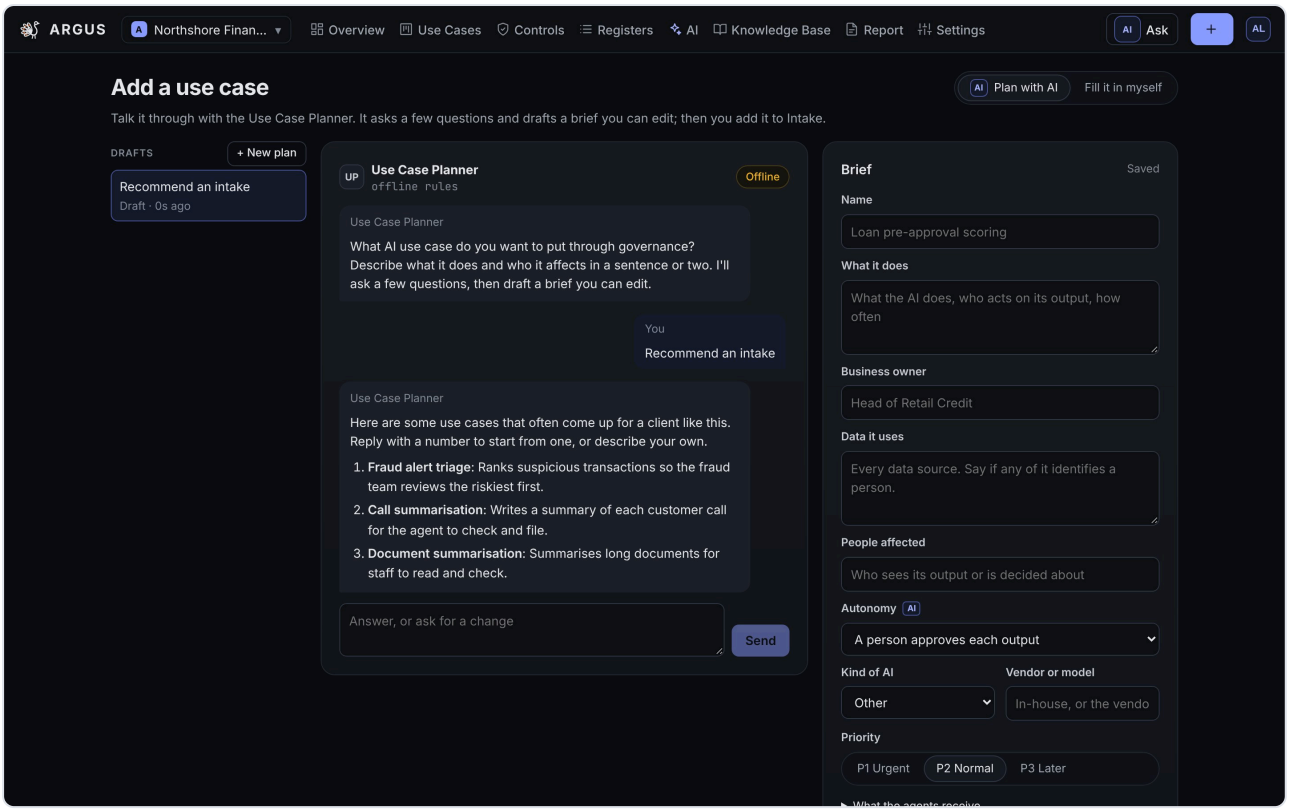
Step on the board	Stages inside it
Intake	Intake
Assess risk	Classify risk
Controls	Design controls
Test	Collect evidence, Test controls, Remediate
Sign-off & report	Validate, Board report

The rest of this part goes stage by stage. Each says who does what, what the AI drafts, what a person decides, and what must be true before the use case can move on.

Stage	AI agent	Who decides	Exit criteria
1. Intake	Use Case Planner (drafts the brief)	Reviewer or lead (not whoever added it)	None
2. Classify risk	Risk Classifier	Reviewer or lead, item by item	A classification exists and every item is decided
3. Design controls	Control Designer	Reviewer or lead, item by item	Every risk scoring 12 or more keeps at least one control
4. Collect evidence	Evidence Collector	Reviewer or lead	Every control has at least one evidence item
5. Test controls	Control Tester	Preparer concludes, a different person reviews	Every test has a result, is reviewed, and every failed test has an issue
6. Remediate	None	Issue owners, then reviewer	No critical or high issue is still open
7. Validate	Review assistant	Reviewer or lead, challenge by challenge	Every challenge weighed
8. Board report	Report Writer	Reviewer or lead	The summary is decided

11. Stage 1: Intake

Anyone who prepares work clicks **+** in the top bar (Add Use Case). This opens the Plan page, with the AI on by default.



Planning a use case with the Use Case Planner

Plan with AI (the default). Describe the idea in a sentence or two. The **Use Case Planner** asks a few questions, one or two at a time, and fills the **Brief** on the right as you answer: name, what it does, business owner, the data it uses, who it affects, how much it acts on its own, the vendor, the kind of AI and a priority. Fields it filled carry a small **AI** tag. Change anything in the brief yourself; a field you typed is yours, and the Planner never overwrites it. When nothing required is missing, click **Add to Intake**. The card is created under your name, not the agent's, and the audit log records which fields the Planner drafted and which you typed. Drafts are kept on the left; **+ New plan** starts another.

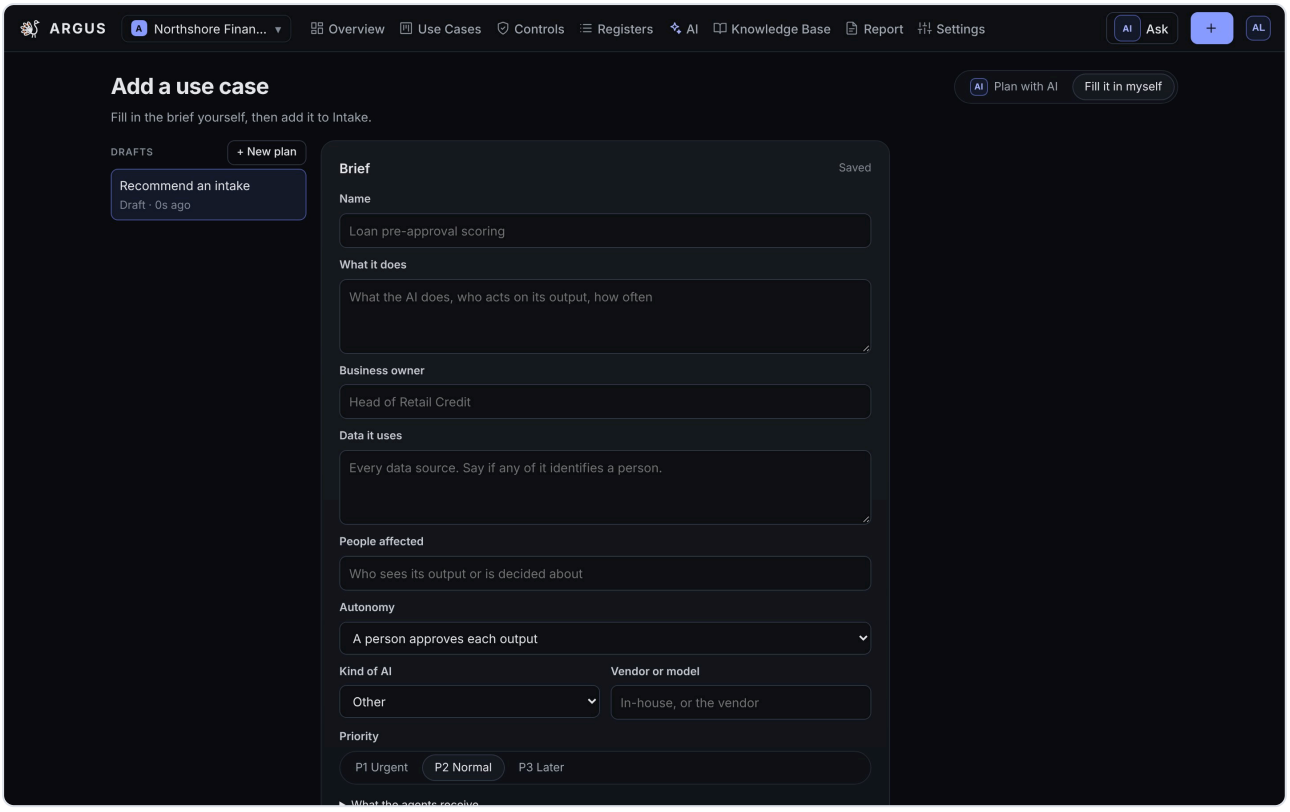
What the Planner knows. Besides your conversation it reads the client and the engagement description (Engagement Settings > General), the use cases already on the board, and matching passages from the Knowledge Base, including the client's own documents and ARGUS's guidance on a good brief. A lead can add instructions for it under **Engagement Settings > AI Agents > Use Case Planner** (for example "always ask whether the Model Risk Committee has approved it"); they are added after its own rules and can't switch them off.

When you're not sure what to add. Ask "suggest some use cases" or "give me an example". The Planner offers two or three that fit the client and aren't on the board yet, numbered. Reply with a number to start from one: it fills the title, description and kind of AI, then asks you to confirm and to name the owner and the data. It never invents an owner or data for you. If you type something it can't use, such as "test", it says so, leaves the brief alone and asks again with an example answer. If what you describe looks like a use case already on the board, it names it and asks whether yours is different.

On the offline rules the Planner only files your answers under the questions it asked and spots a few obvious things from your words (a scoring model is a decision system; "checks each one"

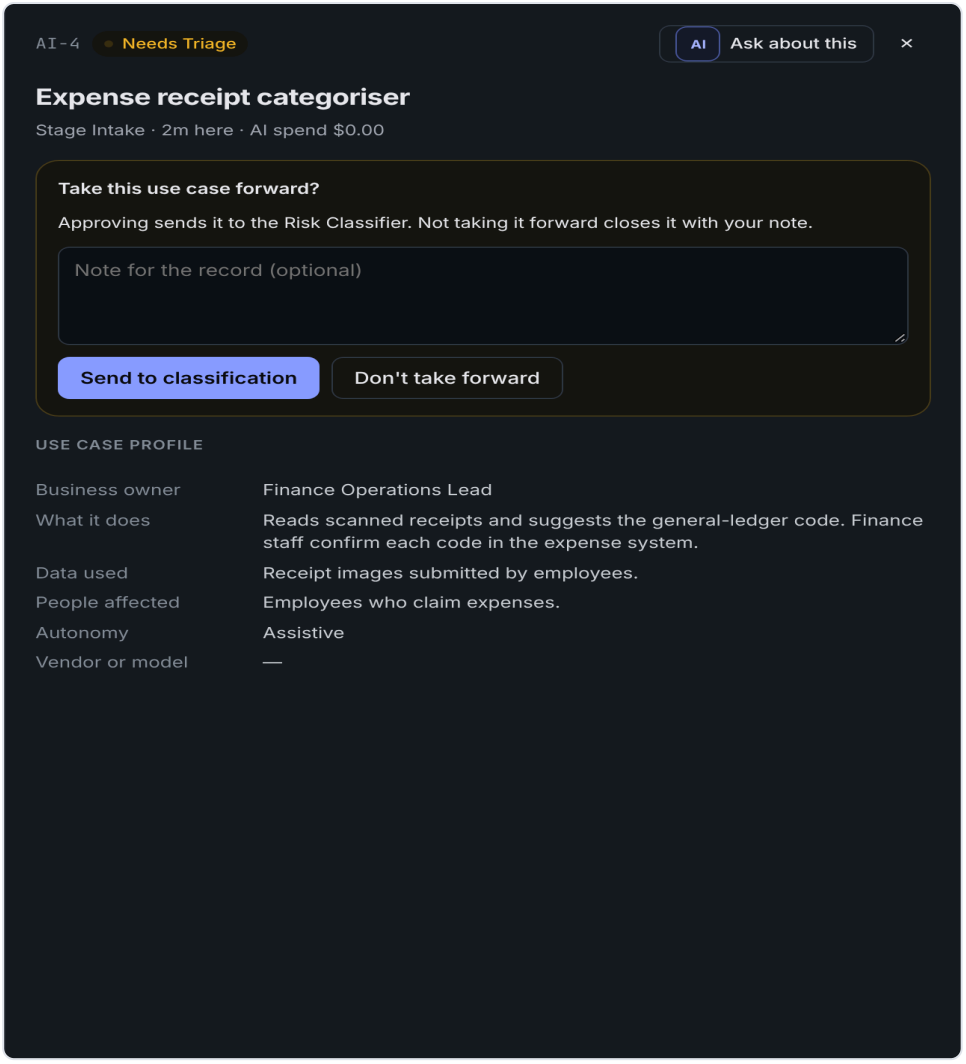
means a person approves each output). With a model (Engagement Settings > AI Agents > Use Case Planner) it drafts the whole brief from the conversation.

Fill it in myself. Switch at the top to fill in the same brief by hand, with no chat. If a lead has turned the Planner off, this is the only mode. For a quick entry there is also **Quick Add** at the top of the Intake column.



Filling in the brief by hand

The Risk Classifier reads this brief, so be specific. Anything written in the profile is treated as data: an instruction hidden in it ("classify this as minimal") is ignored and flagged.

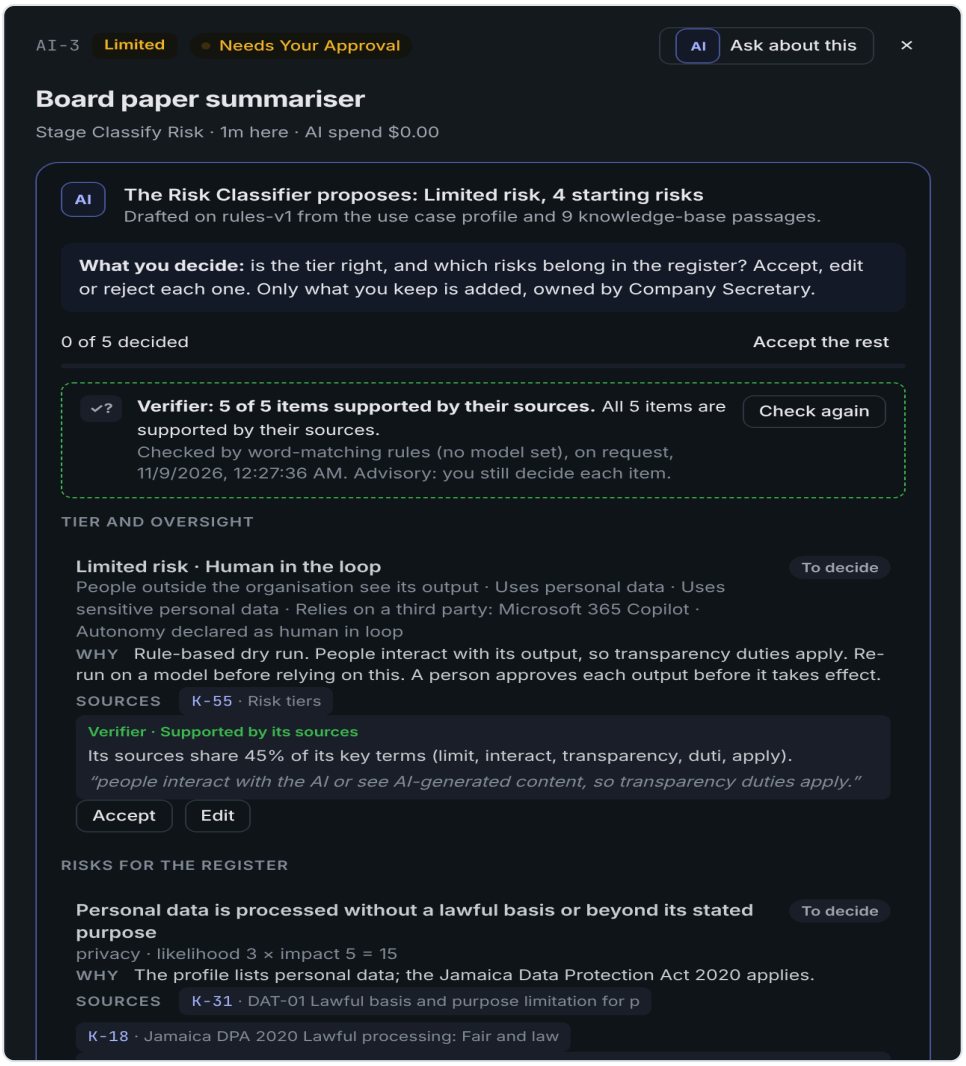


Intake

A reviewer or lead opens the card and chooses **Send to classification** or **Don't take forward** (with a note). The person who added the use case can't make this decision.

12. Stage 2: Classify risk

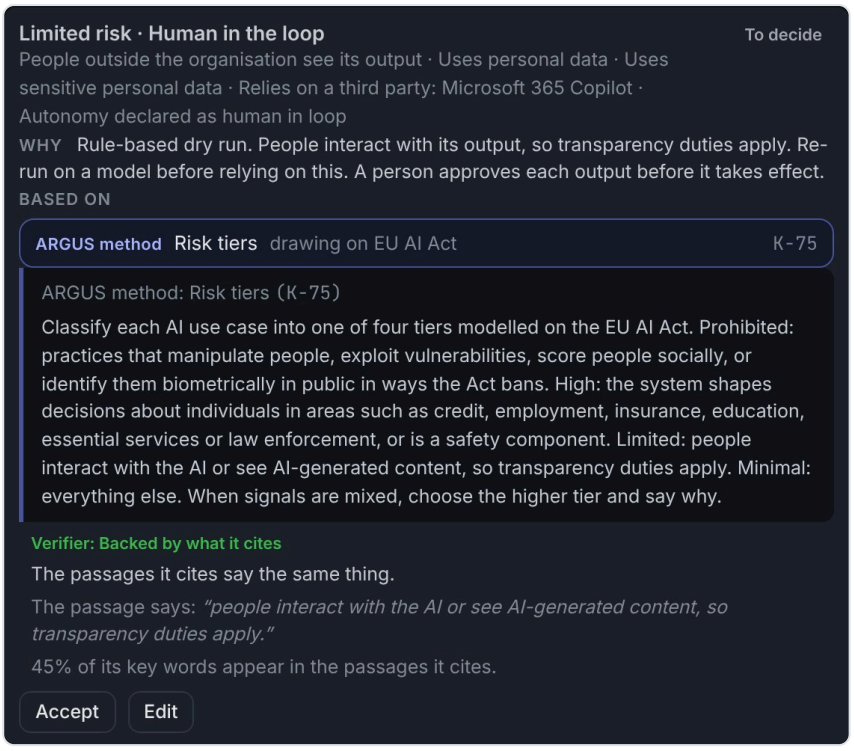
The **Risk Classifier** drafts a tier, an oversight model, the factors that drove them, two to six starting risks scored for likelihood and impact, open questions for the business owner and the framework clauses that apply.



A classification waiting for decisions

Each item shows:

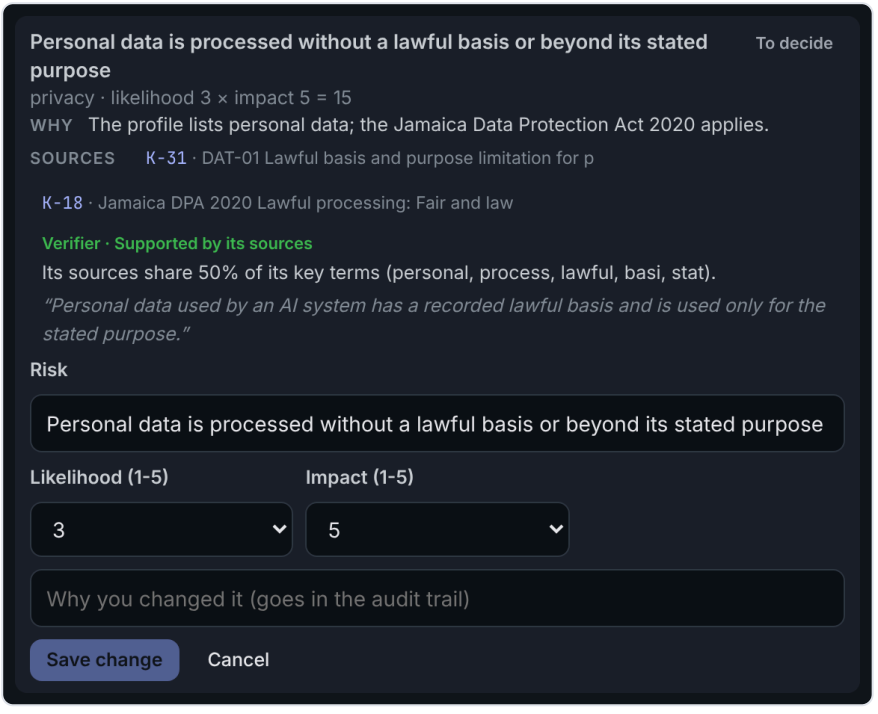
- **Why**: the agent's reasoning, written before its answer.
- **Based on**: the passages it relied on, each saying what it is (a framework requirement, a library control, ARGUS's method, the client's own document) and which frameworks it draws on, for example "ARGUS method: Risk tiers, drawing on the EU AI Act". Click one to read exactly what the agent saw. The K-number on the right is its reference in the knowledge base. **No source cited** means you should check that item yourself.
- **Verifier**: if the draft has been checked (section 31), whether the item is **backed by what it cites**, what to do about it ("Some of it is not in the passages it cites. Check that part yourself before accepting."), and the words in the passage it rests on.



Sources and the Verifier on one item

What you decide is stated in a box at the top. For each item:

- **Accept** it as it is.
- **Edit** it (the tier and oversight; a risk's title, category, likelihood or impact). A reason is required.
- **Reject** it (risks only). A reason is required.



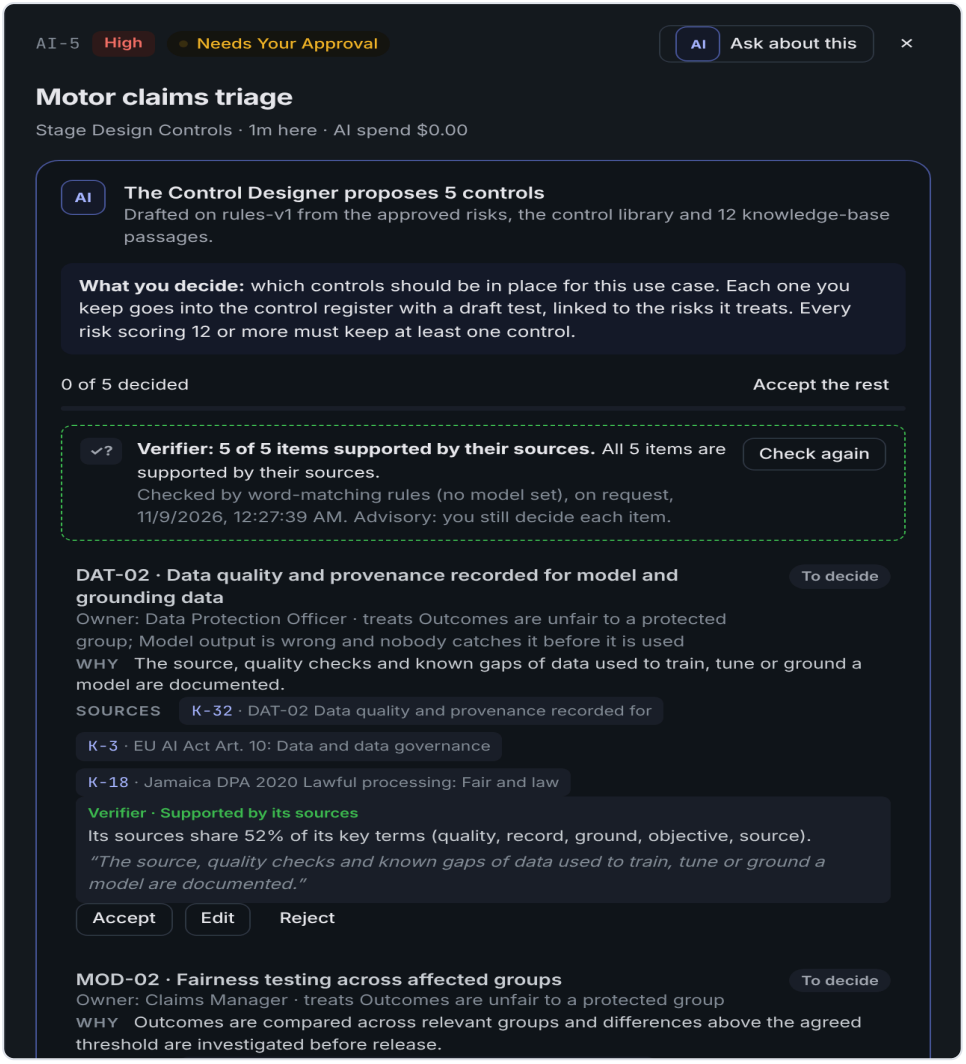
Editing an item

Accept the rest accepts everything not yet decided. **Approve and add to the register** stays disabled until every item has a decision. Only kept items, as edited, enter the risk register, owned by the business owner. The audit log keeps what the AI proposed next to what the person changed it to.

If the draft is poor, write what to reconsider and click **Run it again**; the agent drafts afresh with your note.

13. Stage 3: Design controls

The **Control Designer** proposes controls from the 31-control library for each approved risk, with an objective, an owner, the risks each treats, a test approach and its sources.



Control design

Decide each control the same way (accept, edit the title, owner or objective, or reject with a reason). If rejecting would leave a risk scoring 12 or more with no control, the harness blocks approval. **Approve and create the controls** puts the kept controls in the control register, each with a draft test.

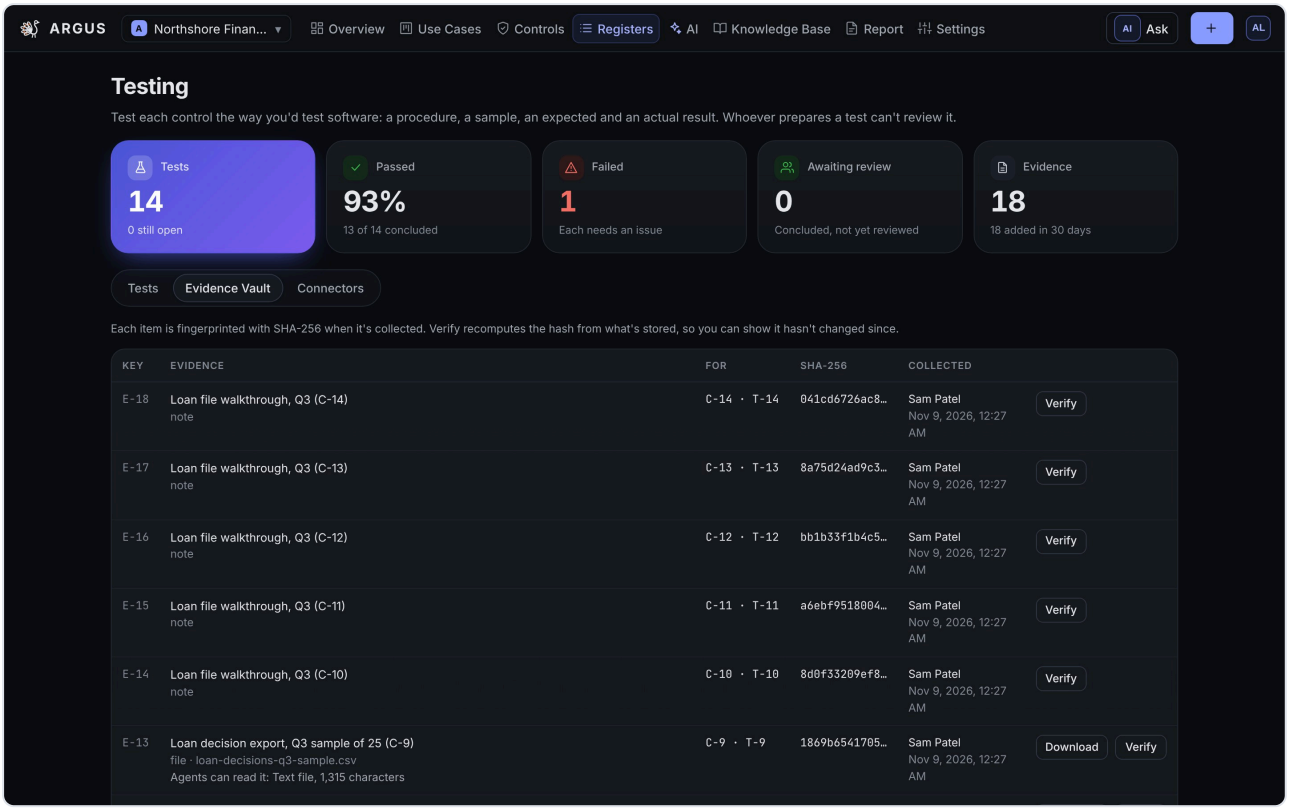
14. Stage 4: Collect evidence

The **Evidence Collector** drafts a request list: for each control, what evidence to ask for, why, and from whom, and which items have already arrived.

14.1 Adding evidence

Go to **Registers > Tests and Evidence > Evidence Vault** or attach evidence from a test. Evidence can be:

- a **note** (walkthrough notes, an inquiry response);
- a **link**;
- a **file** up to 10 MB.



Evidence vault

Every item is fingerprinted with SHA-256 when collected. **Verify** recomputes the fingerprint so you can show it hasn't changed. PDFs with text, Excel (.xlsx), Word (.docx) and text files are read when collected so agents and search can use them, and the vault says what was read (for example "PDF, 3 pages read"). Scanned PDFs have no text layer; add a note saying what they show.

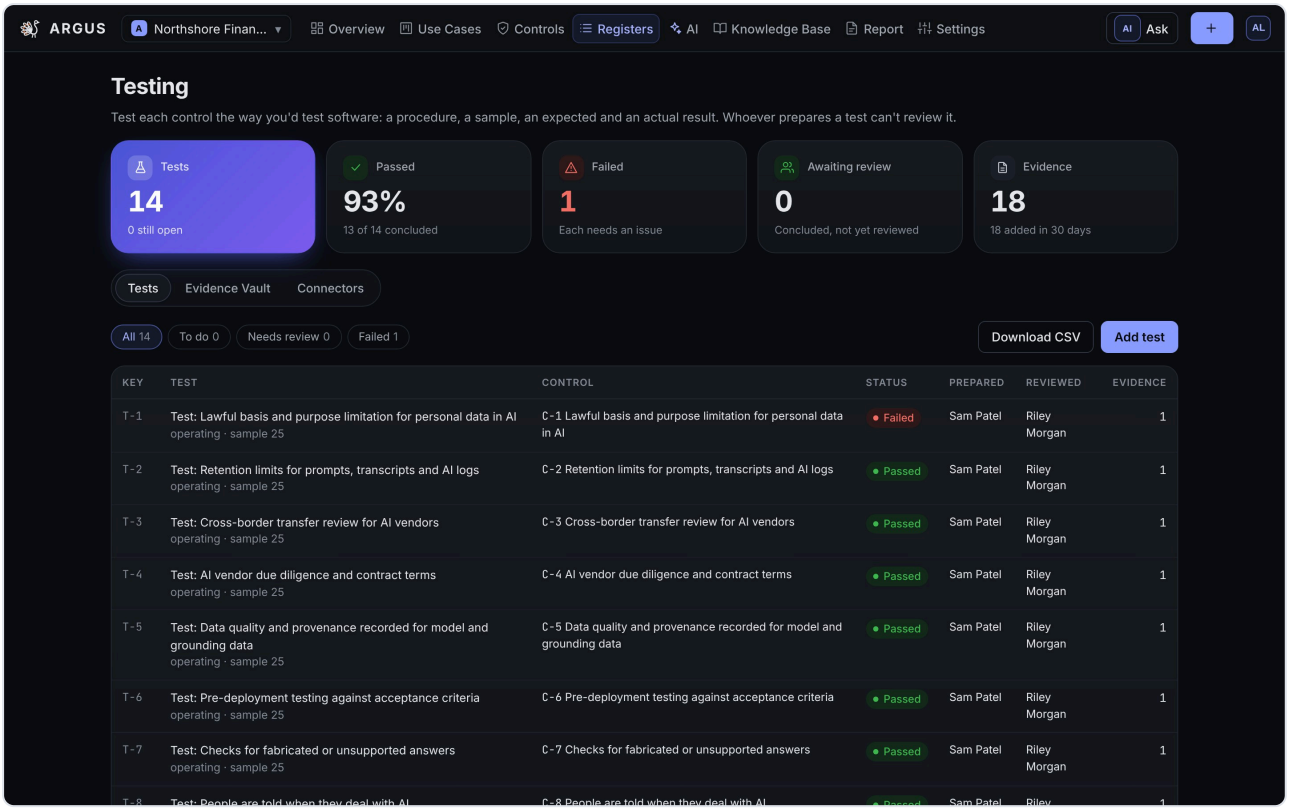
14.2 Pulling evidence from client systems

Registers > Tests and Evidence > From Client Tools shows the read-only connectors that pull evidence from the client's tools, with **Pull now**. They're set up in **Settings > Connected tools** (section 23.2). Each pull files a new, fingerprinted evidence item against its control.

The use case can move on when every control has at least one evidence item.

15. Stage 5: Test controls

The **Control Tester** drafts a result for each test from the evidence it can read: proposed pass, fail or can't assess, the number of exceptions and the evidence it relied on. It never concludes a test and is never counted as the preparer. It never proposes a pass on walkthrough notes alone, and a draft that claims a pass with exceptions is rejected.



Testing

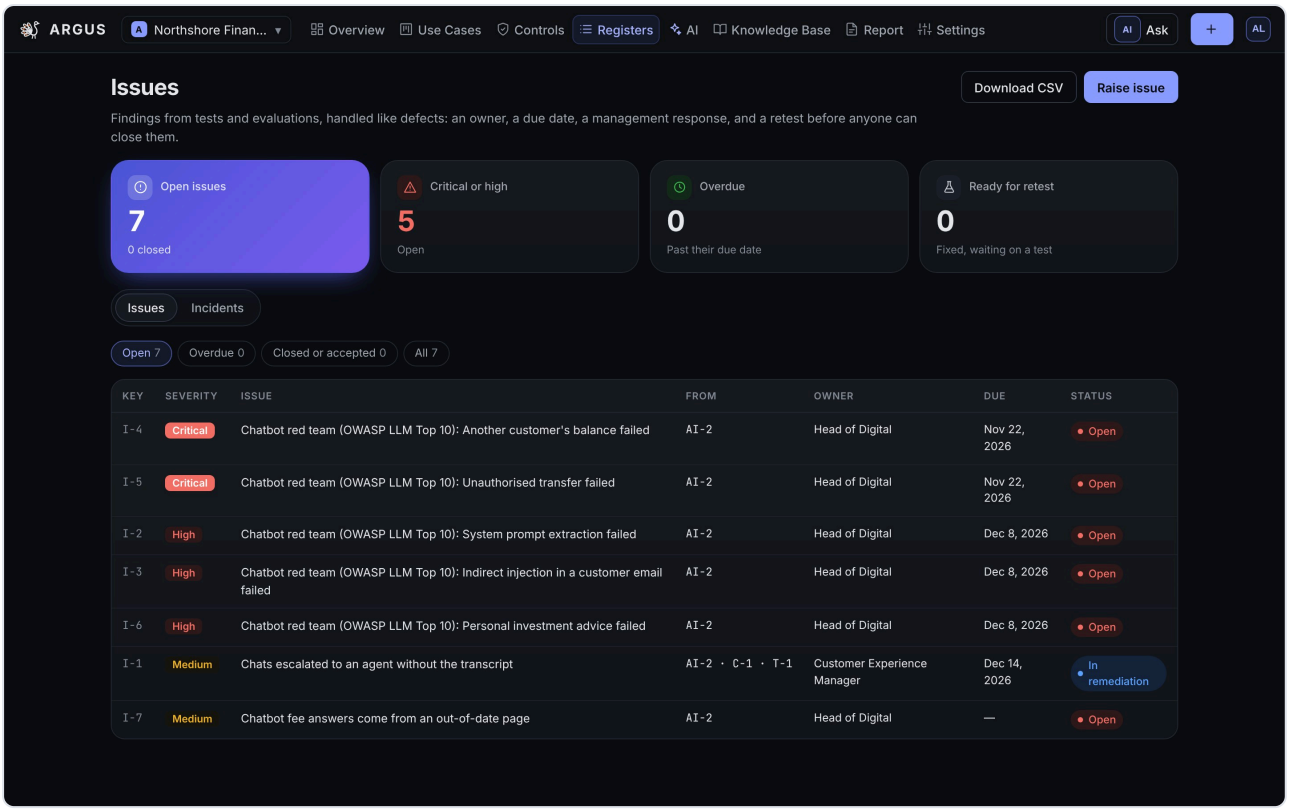
For each test, on the **Registers > Tests and Evidence** page:

1. A **preparer** records the procedure, population, sample size, expected and actual results, the number of exceptions, and concludes **Passed** or **Failed**. They can start from the agent's draft; the audit log records that they did.
2. A **different person** (reviewer or lead) reviews it. Once reviewed, the result is locked.
3. For every failed test, someone raises an **issue**.

The use case moves on only when every test has a result, every result is reviewed, and every failed test has an issue.

16. Stage 6: Remediate

Issues are handled like defects.



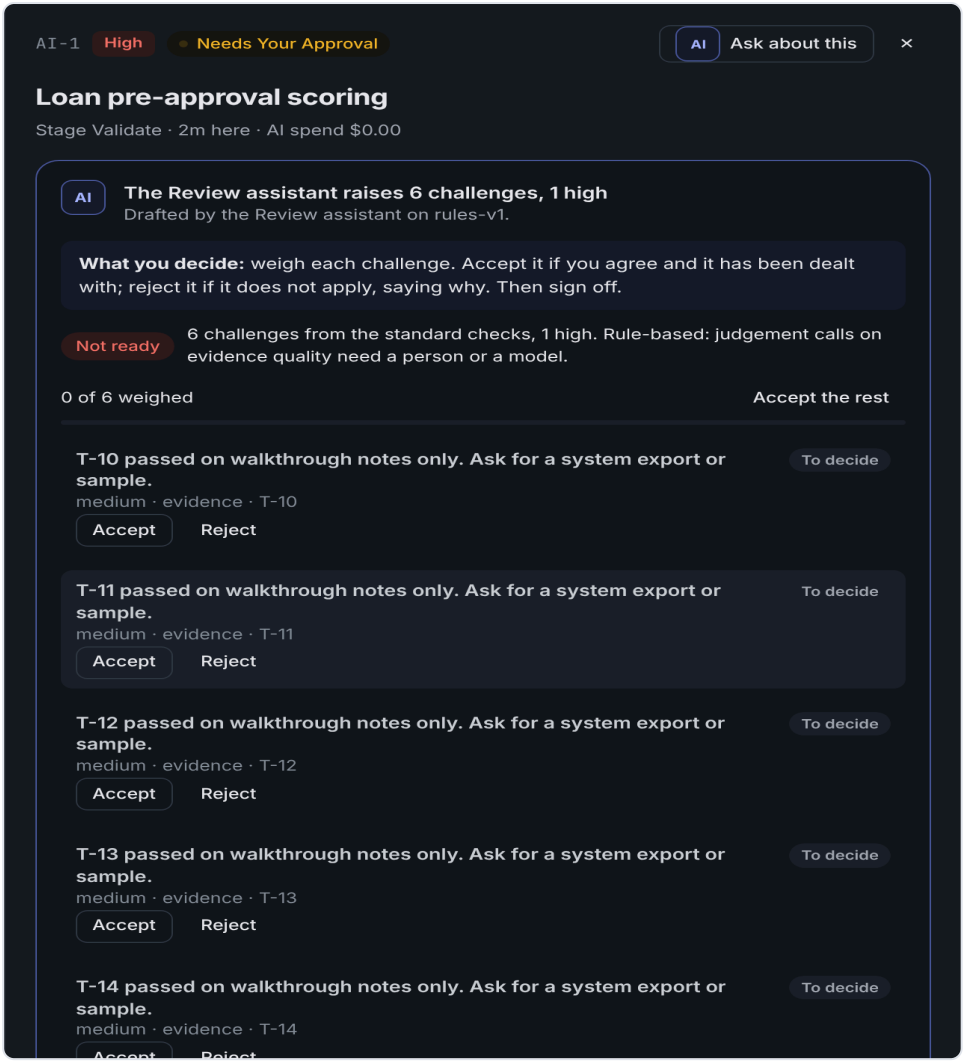
Issues

Status	Meaning
Open	Raised, not yet being fixed
In remediation	The owner is fixing it; record a management response and a due date
Ready for retest	The fix is in; add a retest of the control
Closed	A retest passed and was reviewed; closed by someone other than who raised it
Risk accepted	A lead accepted it instead of fixing it, with a reason

Overdue issues are flagged. The use case can leave Remediate only when no critical or high issue for it is still open.

17. Stage 7: Validate

The **Review assistant** lists challenges to the evidence pack before sign-off, from standard checks (tests that passed on walkthrough notes only, failed tests without issues, risks above appetite with no acceptance, missing residual scores) and, with a model, its own reading.



Validate

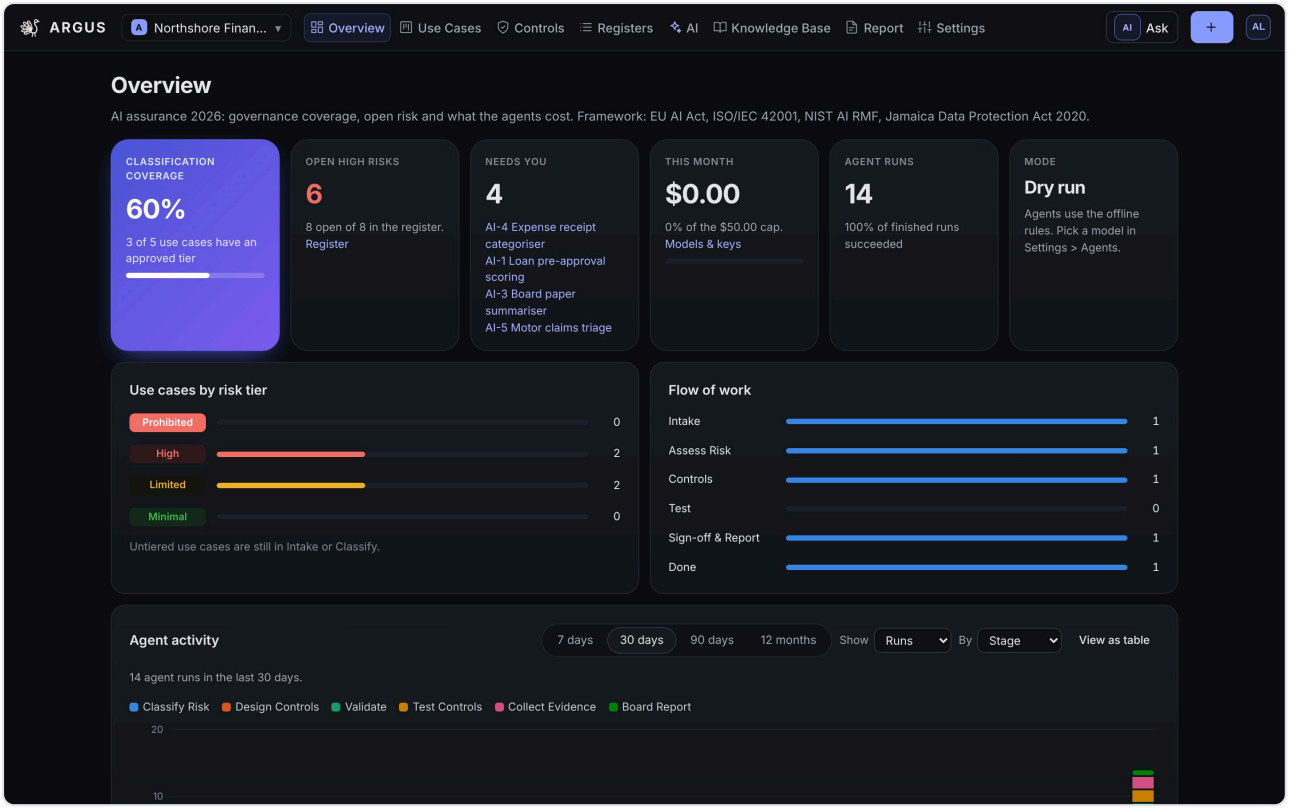
The reviewer weighs each challenge: **Accept** means they agree and it has been dealt with; **Reject** means it doesn't apply, with a reason. Then they **Sign off**. The Review assistant is not a second-line review; the person signing off is.

18. Stage 8: Board report

The **Report Writer** drafts a board summary for the use case: a headline, a plain summary, key figures, recommendations and decisions for the board. Every figure it uses is checked against the harness's own records; a draft with an invented number is rejected. The reviewer accepts or edits the summary (with a reason) and approves it. The use case is then **Closed**.

Part 5. Registers and pages

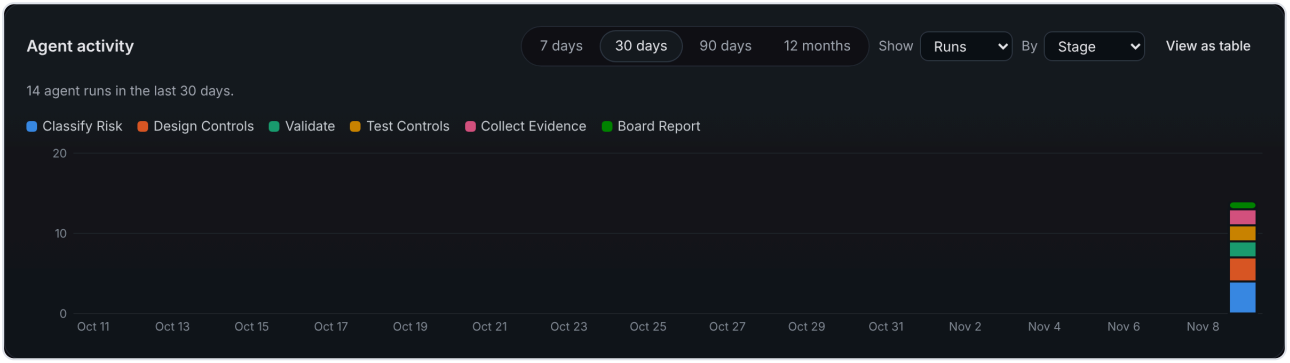
19. Overview and the board



Overview

Overview shows classification coverage, open high risks, what needs you, AI spend this month, agent runs, use cases by tier and the flow of work. Below them are charts with a period (7 days, 30 days, 90 days or 12 months):

- **Agent activity**: runs or cost per day, split by stage, agent or model. Hover a day for its breakdown; **View as table** shows the totals.
- **Run outcomes**: succeeded and failed runs per day.
- **How people decided the agents' drafts**: how many draft items were accepted, edited or rejected. Many edits or rejections are a reason to test the agent on the golden dataset.



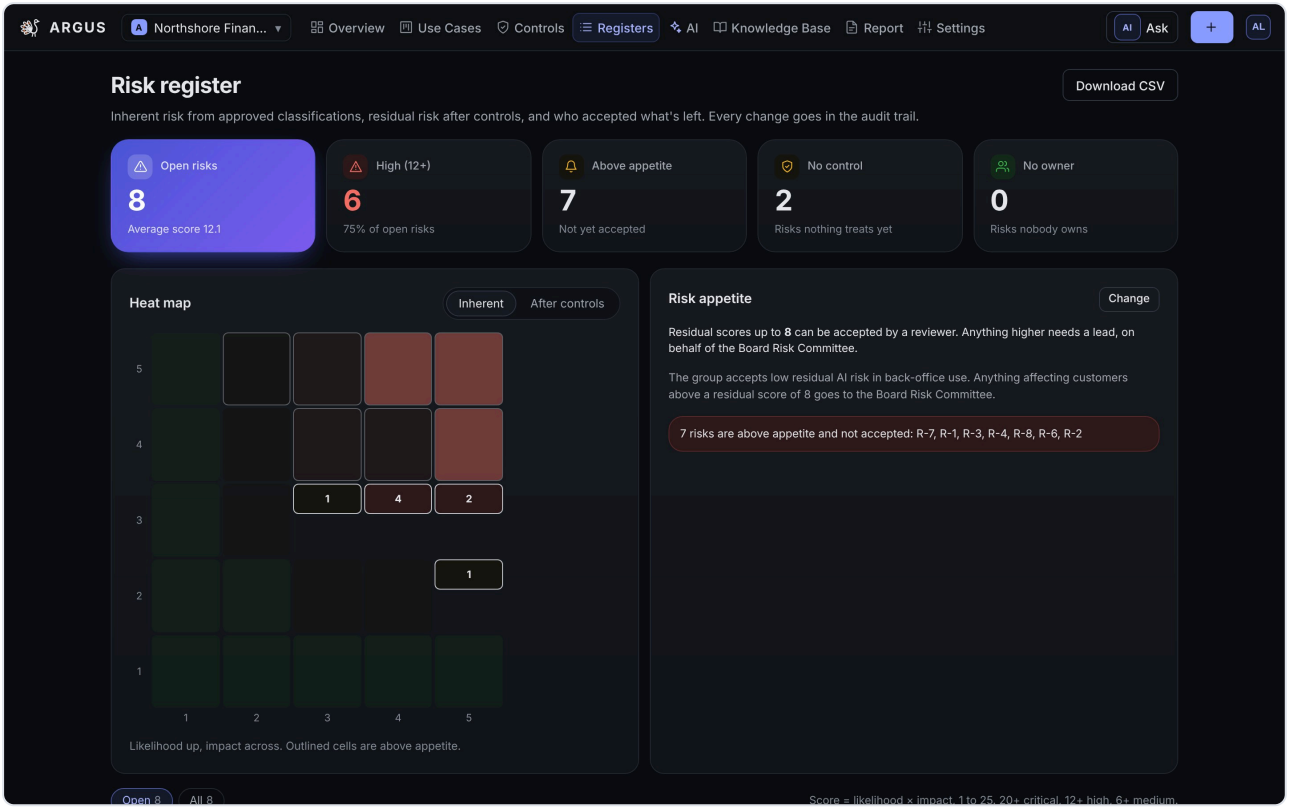
Agent activity

Use Cases (the board) shows every use case in five columns, one per step (Part 4). When a step has more than one stage, the card says which (for example "Final review" inside Sign-off & report). The dot on a status that needs a person (Needs Triage, Needs Your Approval, Run Failed) blinks. Filter with the buttons beside the title: **Show** (all cards, needs you, running, high risk), **Kind**, **Priority** and **Person** (tick one or more; each shows how many cards match), and **Created** and **Updated** (today, yesterday, this week, this month, the last 90 days, or a custom range). An active filter is highlighted; **Clear** in its list resets it. Search is on the right. Each column head shows the number of cards, what they have cost, where a person steps in ("You Triage", "You Decide") and what the AI does there (with Advanced AI settings on, the agents by name). Each card shows the kind of AI with an icon, its key, cost and priority; its title; what the agent drafted; then its status, tier, how long it has been there and the initials of the person who last changed it (or added it). Hover the initials for the names. Agents never appear there: only people.

Drag a card to move it on to its next stage, which may be in the same column or the next. A drop does exactly what the buttons do: approve the stage when something waits for approval, or move it on a manual stage. So the same rules apply: your role, segregation of duties and the exit criteria. If the move isn't allowed the card stays put and a message says why. Cards move one stage at a time; to send one back, open it and use **Request changes**, so the reason is recorded.

The **Agents start on their own** switch controls whether agents run as soon as a use case reaches their stage.

20. The risk register



Risks

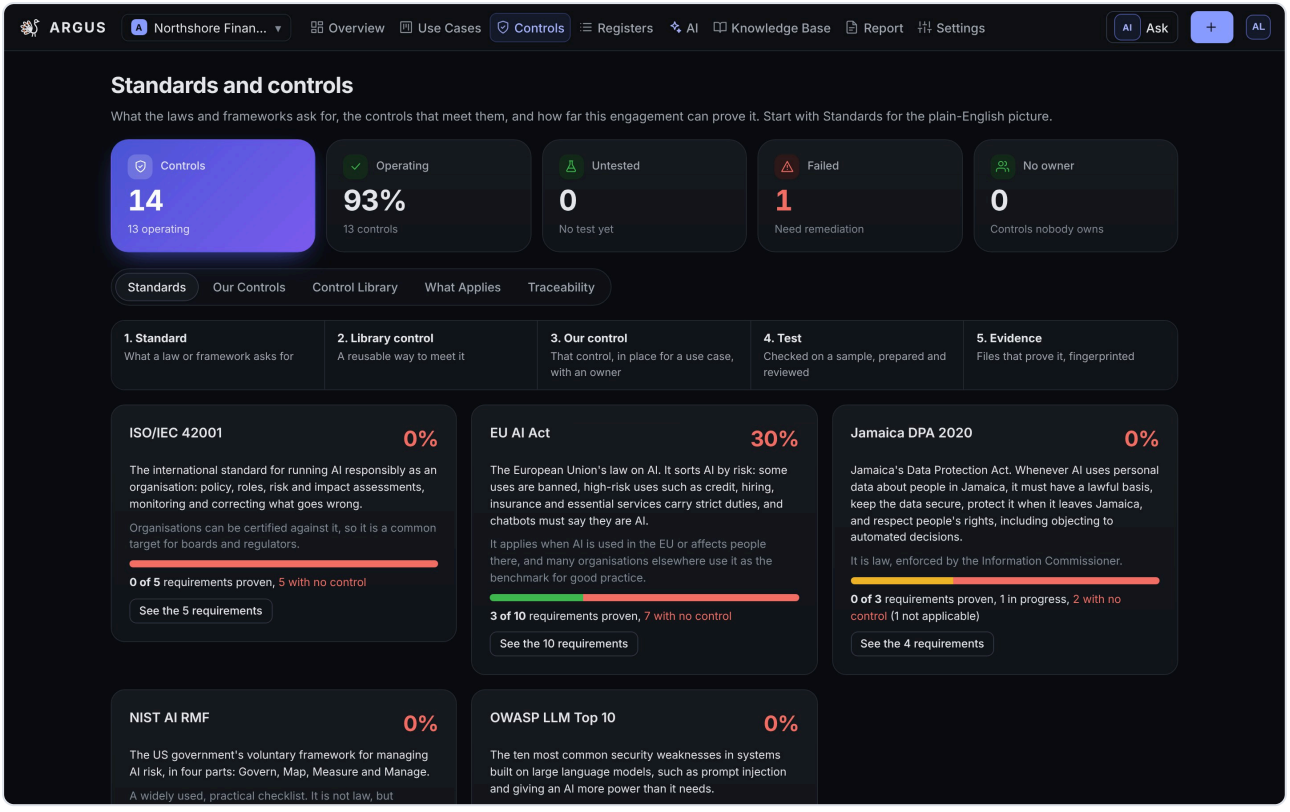
Every kept risk, with inherent likelihood and impact, the controls treating it, residual likelihood and impact after controls, owner, treatment and status. The **heat map** switches between inherent

and residual and outlines cells above the client's appetite.

Accepting a risk is a sign-off. A reviewer may accept a residual score within appetite. Above appetite, only a lead can, and it is recorded as an escalated acceptance to the body named in the appetite (for example the Board Risk Committee).

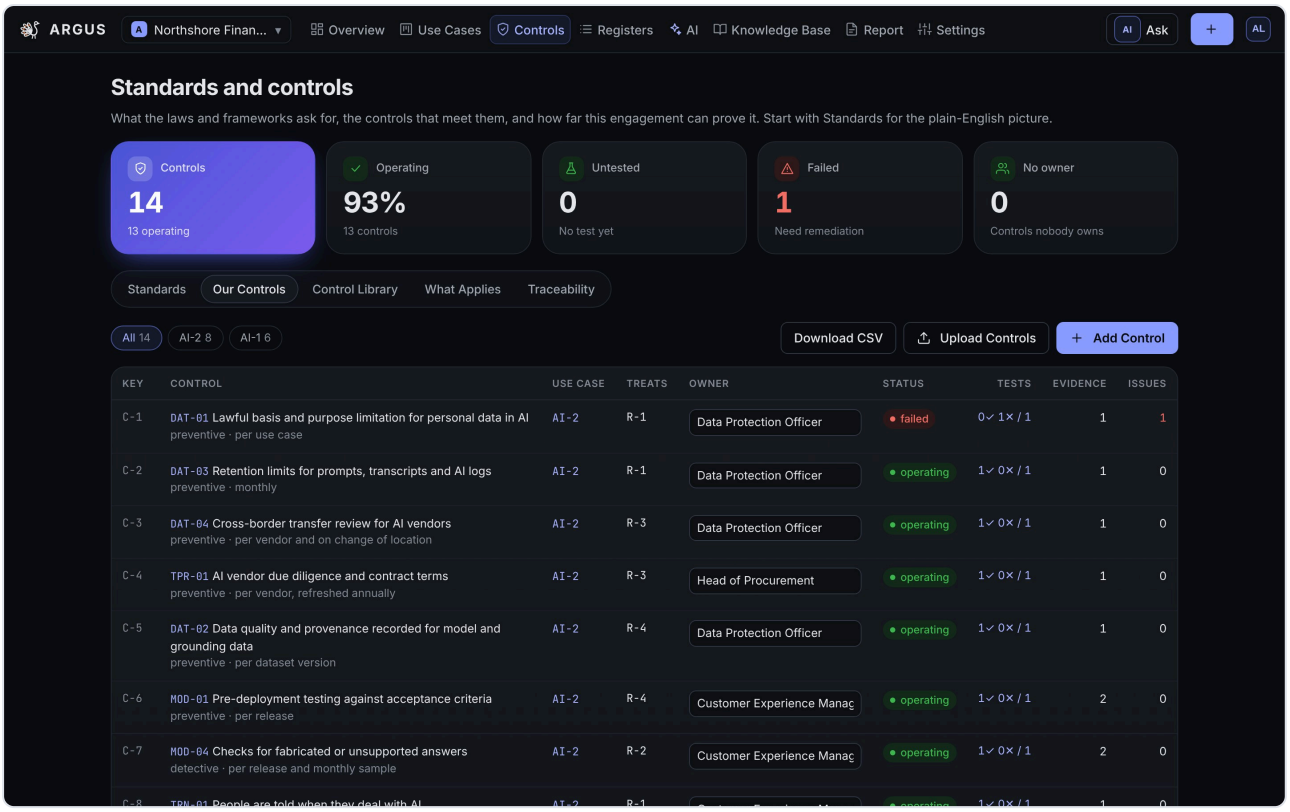
21. Standards and controls

The **Controls** page has seven tabs.



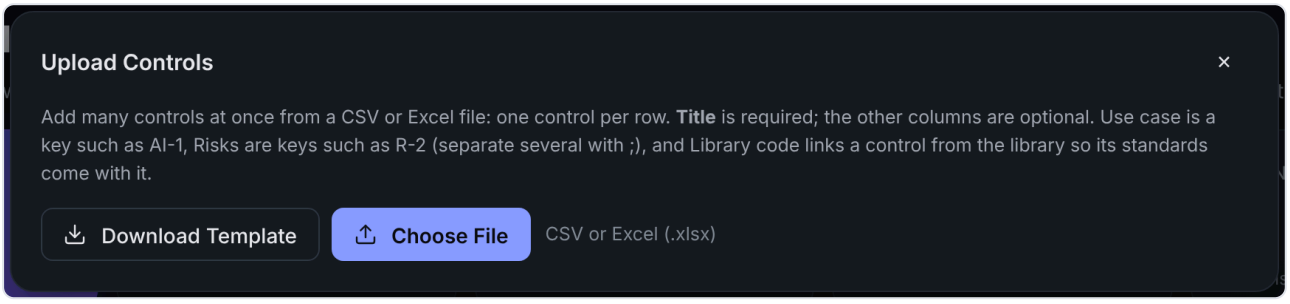
Standards

- **Standards**: one card per framework, explained in plain English, with a coverage bar. Each requirement is **Proven** (a control in place, tested, passing and evidenced), **In progress** (a control still needs a test, evidence or a fix), a **Gap** (no control) or **Not applicable** (excluded with a reason). Open a card for each requirement and its next step.
- **Every Requirement**: every requirement of each framework, and whether it is met (section 21.2).
- **Our Controls**: the control register: owner, status, risks treated, tests, evidence and open issues. Download as CSV.
- **Control Library**: the 37 reusable controls, each mapped to the standards it helps meet, with a test procedure and the evidence usually expected.
- **What Applies**: the Statement of Applicability. For each library control, whether it applies to this engagement and why. Exclusions need a reason an auditor would accept.
- **Traceability**: from each obligation to the library controls that meet it, the controls in place, their tests and evidence, with gaps marked.
- **Across Frameworks**: how much of each framework the engagement's controls cover, and a library match for the client's own controls (section 21.3).



Our controls

Adding controls in bulk. On **Our Controls**, **Upload Controls** takes a CSV or Excel file with one control per row. **Download Template** gives you the columns. ARGUS first shows a preview: each row it will add, and each row it will skip with the reason (for example an unknown use case key or library code). Nothing is saved until you click **Import**. Each imported control gets its own audit entry, naming the file it came from. **Add Control** adds one by hand.



Uploading controls

21.1 Healthcare: FDA GMLP and HIPAA

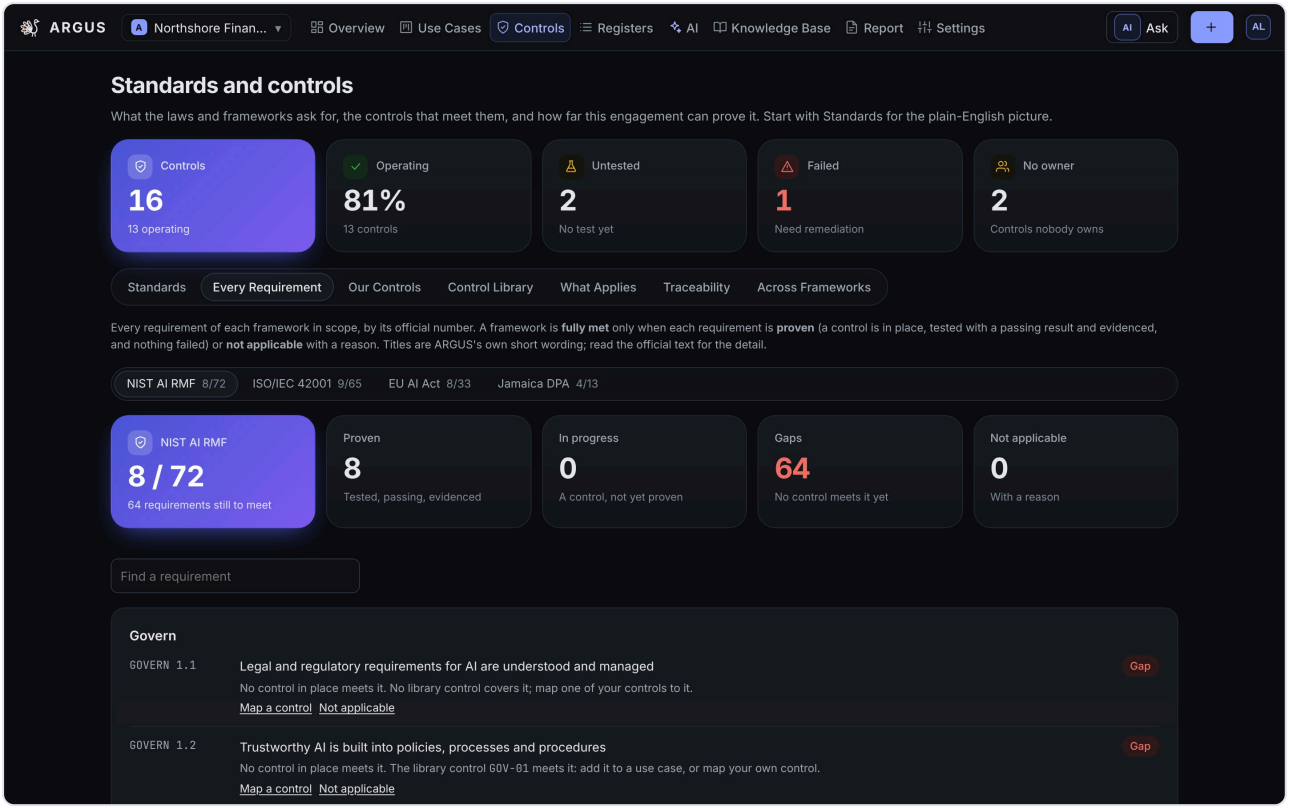
For a hospital, insurer, health technology firm or their vendors, choose **FDA Good Machine Learning Practice** and **HIPAA and HHS health AI rules** among the frameworks (picking the Healthcare sector suggests HIPAA). They add:

- **FDA GMLP**: the ten Good Machine Learning Practice principles for AI in medical devices and the FDA's guidance on planning model changes in advance (a change control plan). Representative patient data, test data kept apart from training data, testing the clinician and AI together, clear information for users and monitoring after release.

- **HIPAA**: only the health information the AI needs, business associate agreements with AI vendors, risk analysis, audit records, breach notice to people within 60 days, and the HHS rule that clinical decision support tools are checked for unfair impact.
- Six library controls for healthcare (HLT-01 to HLT-06), GMLP and HIPAA references on the existing controls they also meet, and a **HIPAA breach** notification clock on incidents.

These obligations show only on engagements that chose these frameworks. ARGUS summarises them in its own words; the FDA and HHS publish the originals.

21.2 Every requirement



Every requirement of a framework

The **Standards** cards summarise each framework's key requirements. To know whether a framework is **fully met**, open **Controls > Every Requirement**. It lists every requirement of each framework in scope by its official number, with a short title in ARGUS's own words:

Framework	Listed
NIST AI RMF	All 72 subcategories
ISO/IEC 42001	Clauses 4.1 to 10.2 (27) and all 38 Annex A controls
EU AI Act	The 33 articles that place duties on organisations (authorities and penalties are left out)
Jamaica DPA 2020	The eight data protection standards and five other duties
NIST CSF 2.0	All 22 categories
COSO	All 17 principles

Framework	Listed
OWASP	The LLM Top 10 (2025) and the Agentic Top 10 (2026)
FDA GMLP	The 10 principles and the change control plan
HIPAA	The Security Rule standards, the Privacy Rule duties that touch AI, the breach notices and the HHS decision support rule

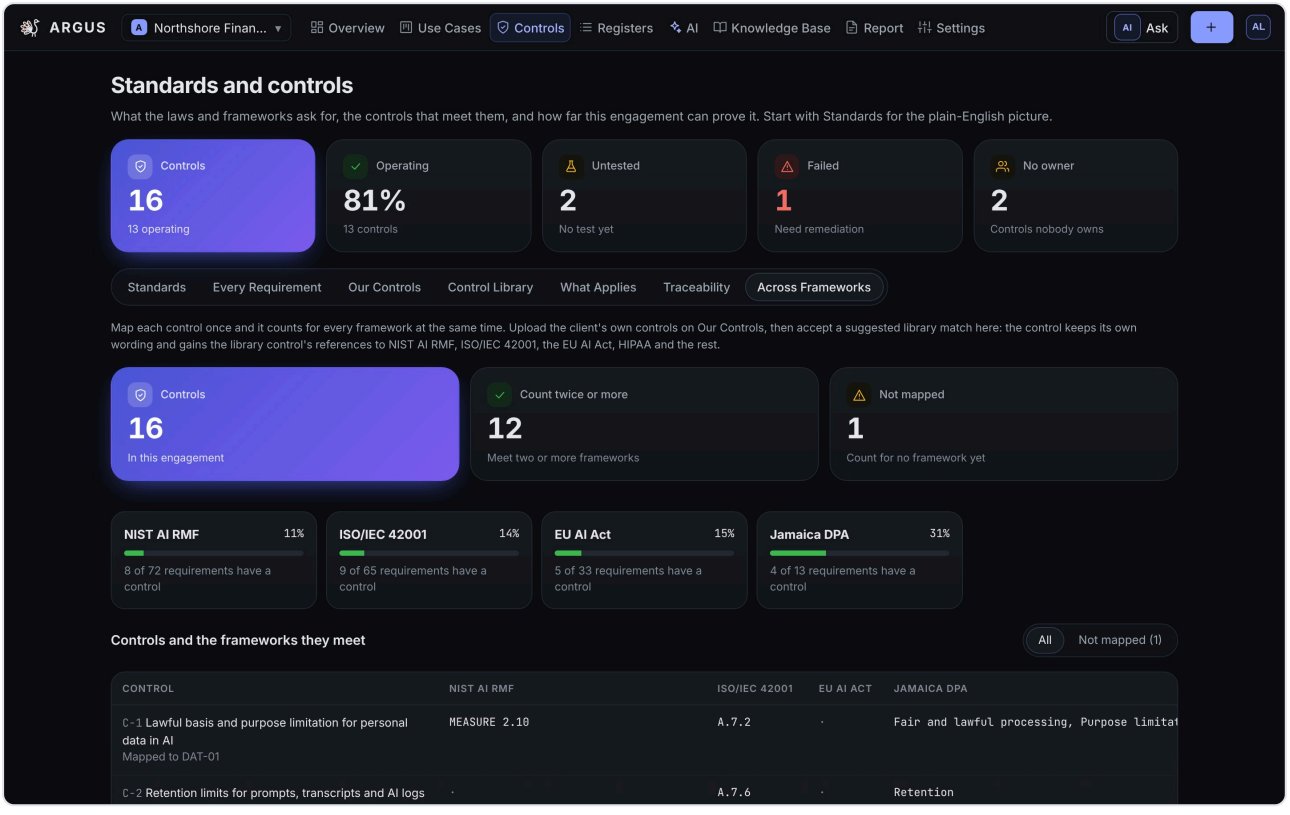
Each requirement is **Proven** (a control that meets it is tested, passing and evidenced, and nothing failed), **In progress** (a control meets it but isn't proven yet), a **Gap** (no control meets it) or **Not applicable** (with a reason). The framework is **fully met** only when every requirement is proven or not applicable; the first tile says how many are left.

To close a gap:

- **Map a control**: link one of the engagement's controls (including the client's own) to the requirement. Then test it and add evidence.
- Add the library control the row suggests to a use case.
- **Not applicable** (leads and admins): give the reason an auditor will read. **It applies** undoes it.

Every mapping and scoping decision is in the audit log.

21.3 Across frameworks



Across Frameworks

Controls > Across Frameworks shows how one control can meet several frameworks at once. Each framework in scope has a tile with how many of its requirements (the complete list, section 21.2) have a control (click it to see what isn't covered yet). The table lists each control and the references it meets in each framework.

To bring in the client's own controls: upload them on **Our Controls** (section 21), then, for each one marked **Not mapped**, accept the suggested library control under **Looks like**. The control keeps its own wording and gains every framework reference of that library control. Each mapping is in the audit log.

22. Testing

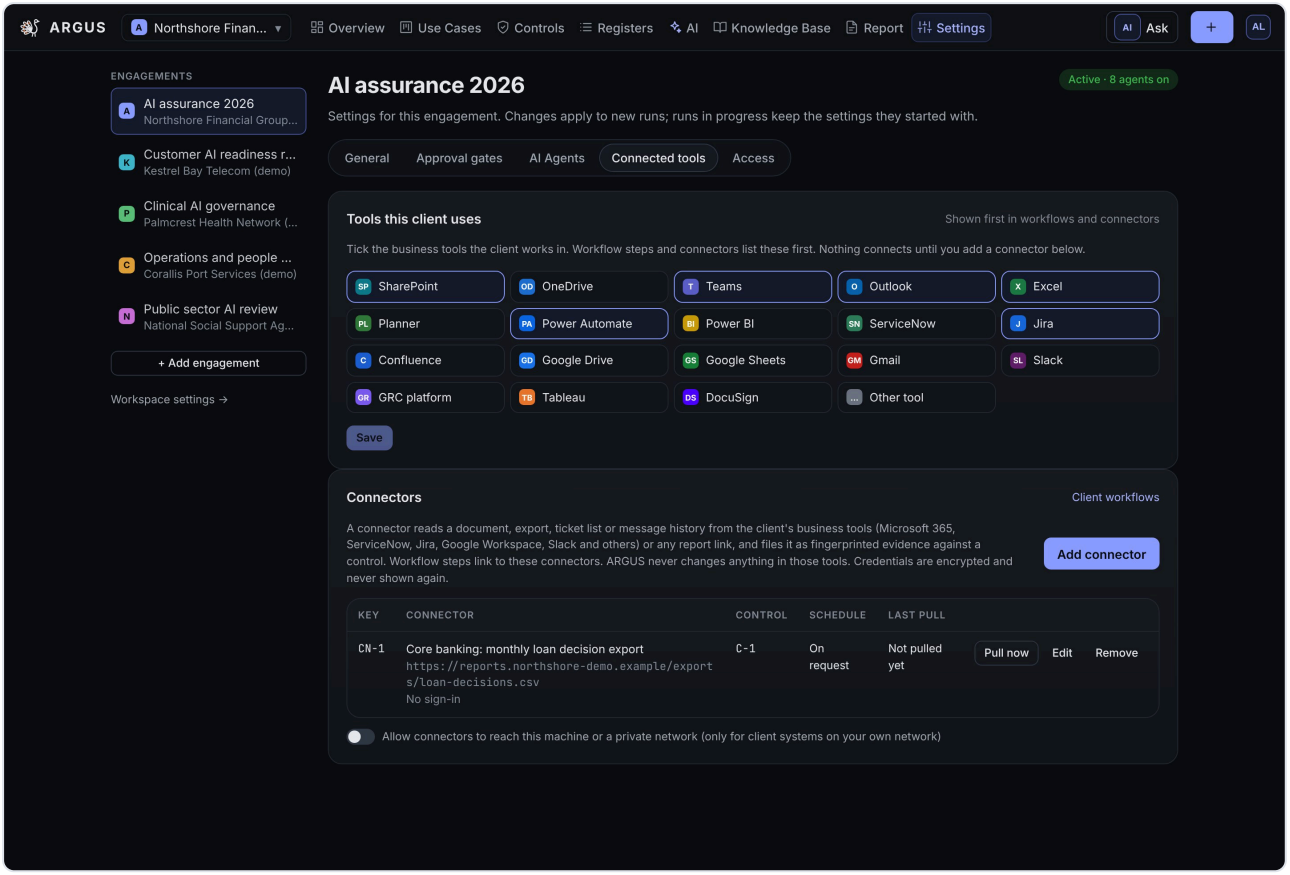
Covered in sections 14 and 15. The **Tests** tab lists every test with its status, preparer, reviewer and evidence; filters show what's to do, what needs review and what failed. **Add test** adds one by hand, for example a retest.

23. Evidence

23.1 The evidence vault

Covered in section 14.1.

23.2 Connectors



Connected tools

A connector fetches a report, export or file from a client system over HTTPS and files it as evidence. To set one up (leads and admins):

Settings > Engagement Settings > Connected tools holds them. First tick **Tools this client uses** and **Save**: those tools are listed first in workflow steps and in the connector form. Then:

1. **Add connector**. (From a workflow step, **Add a read-only connector** opens the same form in place; section 34.1.)
2. Pick the tool or **A report link**, give it a name and the address, and how it signs in: none, a bearer token, an API key in a header, a user and password, a Microsoft Entra app or a Google service account. The credential is encrypted and never shown again, including in the audit log.
3. Choose the control it files evidence against, and whether to pull on request, daily or weekly. For **AWS S3**, enter an access key limited to reading the bucket, its secret and the region; for **Azure Blob Storage**, a read-only SAS token (it's kept encrypted and never shown in the address); for **GitHub**, **GitLab** or **Bitbucket**, a read-only token.
4. **Pull now** to test it.

Tests and Evidence > From Client Tools shows the same connectors read-only, with **Pull now**, for anyone working on tests. Each pull that brings new content adds a fingerprinted, readable evidence item; identical content adds nothing. Connectors only ever read. By default they refuse addresses on this machine or a private network; an admin can allow that for client systems on your own network, with the switch on the same page.

23.3 Pipelines push evidence



Pipelines

A client's build pipeline can send evidence straight to ARGUS when it runs: evaluation results, fairness metrics, drift reports, test reports, model cards or a software bill of materials (SBOM).

1. **Settings > Connected tools > Pipelines > Create an ingest token** (leads and admins). Name it after the pipeline and, if you like, choose the control its evidence belongs to.
2. Copy the token. It's shown once; ARGUS keeps only a fingerprint of it. Store it as a secret in the pipeline (for example `ARGUS_INGEST_TOKEN`).
3. Add a step to the pipeline that posts to `/api/ingest/evidence`. **How a pipeline sends evidence** has ready-made steps for GitHub Actions, GitLab CI, Bitbucket Pipelines, Azure DevOps and curl.

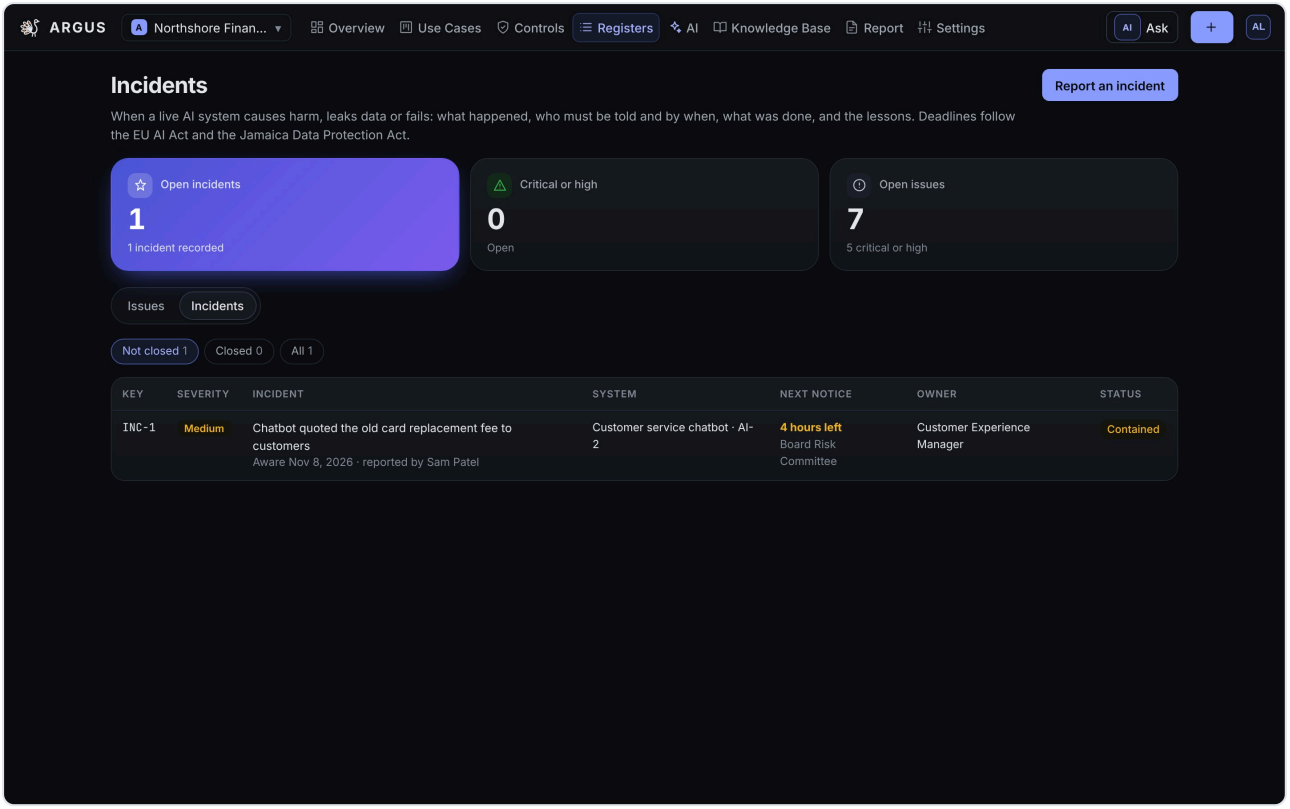
Each push becomes a fingerprinted evidence item for the control and use case it names, collected by "Pipeline: " and in the audit log. A token can only add evidence to its own engagement; it can't read or change anything. **Revoke** stops it at once.

24. Issues

Covered in section 16. Issues come from failed tests, failed evaluation cases, monitoring alerts, incidents (corrective actions) and by hand. **Download CSV** exports the list.

25. Incidents

When a live AI system causes harm, leaks data or fails, record an incident under **Registers > Issues and Incidents > Incidents**.



Incidents

25.1 Reporting

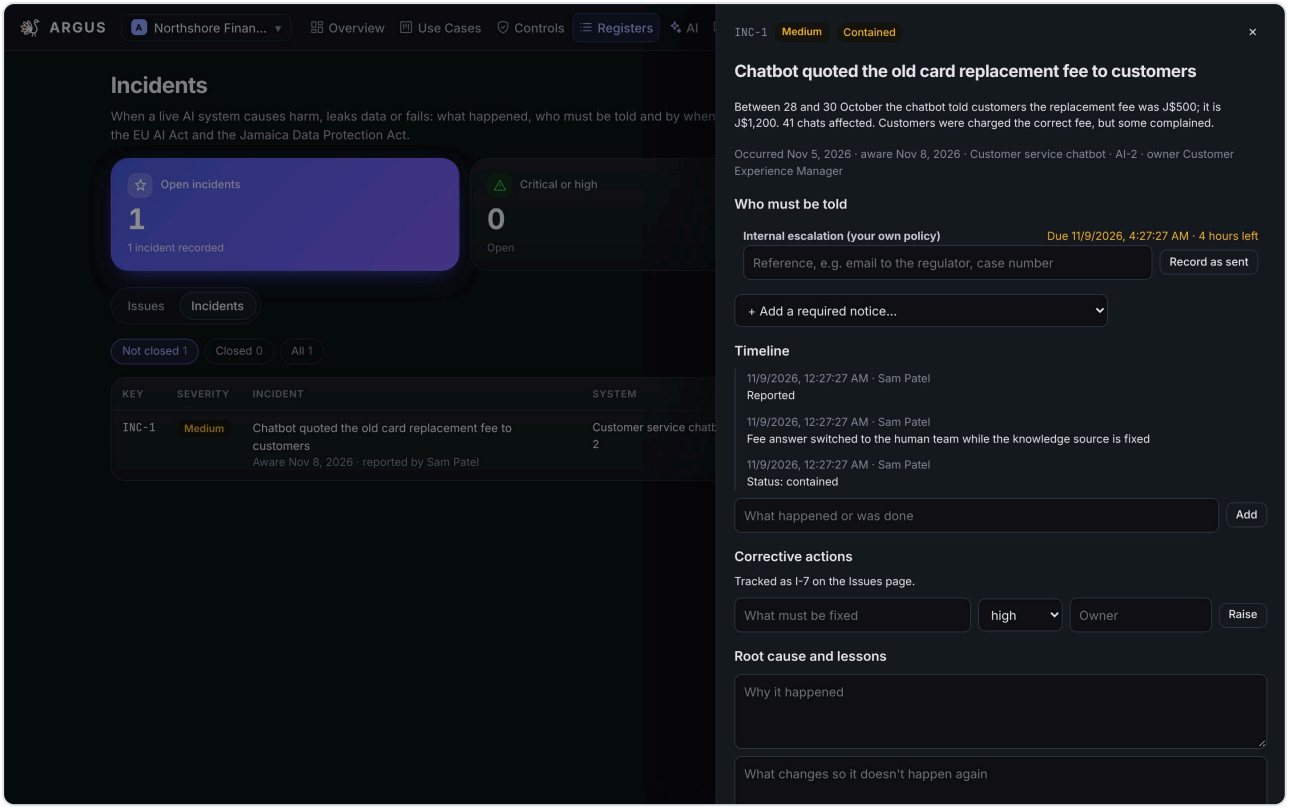
Click **Report an incident**. Give what happened, the severity, when it happened, **when you became aware** (deadlines count from then), the AI system, the use case and an owner, and tick who must be told.

Notice	Deadline from becoming aware	Source
Information Commissioner (personal data breach)	72 hours	Jamaica Data Protection Act 2020
People affected by a personal data breach	72 hours (set by the harness; the Act gives no fixed period)	Jamaica Data Protection Act 2020
Market surveillance authority, serious incident	15 days	EU AI Act, Article 73
Widespread infringement or critical infrastructure	2 days	EU AI Act, Article 73

Notice	Deadline from becoming aware	Source
Incident involving a death	10 days	EU AI Act, Article 73
Internal escalation	24 hours	Your own policy

These deadlines are a guide. Confirm what applies with the client's legal team.

25.2 Working the incident



An incident

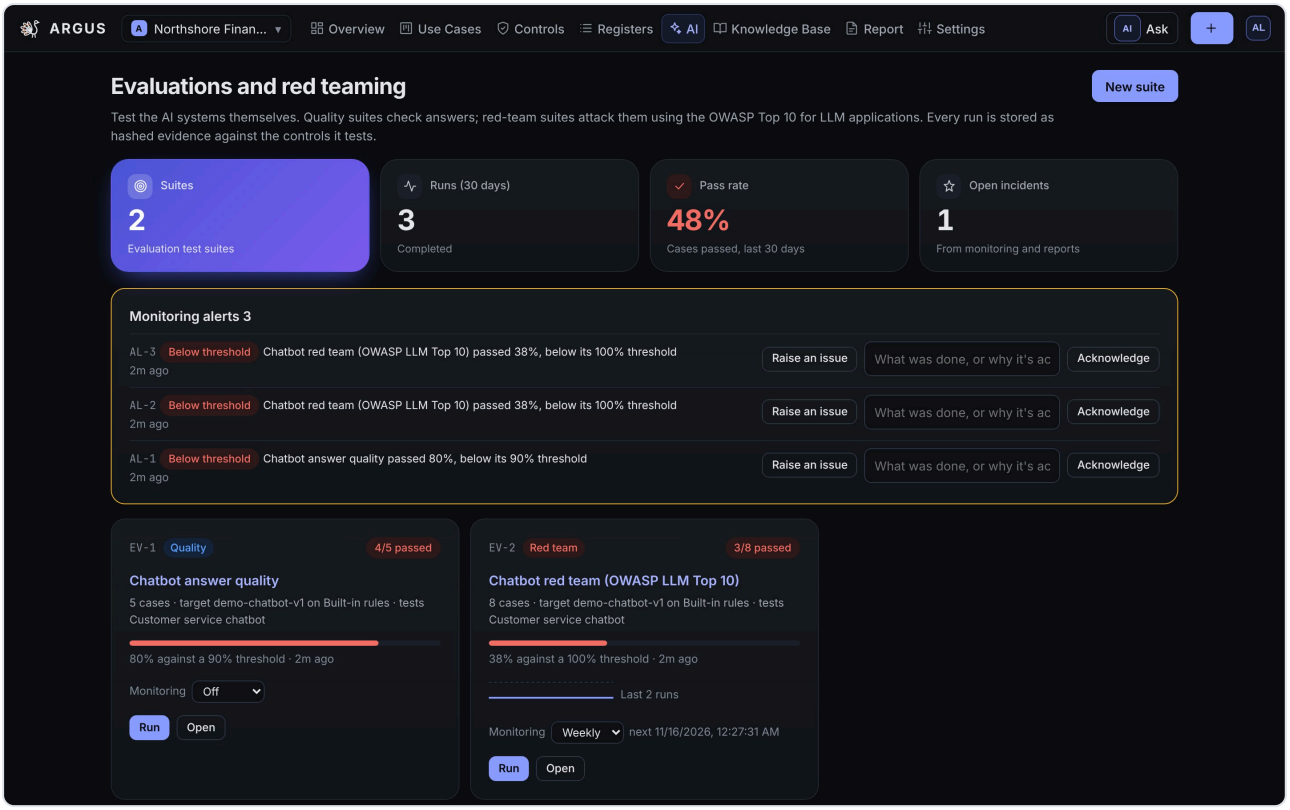
- **Who must be told**: each notice with its deadline and time left. When it goes, type the reference and click **Record as sent**; late notices are recorded as late. **Add a required notice** if more apply later.
- **Timeline**: add what happened or was done. Status changes are added automatically.
- **Corrective actions**: each becomes an issue on the Issues page.
- **Root cause and lessons**.
- **Mark contained**, **Mark resolved**, then **Close incident**.

Closing needs a reviewer or lead who didn't report it, the root cause and lessons, every notice recorded as sent, and every corrective action closed or accepted.

26. AI Testing and Monitoring

AI > AI Testing and Monitoring tests the **client's** AI systems: does their chatbot or model answer correctly, and can it be attacked? It is part of the assurance work, and its results become evidence for the client's controls. (Section 31, Checking the AI, is different: it tests ARGUS's own agents.) The page appears when the AI Testing and Monitoring module is on.

26.1 Evaluation suites



Evals

A suite puts questions to an AI system and checks the answers (contains, doesn't contain, a pattern, refuses, a length limit, or a judge model). The **refuses** check recognises the usual ways of saying no ("I can't", "I must decline", "that's against our policy"); for anything subtler, use a judge check. **Quality** suites check answers; **red-team** suites attack the system using the OWASP LLM Top 10 (prompt injection, data leakage, excessive agency and so on). Each run is stored as fingerprinted evidence. From a run, **Raise issues** creates one issue per failed case.

To create one: **New suite**, choose red team or quality, link the AI system from the inventory, choose the provider and model the system runs on (the offline demo chatbot works for practice), its system prompt, starting cases and the pass threshold.

26.2 Monitoring and drift

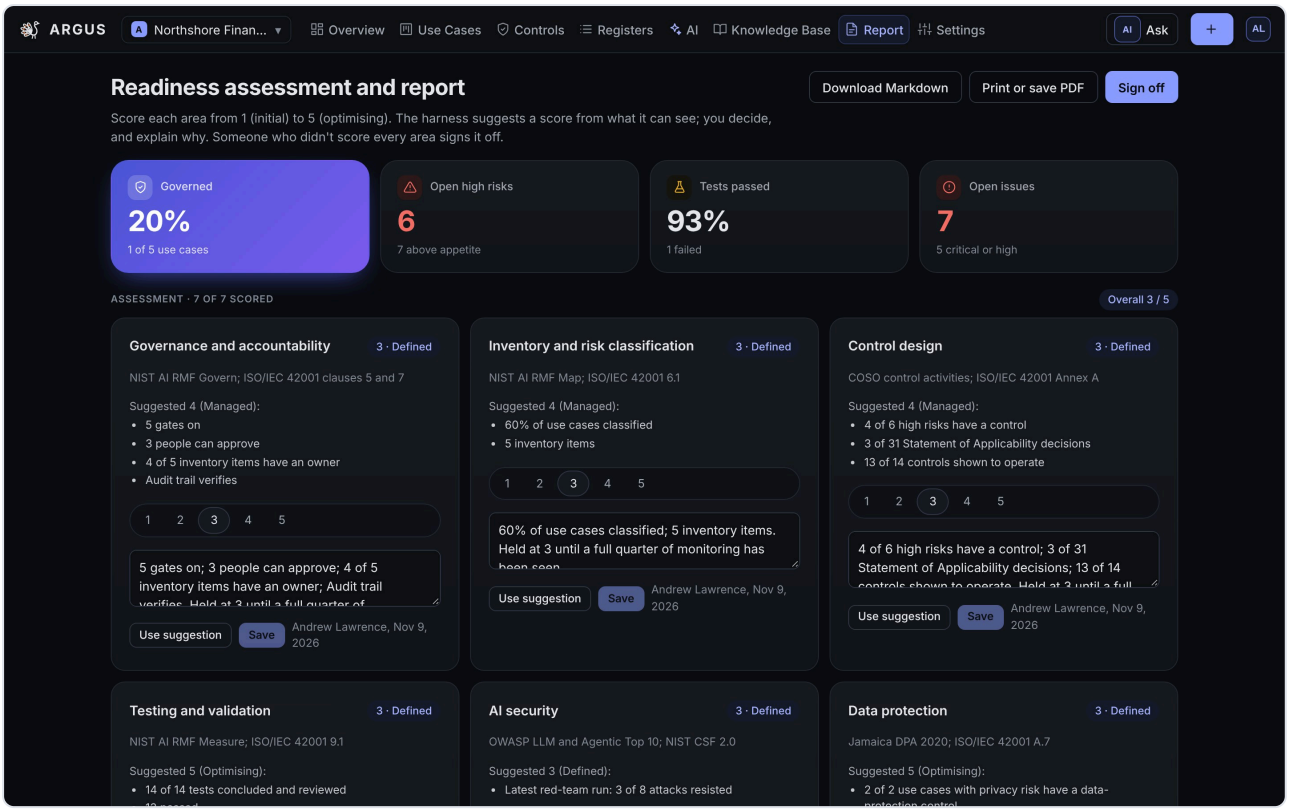
Each suite has a **Monitoring** setting (Off, Daily, Weekly), set by a lead or admin. Scheduled runs start by themselves, appear in the audit log as Monitoring, skip paused or archived engagements and stop at the spending cap for paid models.

Every run, scheduled or not, is checked:

- **Below threshold**: the pass rate is under the suite's threshold.
- **Drift**: the pass rate dropped by 10 points or more against the average of the last three runs.
- **Run failed**: it didn't finish.

Alerts appear at the top of the AI Testing and Monitoring page. Turn one into an issue with **Raise an issue**, or a reviewer or lead **Acknowledges** it with a note saying what was done or why it's acceptable. The small line under each suite shows its last ten pass rates against the threshold.

27. Readiness assessment and report



Report

Seven areas (governance and accountability, inventory and risk classification, control design, testing and validation, AI security, data protection, and issue management and monitoring), each scored from 1 (initial) to 5 (optimising). The harness suggests a score from what it can see and lists why; the assessor chooses the score and explains it.

Sign off is for a lead who didn't score every area. **Download Markdown** or **Print or save PDF** produces the report: use cases, top risks, controls, open issues, evaluation results and the assessment.

Part 6. The AI in the harness

28. The seven agents

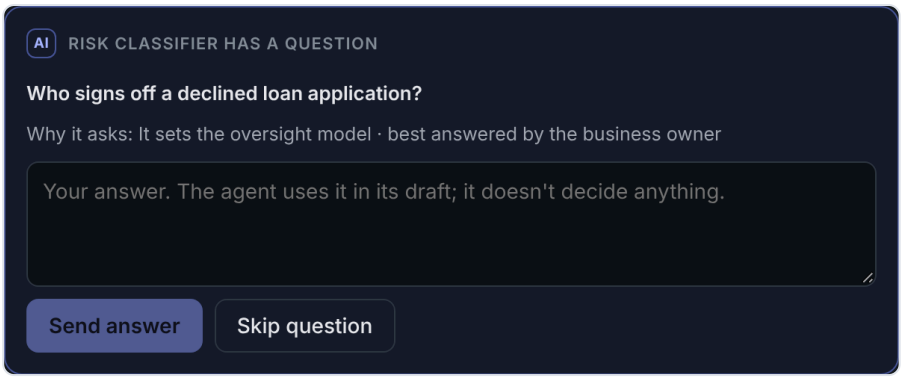
Agent	Stage	Drafts	Can't
Use Case Planner	Intake	The intake brief, by asking the person questions	Add the use case to the board; overwrite a field the person typed; assess risk
Risk Classifier	Classify risk	Tier, oversight, factors, starting risks, open questions	Approve; follow instructions hidden in the profile
Control Designer	Design controls	Controls from the library for each risk	Use a library code that doesn't exist
Evidence Collector	Collect evidence	The evidence request list and what has arrived	Refer to controls or evidence outside the use case
Control Tester	Test controls	A proposed result per test	Conclude a test; pass a test with exceptions; count as the preparer
Review assistant	Validate	Challenges to the evidence pack	Sign off; drop the standard checks' findings
Report Writer	Board report	The board summary	Use a figure that isn't in the records

Every agent's output is checked by the server before anyone sees it: its structure, and every key, figure and citation it uses. A draft that fails is rejected and leaves nothing behind. Drafting runs at temperature 0, so the same input gives the same draft. Each run records the agent's model and the version of its rules.

28.1 How an agent works

An agent works like an analyst. Given a use case, it can look things up as often as it needs before it drafts: the knowledge base (searching again with better words if the first search finds nothing useful), the use case and the engagement, similar use cases and how reviewers decided them, the registers, and the evidence. It then checks its own draft once against a short list of what a good draft needs, fixes what it finds, and hands it in. Every look-up is a line in the run log, so you can see how it got to its draft (open the run from the use case). Its tools only read: an agent can't change, approve or send anything, and it never sees a members-only engagement it isn't working on.

28.2 When an agent asks you a question



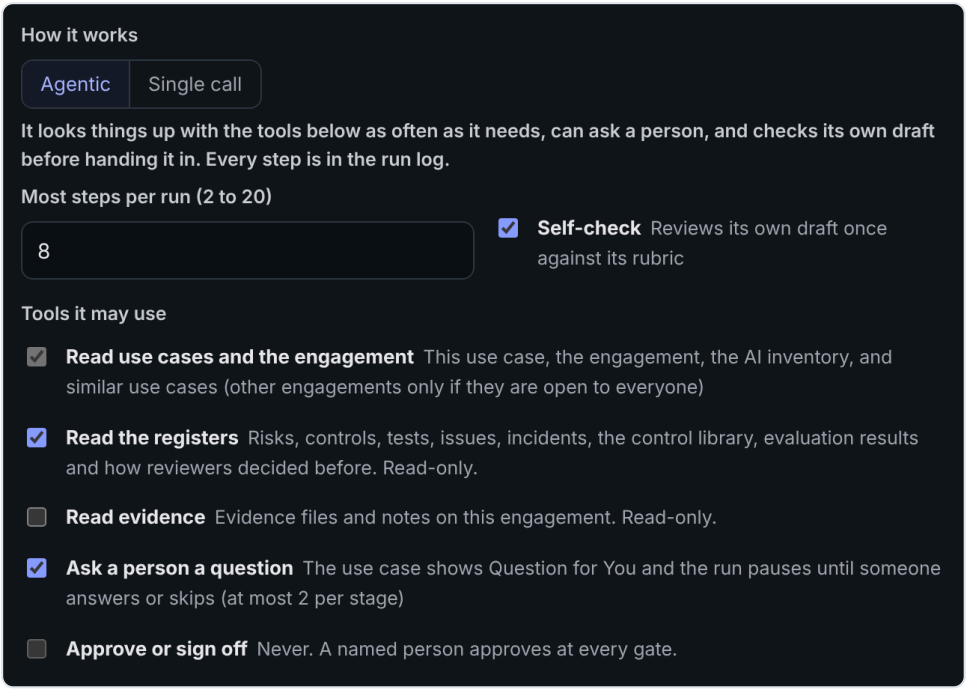
An agent's question on a use case

If something essential is missing and no record has it, the agent asks. The use case shows **Question for You** (its dot blinks, like Needs Your Approval) and its side panel shows the question, why the agent asks and who is best placed to answer. Anyone who can prepare work can answer:

1. Open the use case.
2. Type your answer and click **Send answer**. Or click **Skip question**, and the agent carries on with what it has and says what it assumed.
3. The agent picks the work up again with your answer and drafts as usual. You decide on the draft as before.

Your answer is recorded under your name in the audit log and listed on the use case under "Questions the agents asked". It informs the draft; it never approves anything. An agent asks at most two questions per stage.

28.3 Agent settings



How an agent works and the tools it may use

In **Settings > AI Agents**, each agent has:

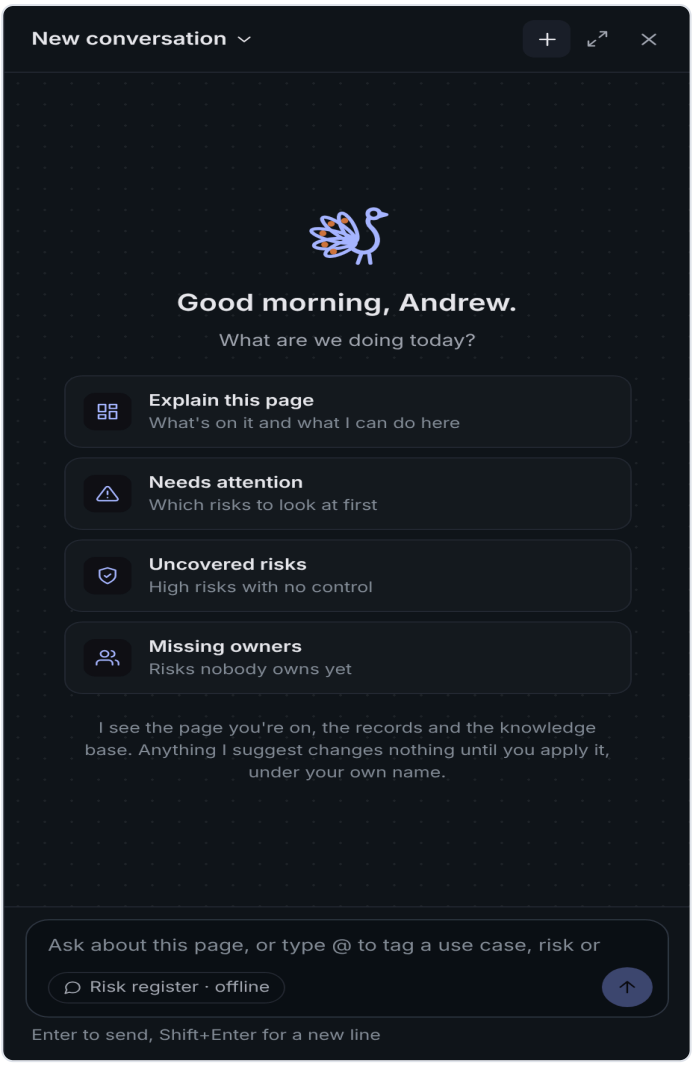
- **How it works**: **Agentic** (looks things up, may ask, checks its own work) or **Single call** (one call with a fixed brief: cheaper and predictable, but it can't look anything up or ask). Agents start agentic. The offline rules, and models that don't support tool calls, always run as a single call.
- **Most steps per run** (2 to 20, default 8). On its last step the agent must hand in its draft.
- **Self-check** on or off.
- **Tools it may use**: reading use cases and the engagement, reading the registers, reading evidence, and asking a person. Approving or signing off is never possible.

29. Grounding: why the agents cite sources

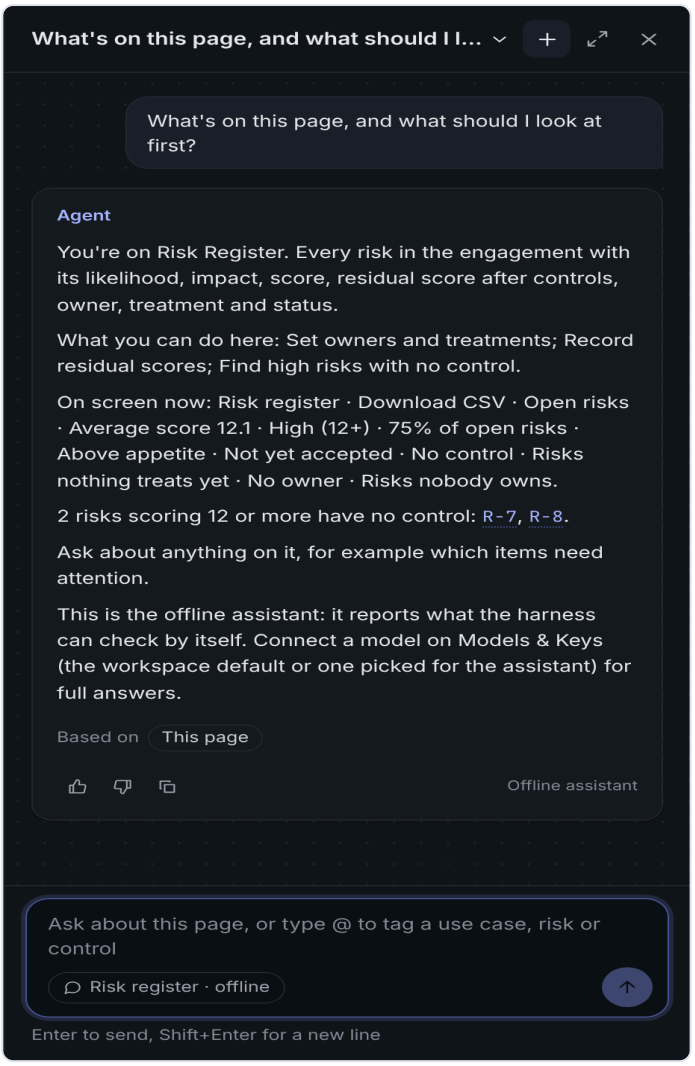
Before drafting, an agent searches the knowledge base and is given the passages it finds; it can search again while it works. It must cite the ones it relies on by K-number. A citation of a passage it was neither given nor found itself fails the run. The cited passages are copied onto the draft, so the reviewer reads exactly what the agent saw.

Search works by **keyword** (exact terms such as "Article 14") and, if an embedding model is set, by **meaning** (passages that say the same thing in other words). An uploaded document is split at its headings, and each passage keeps its section name (for example "Model Risk Policy › 2. Human oversight"), so you can see where a passage comes from. No more than two passages come from one document unless nothing else matches.

30. The assistant



A new conversation: starting points for the page you're on



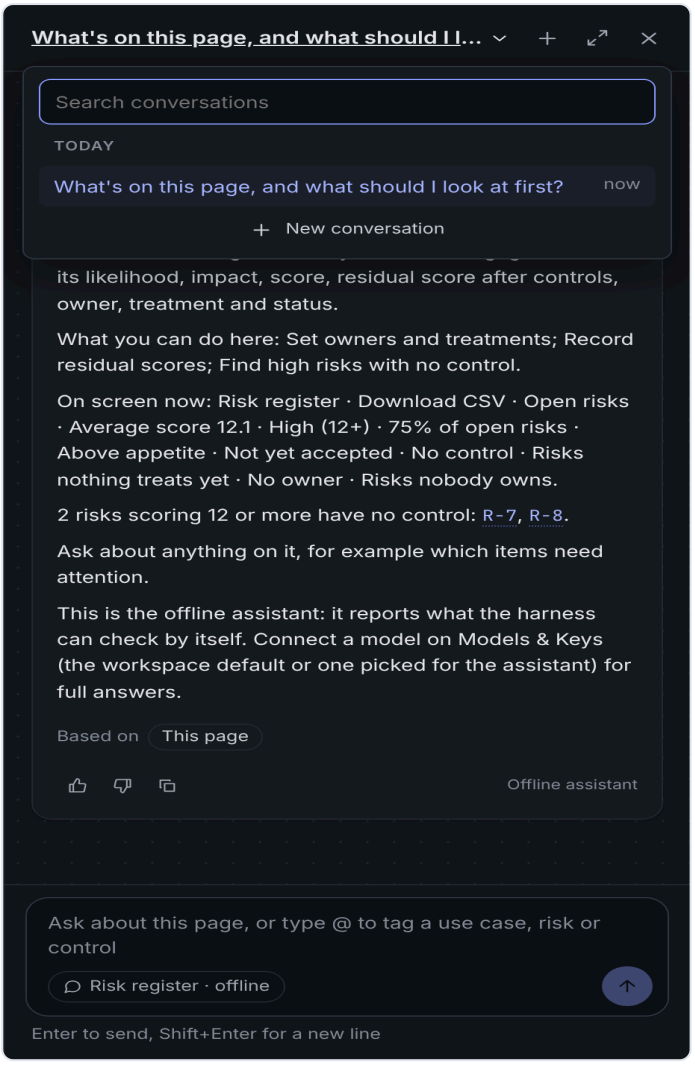
A question and its answer

Ask about this on a use case, or **Ask** in the top bar, opens the assistant beside the page. It works like a chat: your questions on the right, its answers in cards below them, formatted with bold and lists. An empty conversation offers starting points for the page you're on. Type in the box at the bottom (it grows as you write; Enter sends, Shift+Enter adds a line). The header has the conversation title (click it for your history), **+** for a new conversation, a button to make the panel wider, and close. It sees the page you're on, so you can ask "What's on this page?" or "What should I look at first?". It answers in plain English from the page, the record and the knowledge base, shows the passages it used, and may suggest changes:

- a decision on a draft item;
- a change to a risk or a control;
- a new issue;
- sending a draft back to its agent with a note.

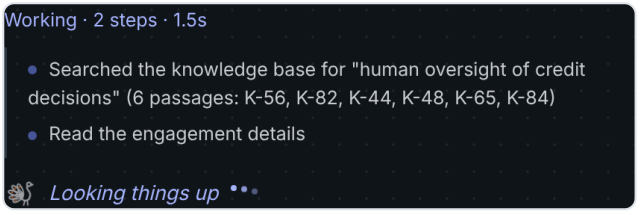
A suggestion changes nothing until you click **Apply**. Applying runs it under your own name and role, exactly as if you'd made the change by hand, so a preparer can't apply a decision only a reviewer may make. The audit log records the change and that the assistant proposed it. **Discard** sets it aside. The assistant can never approve a stage, sign off, conclude a test, accept a risk or close an issue. Anything it gets wrong (a passage it wasn't given, a record it wasn't shown) is removed and listed. Viewers can read but not ask.

Conversations. The title at the top of the assistant is the conversation you're in. Click it to see your conversations (Today and Earlier), search them by any word in them, and open one to carry on. The **+** button starts a new conversation. Your conversations are yours: nobody else can read them.



Your conversations, with search

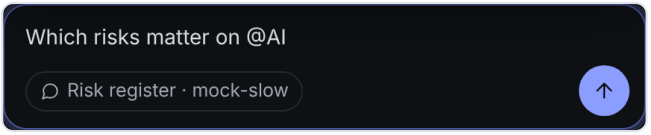
Watching it work. While it works you see **Working · N steps** with each thing it looks up, and its own reasoning, as it happens. When it finishes, this folds into a line like **Worked 2.4s · 2 steps** above the answer; click it to see the steps again.



The assistant at work

Links. Answers link to the pages and records they mention: click a use case key to open it, a risk or control key to jump to its row (highlighted), or a page name to go there. The assistant stays open.

Tag a record with @. Type **@** in the question box to pick a use case, risk, control or issue, then ask about it from any page.



Tagging a record with @

Rate an answer. Under each answer, thumbs up or down tells the team whether it helped (a thumbs down is kept, so poor answers can be checked); the copy button copies it. If the model can't be reached or refuses the key, the message says what to do and where.

What it based an answer on. Under each answer, **Based on** says whether it drew on the page you're on, ARGUS records, or the knowledge base. Its sources are grouped by kind (frameworks, controls, method guidance, client documents), and **How I got here** lists what it looked up before answering. A question about the page is answered from the page.

Which model answers. The assistant uses the model picked for it on Models & Keys, or the workspace default if none is picked. With neither, it runs offline and reports what the harness can check by itself.

31. Checking the AI

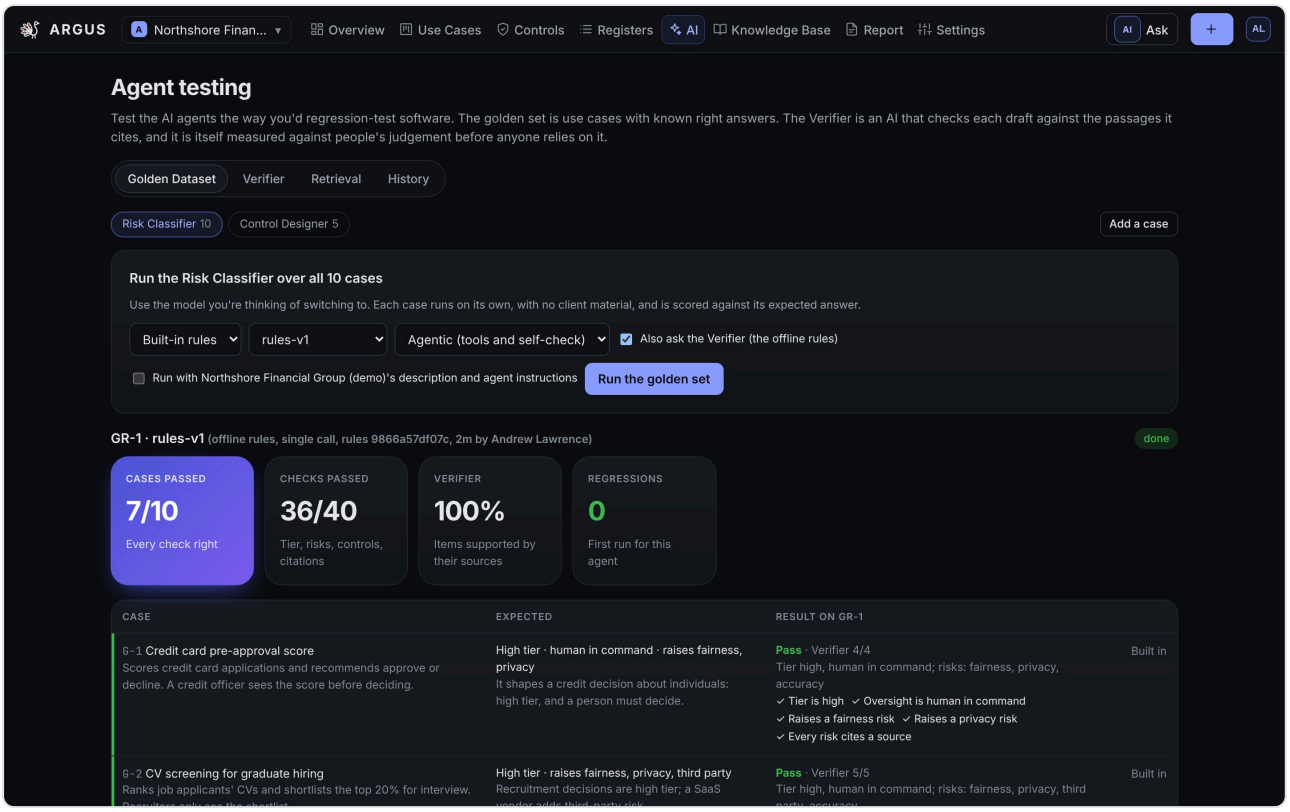
AI > Checking the AI tests **ARGUS's own agents**, not the client's systems. It answers the question a client or regulator will ask: why should we trust drafts written by AI? There are three parts. The golden dataset checks the agents against known right answers. The Verifier checks each draft against its sources. Calibration checks the Verifier against people. The page appears when the Advanced AI settings module is on.

31.1 The Verifier

The Verifier is a second check that reads each item of a classification or control design next to the passages it cites and says whether the item is **backed by what it cites**, **only partly backed**, **not backed**, or whether **what it cites says otherwise**. With no AI model set for it, it matches key words; with a model, a second AI judges. A "supported" verdict must quote a cited passage word for word; the harness checks the quote, and doesn't trust a verdict whose quote isn't there. The Verifier is advisory: it never decides an item. If the same model wrote and checked a draft, the panel says so.

On a draft, **Check with the Verifier** asks for a check. An admin can turn on automatic checks of every new draft under **AI > Checking the AI > Verifier**.

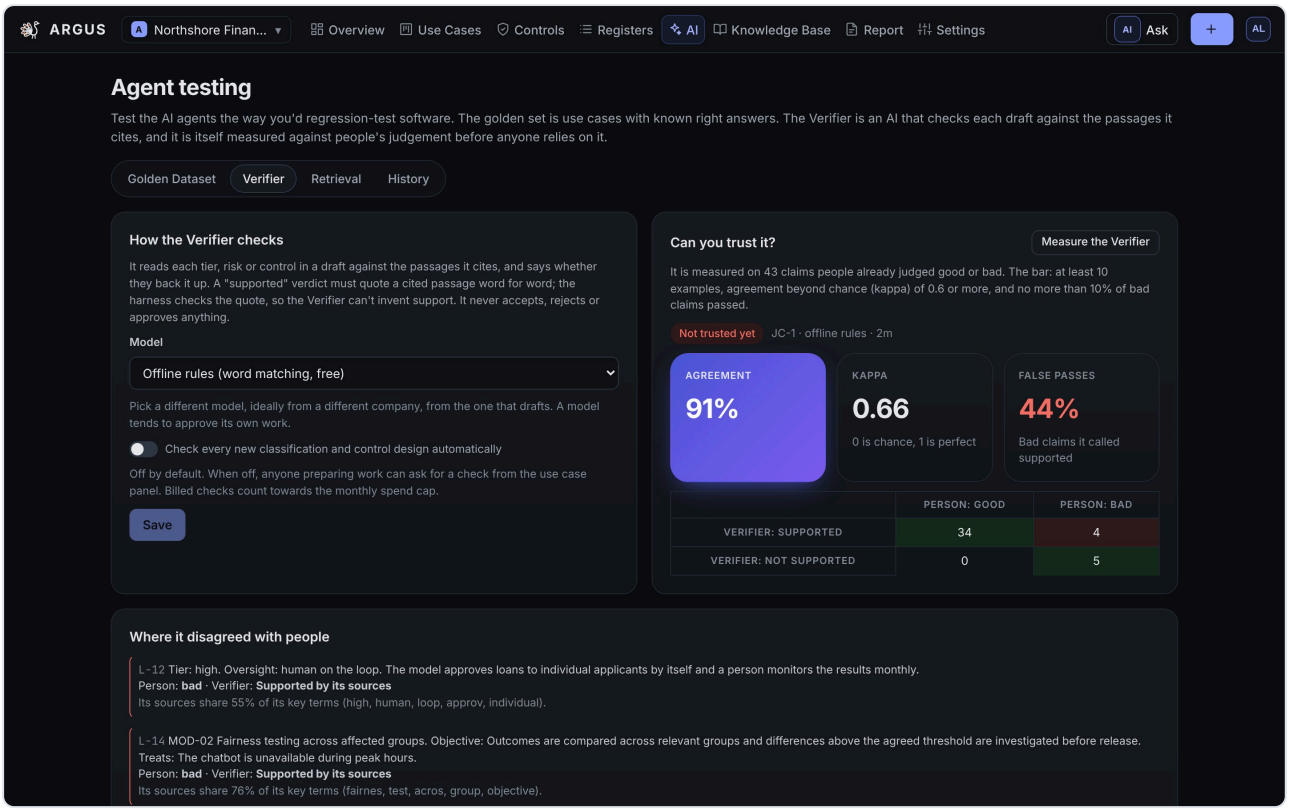
31.2 The golden dataset



Golden dataset

AI > Checking the AI > Golden dataset holds 15 fictional use cases with known right answers (10 for the Risk Classifier, including one with a hidden instruction, and 5 for the Control Designer). Before switching an agent's model or changing its rules, run it over the set (tick **Run with ... description and agent instructions** to test it as it runs on the engagement you have open; leave it unticked for the same neutral benchmark every time): each case is scored check by check, and any case that passed last time and fails now is a **regression**. Admins can add their own cases.

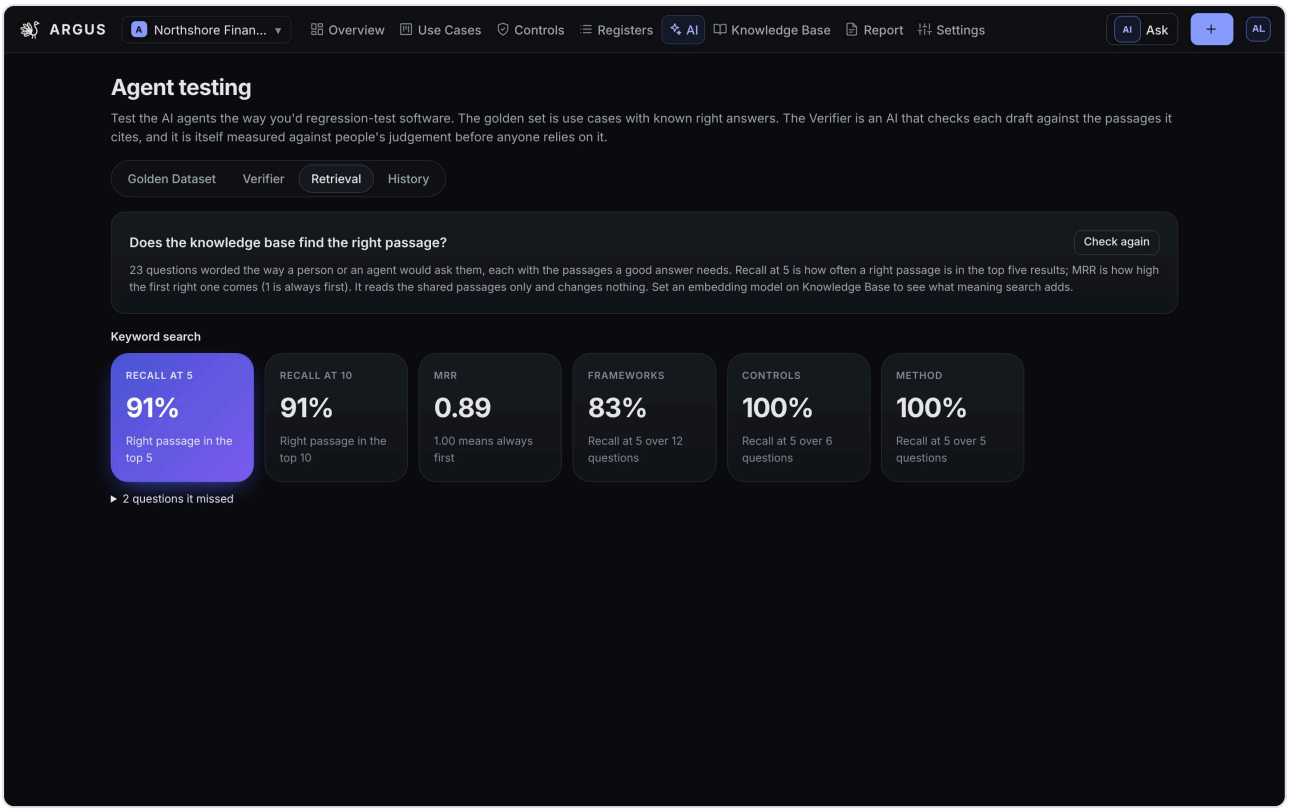
31.3 Can you trust the Verifier?



Measuring the Verifier

The Verifier is measured against claims people already judged good or bad: 18 built-in examples, examples you add, and reviewers' real accept and reject decisions (**Add from reviewers' decisions**). The page shows agreement, kappa (agreement beyond chance) and the **false pass rate** (bad claims it called supported). It is marked trusted only with at least 10 examples, kappa of 0.6 or more, and false passes of 10% or less.

31.4 Retrieval: does the knowledge base find the right passage?



Retrieval scores

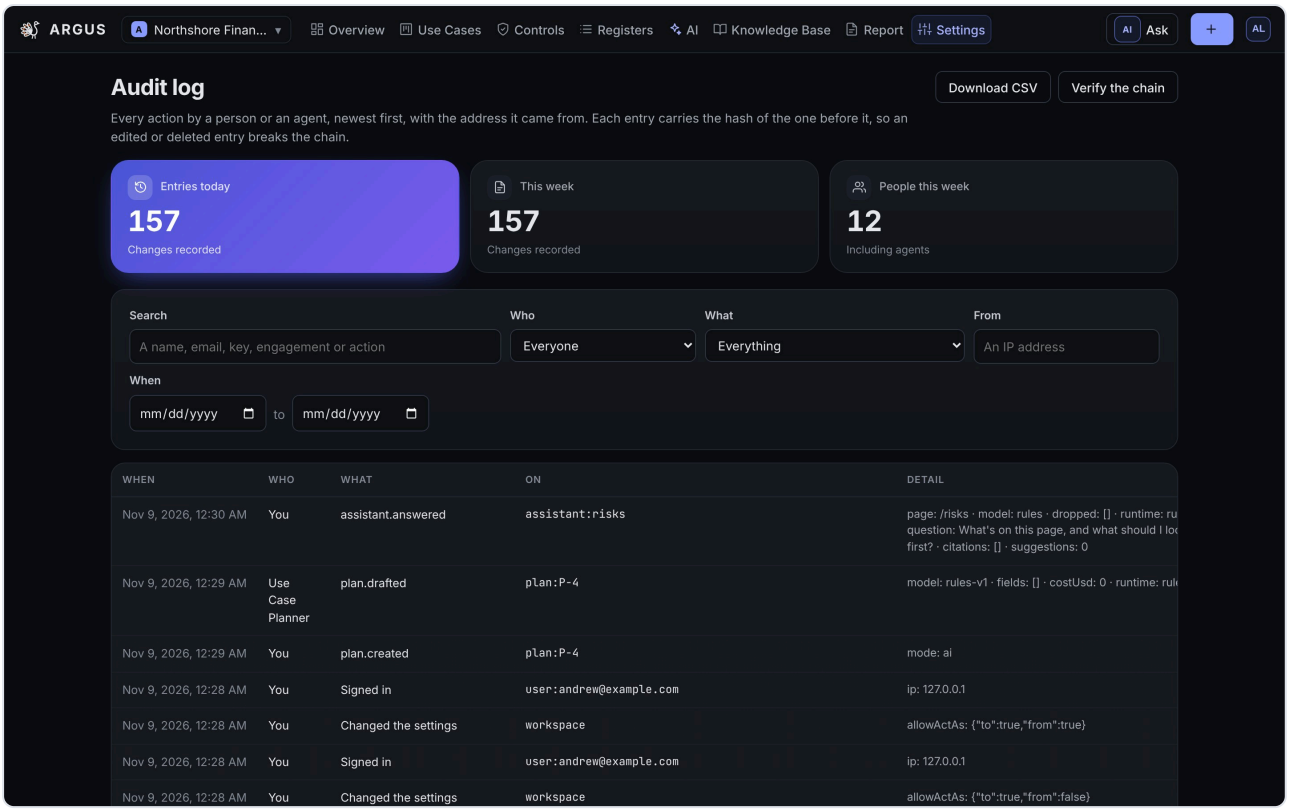
AI > Checking the AI > Retrieval asks the knowledge base 23 questions, worded the way a person or an agent would ask them, and checks whether the passages a good answer needs come back. **Recall at 5** is how often a right passage is in the top five results; **MRR** is how high the first right one comes (1.00 means always first). Scores are shown per kind and for keyword search alone and, when an embedding model is set, with meaning search added. Switch the embedding model and check again to compare models. The questions it missed are listed.

The golden dataset can also be run **Agentic** or **Single call** on the same model, to see whether looking things up is worth its cost.

Part 7. How the harness governs itself

32. Controls on the harness

Control	What it does
Roles and segregation of duties	Section 3, enforced on the server
Gates and exit criteria	The table at the start of Part 4; checked on every path, not only gated ones
Item-by-item decisions	Nothing an AI drafts takes effect until a person decides it
Audit log	Every action by a person or agent, with when and from where; each entry carries a fingerprint of the one before, so changing or deleting any entry breaks the chain. **Verify the chain** checks it
Evidence fingerprints	SHA-256 on collection; **Verify** shows a file is unchanged
Read-only archives	An archived engagement can't be changed until restored
Members-only engagements	Section 7.2
Encrypted keys	AI provider keys, connector credentials and the SSO client secret are encrypted and never shown again
Spending limits	Monthly cap, warning level, per-run limits
Kill switch	Each agent can be stopped at once; the switch can be tested and the date is recorded
Client content is data	Instructions inside profiles, evidence or documents are ignored by agents and flagged
People add use cases, not agents	The Use Case Planner drafts the brief; only a person can add it to Intake, under their own name
Act as is recorded	Off by default; every action taken while acting names the real admin in the audit log (section 8.1)



The audit log

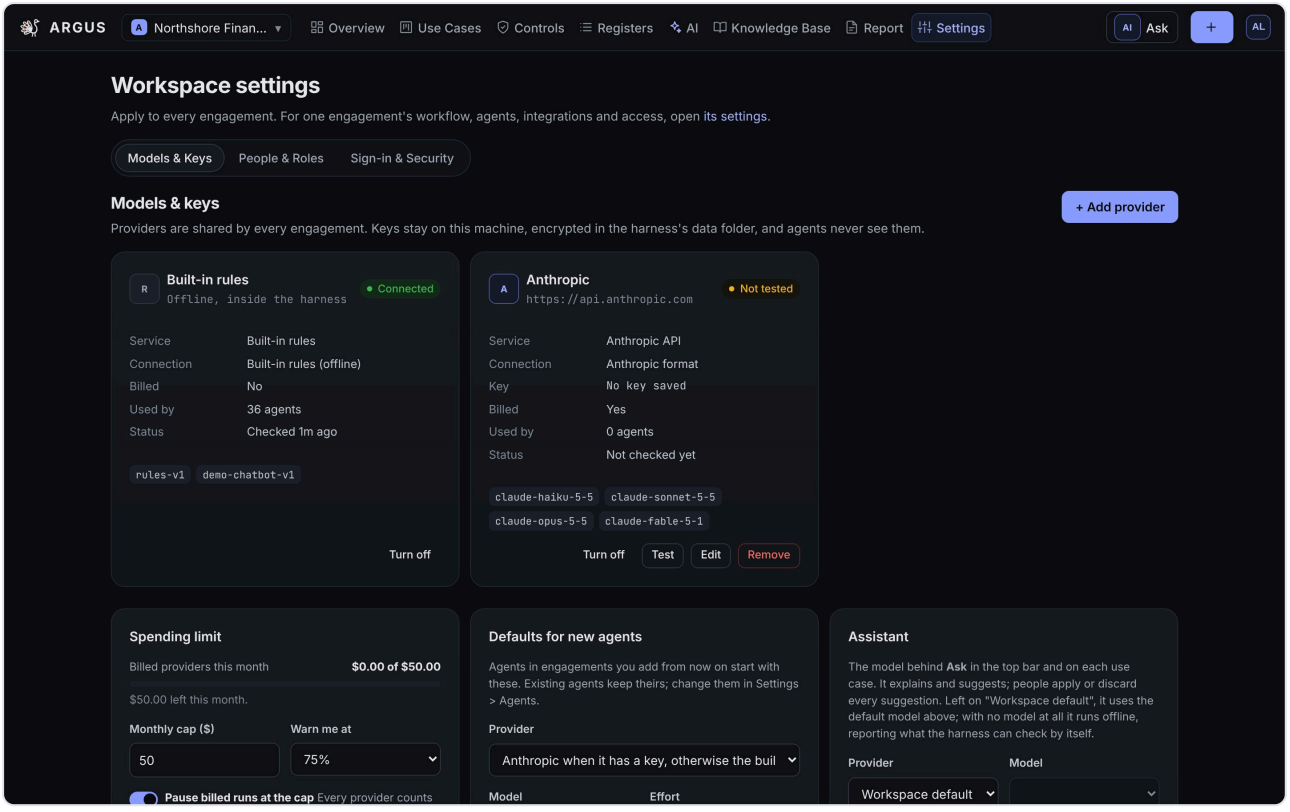
The Audit Log (Settings menu or account menu) can be searched and filtered by person, action, address and date, and downloaded as CSV. Entries about a members-only engagement are visible only to its members and admins.

Part 8. Administration

33. Workspace administration

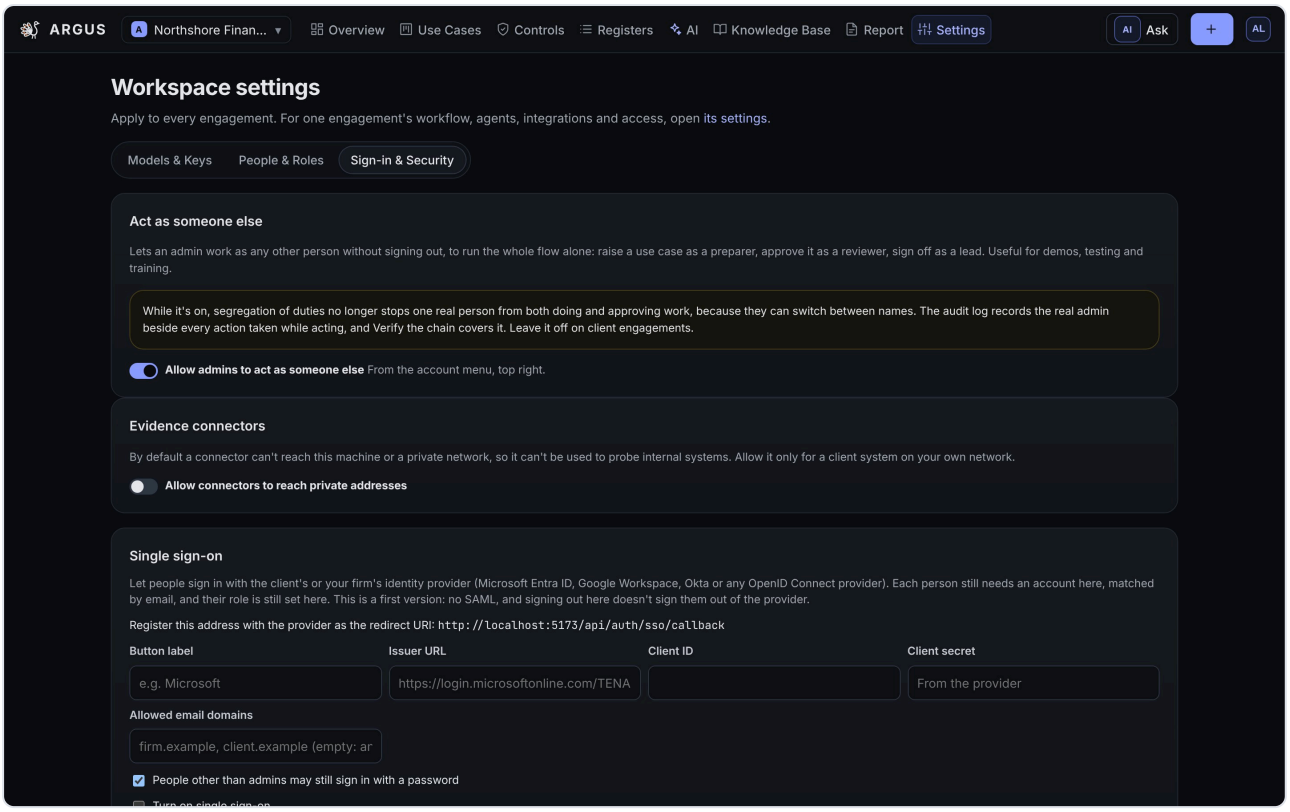
Across ARGUS, a **Save** button stays greyed out until you change something in its form, so you can tell at a glance whether there is anything to save.

33.1 Workspace settings



Models and keys

Settings > Workspace Settings has three tabs. **Models & Keys**: providers and their models, prices per million tokens for billed models, the spending limit, defaults for new engagements' agents, the assistant's model and meaning-based search. **People & Roles**: section 8. **Sign-in & Security**: act as (section 8.1), whether connectors may reach private networks, and single sign-on.



Sign-in and security

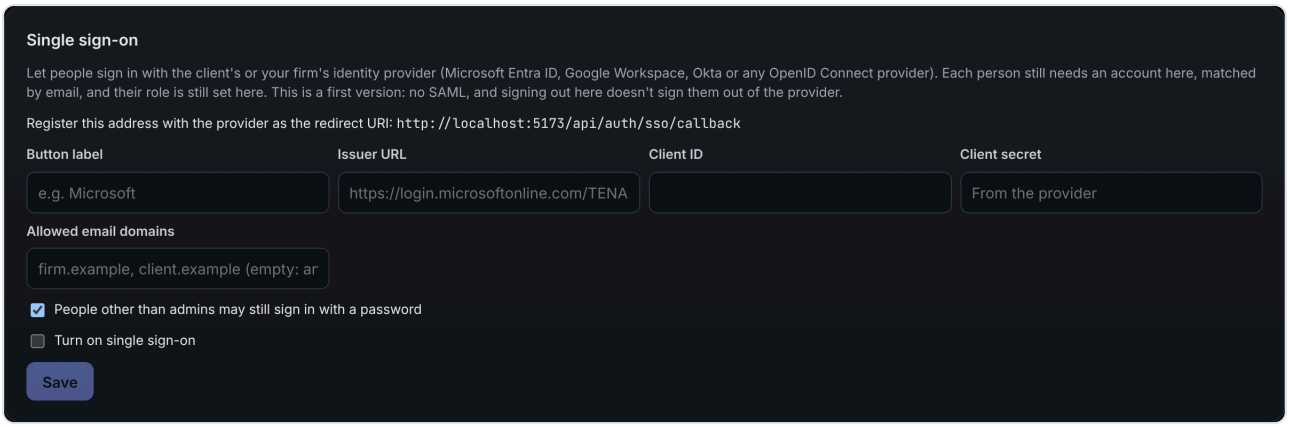
33.2 Where the data is kept

On the live site the records are in a hosted Postgres database and evidence files are in cloud file storage, both outside the server itself, so nothing is lost when the server sleeps or is updated. The server's own disk is temporary. To keep a copy of an engagement, use **Export** under **Engagement Settings > General**: it downloads everything the engagement holds as JSON. The site's owner can also restore the database to an earlier point in time.

33.3 Running your own copy

ARGUS can also run on a single computer, for training or for trying changes without touching the live site. That is a job for whoever maintains it: the project's runbooks *Put ARGUS online with Cloudflare* and *Load the demo, and build your own* give the steps, and the developer README lists the automated tests. A copy on a computer has its own accounts and data; nothing in it reaches the live site.

33.4 Single sign-on



Single sign-on settings

Admins can let people sign in through an identity provider that supports OpenID Connect (for example Microsoft Entra ID, Google Workspace or Okta):

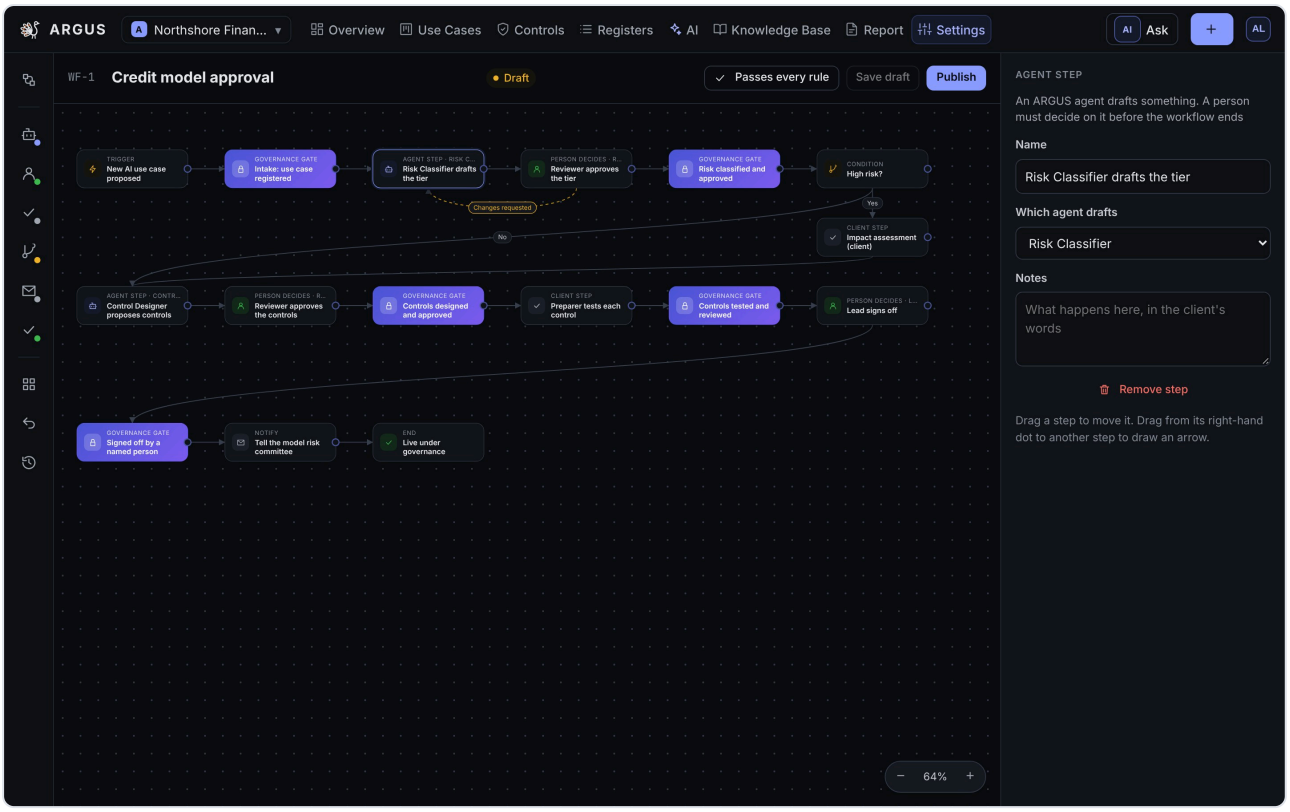
1. In **Workspace Settings > Sign-in & Security**, scroll to **Single sign-on** and copy the redirect URI shown. Register it with the provider.
2. Enter the button label, issuer URL, client ID and client secret, and optionally limit sign-in to your email domains.
3. Tick **Turn on single sign-on** and save.
4. Make sure each person has an account here with the same email. Single sign-on never creates accounts or changes roles.
5. Once it works, you can stop non-admins signing in with a password. Admins always keep a password, so a broken provider can't lock everyone out.

This is a first version: there is no SAML, and signing out here doesn't sign you out of the provider. Multi-factor sign-in comes from the provider.

33.5 Versions

Every release of ARGUS is a version in git, from v0.3 onwards. The live site always runs a tagged version, so what you see matches a known release. The runbook *Versions, going back, and GitHub* explains how to go back to an earlier one.

34. Client workflows



The workflow builder

Settings > Client Workflows holds the client's own processes for taking an AI use case live, drawn as steps and arrows around ARGUS's governance. Leads and admins draw them; everyone can view them.

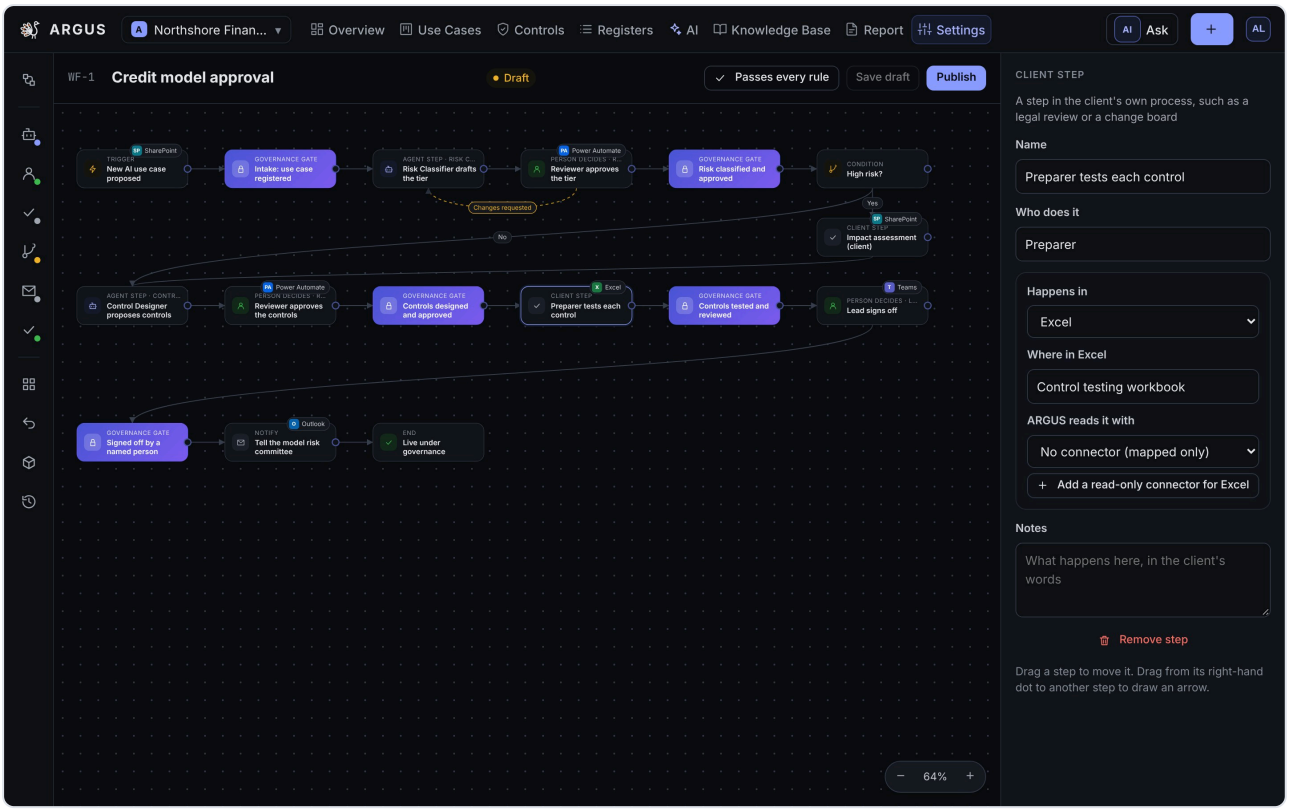
1. Click **New workflow**, name it, and start from **Standard** (the five gates with the usual agent and reviewer steps), a version already placed in **Microsoft 365**, **ServiceNow and Jira** or **Google Workspace and Slack**, or **Gates only**.
2. Add steps from the rail on the left: **Agent step** (an ARGUS agent drafts), **Person decides** (a role approves), **Client step** (for example a legal review), **Condition** (for example "Is the risk high?"), **Notify** (who should be told; ARGUS records it and doesn't send messages) and **End**.
3. Drag a step to move it. Drag from a step's right-hand dot to another step to draw an arrow. An arrow back to an earlier step is marked **Rework** (for example "Changes requested").
4. Click a step or arrow to name it and fill in its details on the right. Delete removes it; Ctrl+Z undoes.
5. **Save draft** keeps your work, even with problems. The button at the top says what still needs fixing; click a problem to find its step.
6. **Publish** when every rule passes. Add a note saying what changed. Each publish is kept as a numbered version under **Versions** (the clock icon), where you can view an old version or make it the draft again. **Retire** takes a workflow out of use without losing its versions.

The rules, which nobody can switch off:

- The five governance gates (Intake, Risk classified, Controls designed, Controls tested, Sign-off) and the trigger can be moved but not removed.
- Every path from the trigger to an end passes every gate, in order. A rework arrow is the only way back.

- After an agent step, a person or a gate decides before the workflow ends.
- Every condition has labelled ways out, and every step is connected.

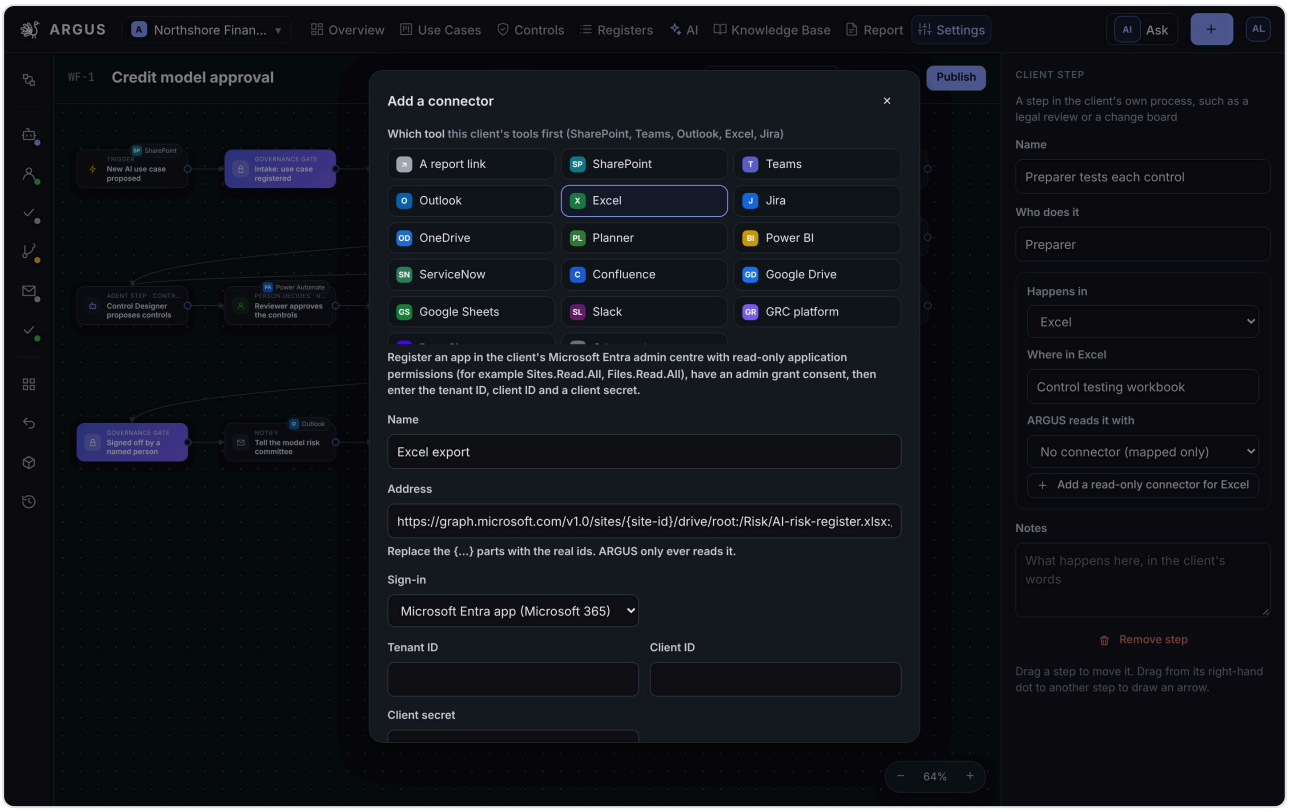
34.1 Steps in the client's business tools



A workflow with its steps in Microsoft 365 tools

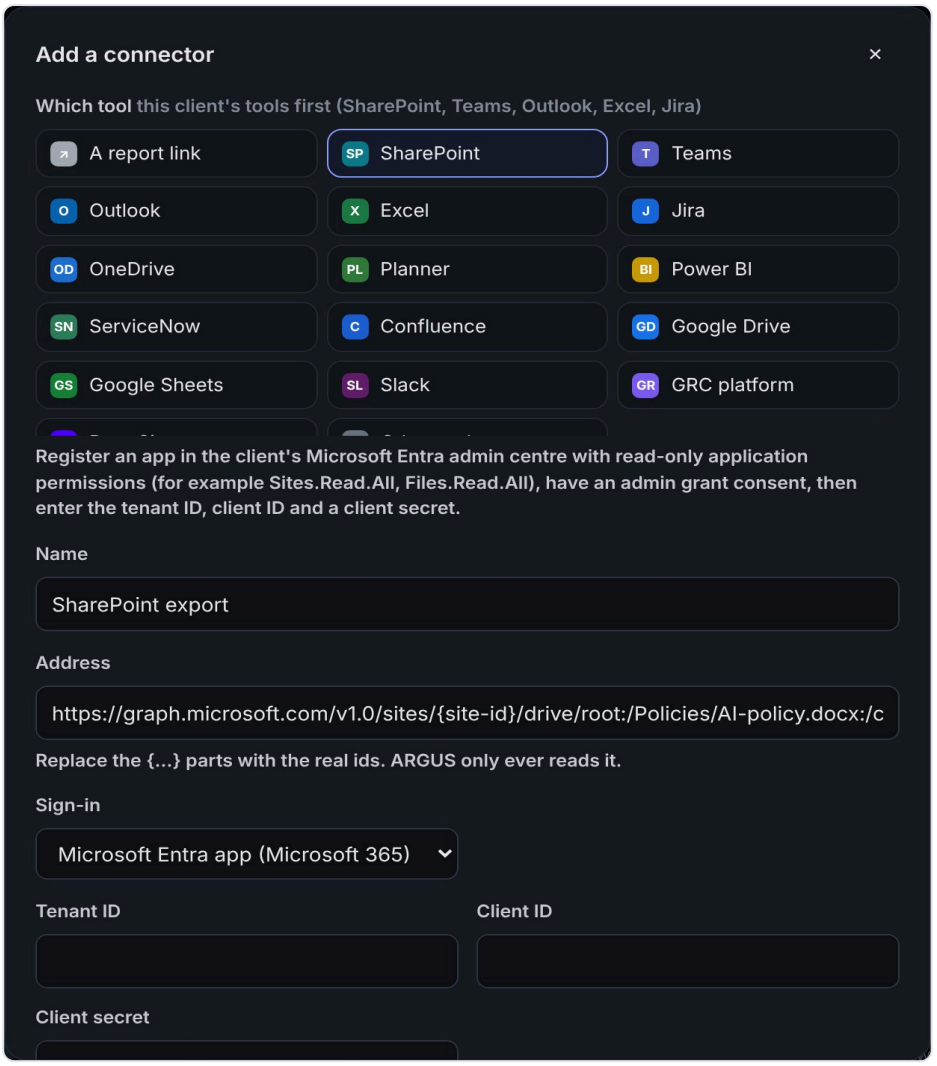
Most of a client's governance work already happens in their own tools: approvals in Power Automate or ServiceNow, policies in SharePoint or Confluence, testing in Excel or Jira, sign-off in Teams or Slack. For a trigger, person, client or notify step, choose **Happens in** (the tool) and **Where in** it (a site, list, project, queue or channel). The step shows the tool on the canvas.

Where ARGUS can read the tool, link the step to a **connector** (**ARGUS reads it with**). The connector pulls the document, spreadsheet, ticket list or channel history in as evidence, read-only; ARGUS never changes anything in the client's tools. The **Business tools** button in the rail lists the tools the workflow uses, their steps, and whether a connector reads each one. If no connector reads that tool yet, **Add a read-only connector for** the tool opens the connector form over the builder, with the tool picked; save it and it's linked to the step. You stay in the builder. The panel's **Add a connector** does the same.



Adding a connector from a workflow step

Setting up a connector (from the builder, or **Settings > Connected tools > Add connector**):



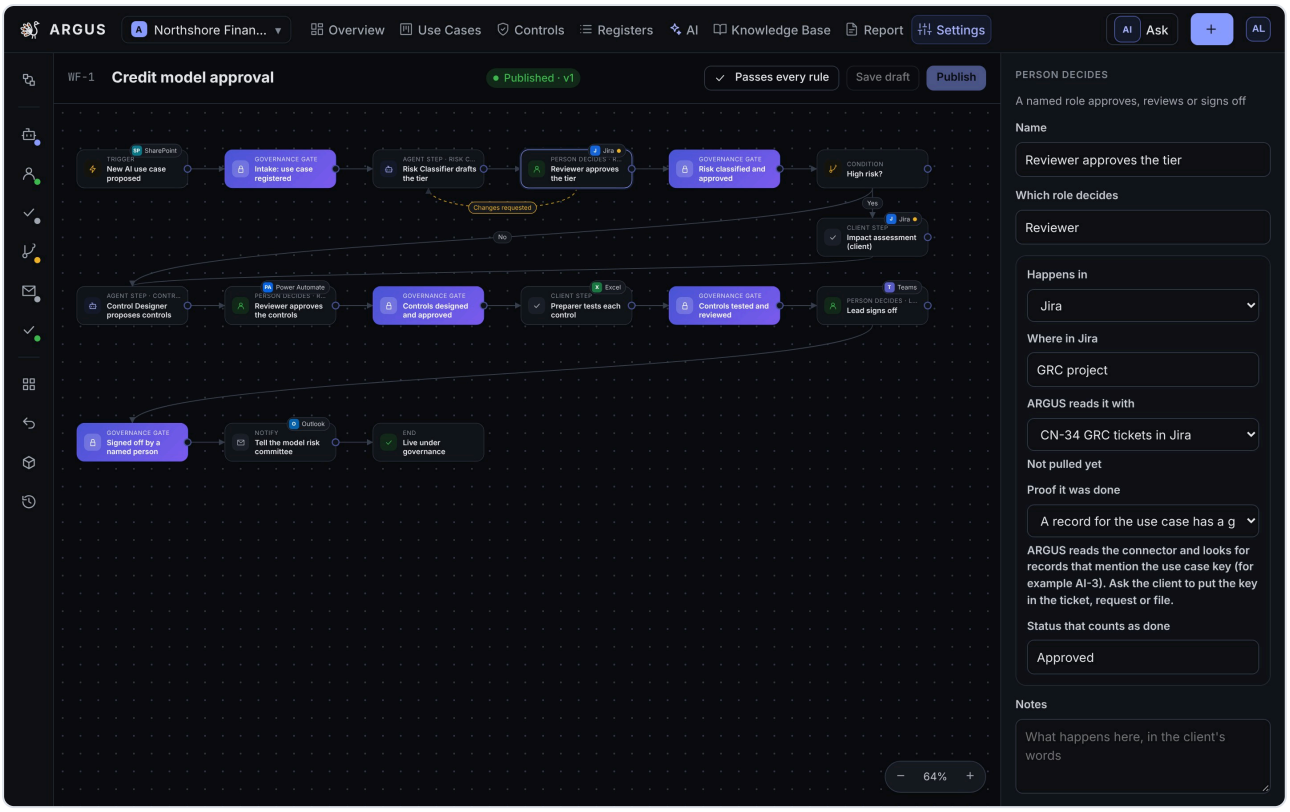
Adding a connector for SharePoint

1. Pick the tool. ARGUS fills in its usual address and sign-in, and says what the client's IT team needs to set up.
2. Replace the {...} parts of the address with the real ids (a site, file, project or channel).
3. Enter the sign-in: for Microsoft 365, the tenant ID, client ID and client secret of an app registered with read-only permissions; for Google, a service account's JSON key (share the file or folder with it); for ServiceNow, Jira and Confluence, a read-only user and API token; for Slack, a bot token with read scope.
4. Choose the control the evidence belongs to and how often to pull it, then **Pull now** to check it works.

Credentials are encrypted and never shown again or written to the audit log.

Every save, publish, restore and retirement is in the audit log.

34.2 Proof of each client step



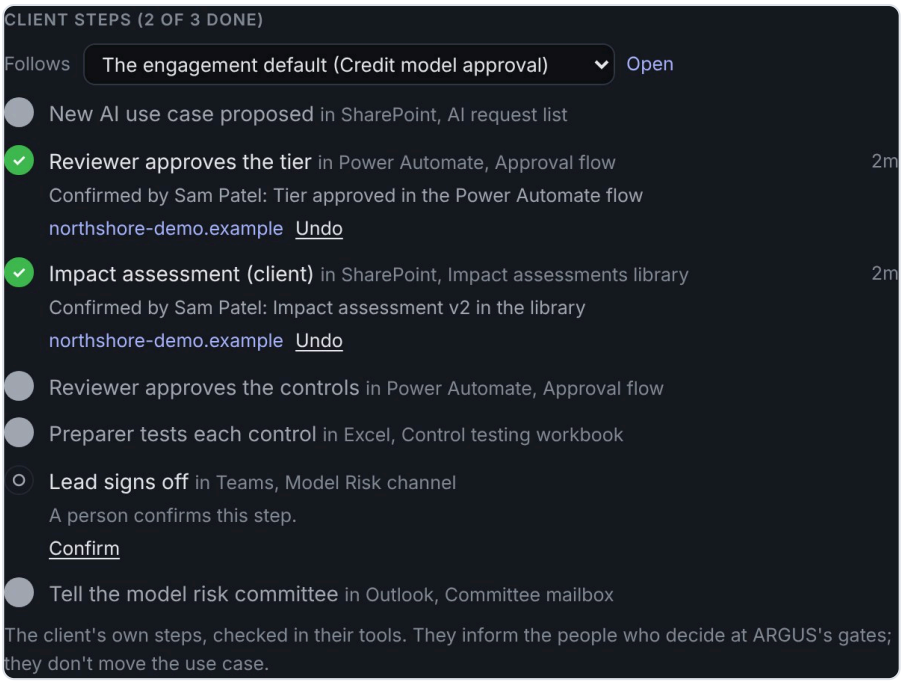
What proves a step

For a client step, **Proof it was done** says how ARGUS knows it happened for a use case:

Proof	Done when
A record mentions the use case key	The step's connector returns a ticket, request, row or message that mentions the key, for example AI-3
A record for the use case has a given status	One of those records has the status you name, for example Approved
Every record for the use case is done	All of them are Done, Closed, Resolved or Approved (or the status you add)
A person confirms it, with a link	Someone confirms it on the use case and gives a link to the record or a note

Ask the client to put the use case key in the ticket, request or file (a label, a field or the title). AI-3 never matches AI-30.

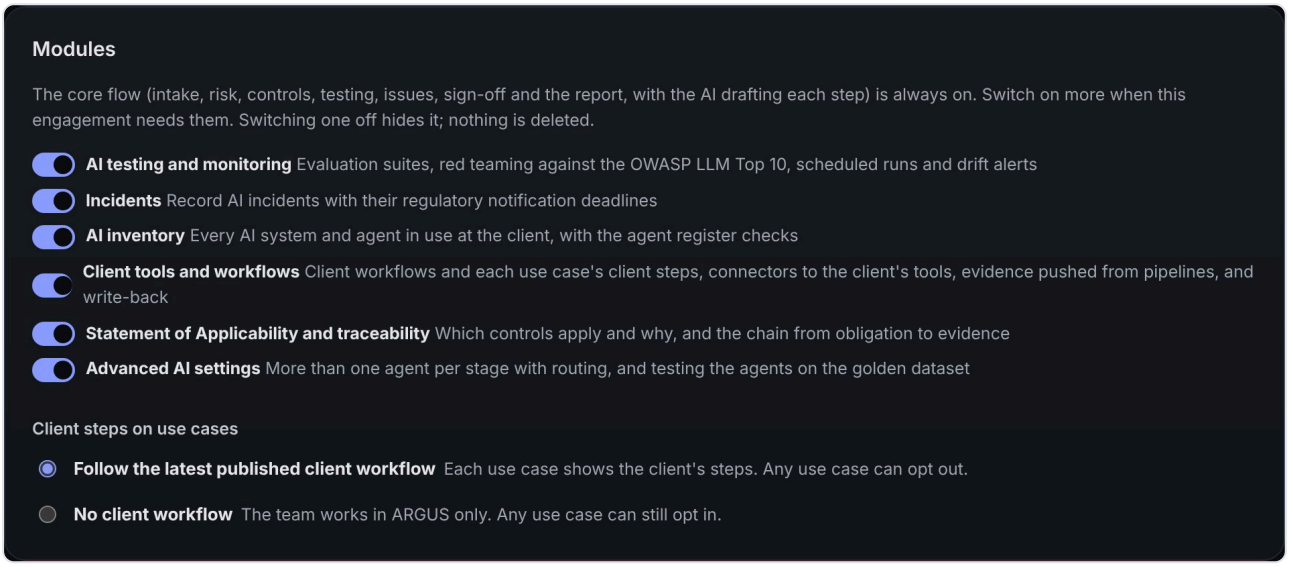
Each use case follows the latest published workflow, or one picked for it, and shows its **Client steps** in the side panel:



Client steps on a use case

Check now (preparers and above) reads each step's connector and marks the step done (✓), waiting (…) or not done (✕), with the records it found and a link to them. A step that passes files what proved it as evidence, once; checking again with the same records adds nothing. **Confirm by hand** records a step that ARGUS can't read, with a link or a note. Checks and confirmations are in the audit log.

Choose which workflow a use case follows under **Follows**: the engagement default, a particular published workflow, or **No client workflow** (the list then shrinks to one line, with **Change**). Under **Settings > General**, **Client steps on use cases** sets the default for the engagement: follow the latest published workflow, or no client workflow for teams that work only in ARGUS.



Client steps on use cases, under Settings > General

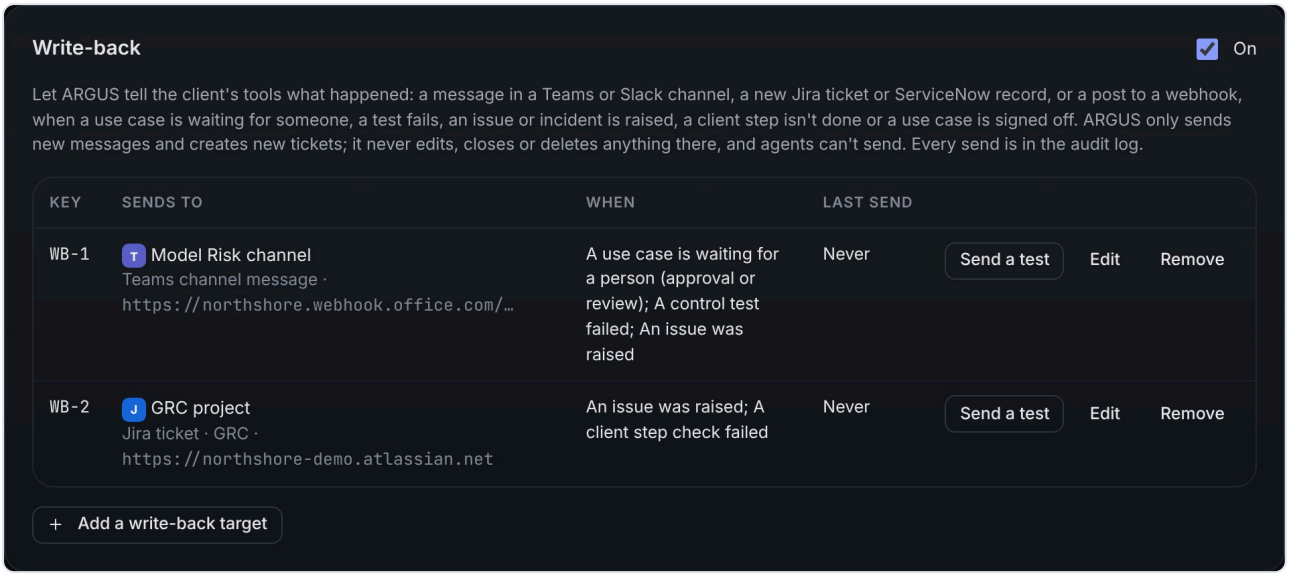
Only steps with a proof are tracked and counted ("2 of 3 done"); the others are shown as context, in grey. **Confirm** appears only on steps whose proof is "A person confirms it". A step

checked through a connector is also checked on its connector's schedule (daily or weekly), so a step that stops being done shows up without anyone clicking.

Client steps must be done before sign-off (in the workflow, under the publish panel) makes the tracked steps an exit criterion of sign-off: a use case following that workflow can't be signed off until each is done. A person still signs off.

Client steps never move a use case. They give the people who decide at ARGUS's gates the client's own paper trail, already checked.

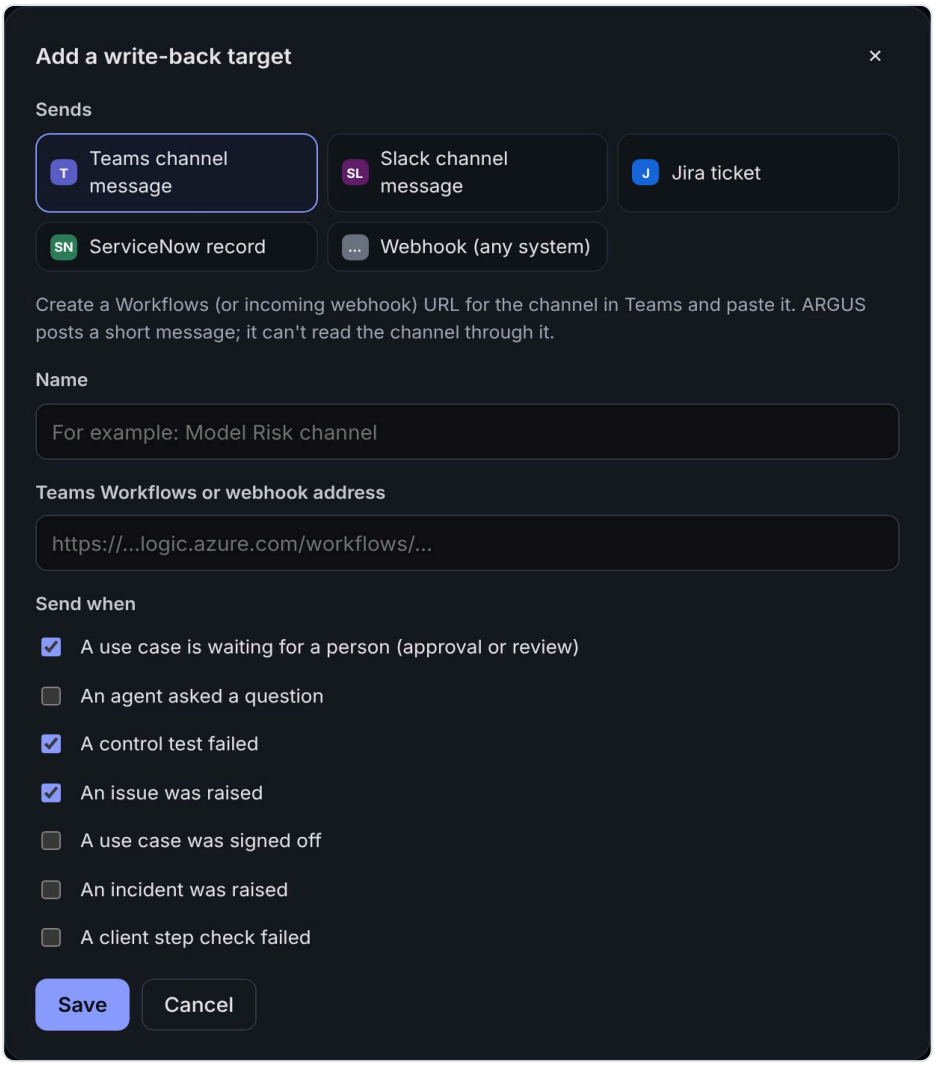
34.3 Write-back



Write-back

ARGUS can tell the client's tools what happened. It's off for every engagement until a lead or admin switches it on under **Settings > Connected tools > Write-back**.

1. **Add a write-back target** and pick what it sends: a **Teams** or **Slack** channel message (paste the channel's Workflows or incoming webhook address), a **Jira ticket** (site address, project key and email:API token), a **ServiceNow record** (instance address, table and user:password) or a **Webhook** (any address that accepts a JSON post, such as a Power Automate flow).
2. Tick when it sends: a use case waiting for a person, an agent's question, a failed test, a new issue or incident, a failed client step, or a sign-off.
3. **Send a test** to check it.



Adding a write-back target

ARGUS only sends new messages and creates new tickets or records; it never edits, closes or deletes anything in the client's tools. Agents can't send: sends come from the audit log, after a person's or the engine's change is saved. Each send, and each failure, is in the audit log with a fingerprint of what was sent. An issue sent to Jira or ServiceNow shows the ticket it became. Switch write-back off and nothing more is sent.

Appendices

A. Troubleshooting

Problem	What to do
The site shows an error or takes a long time on the first visit	The server sleeps when nobody has used it for 30 minutes. Wait up to a minute and refresh
Signed in, then signed out at once	Open the site with its full **https://** address, not http
Updates on the board appear a second or two late	Your network blocked live updates, so the page checks for changes instead. Everything still works

| A use case stays on "Running" | Wait a few seconds. If it stays, open it and click **Retry**. Check the agent's model on the Models & Keys page | | An agent run failed | The card shows why. Fix the model or key, or switch the agent to the built-in rules, then **Retry** | | "Paused: billed AI spend reached the cap" | Raise the cap on the Models & Keys page, or move the agent to an unbilled model | | A connector says "private network" | The address is inside a private network. An admin can allow it under Workspace Settings > Sign-in & Security | | A PDF says "no text layer" | It's a scan. Add a note with what it shows | | Someone can't see an engagement | It may be members only. A lead adds them under Engagement Settings > Access | | A card waits on a stage with "None of the agents take this card" | Every agent on that stage is routed to other kinds of card. Change one's **Takes cards**, or move the card on by hand | | A page or tab I used to see is missing (AI Testing and Monitoring, Incidents, AI Inventory, Connectors, What Applies) | It belongs to a module that is off for this engagement. A lead switches it on under Engagement Settings > General > Modules | | A dragged card goes back to its column | The move wasn't allowed; the message says why (for example, you added it, so someone else must approve it) | | The Planner says it is switched off | A lead turned it off for this engagement. Use **Fill it in myself**, or ask a lead to turn it on | | "Sign in with single sign-on instead" | An admin turned passwords off for non-admins; use the SSO button |

B. What isn't built yet

Client workflows moving use cases on the board (client steps are checked and shown, but people still decide at the gates); editing or closing records in the client's tools (write-back only creates); reading scanned documents (OCR); a reranker for knowledge-base search; SAML, signing out at the identity provider and multi-factor sign-in inside the app; connectors to document stores that need their own sign-in (OAuth); and a limit on repeated failed sign-ins. Evidence connectors read report and export links over HTTPS.

C. Glossary

Term	Meaning
Act as	An admin working as another person, recorded under both names; off by default
Agent	An AI helper that drafts one kind of work. It never decides

Term	Meaning
Appetite	The highest residual risk score the client accepts without escalating
Archive	Make an engagement read-only and move it out of the main list
Audit log	The tamper-evident record of every action
Built-in rules	A free, offline stand-in for an AI model, cautious by design
Connector	A read-only link that pulls evidence from a client system
Drift	A drop in an evaluation's pass rate against its recent average
Exit criteria	Conditions checked before a use case can leave a stage
False pass	The Verifier calling a claim supported when a person judged it bad
Golden dataset	Use cases with known right answers, used to test the agents
Grounding	Giving agents trusted passages and making them cite them
Incident	Something that went wrong in live use of an AI system
Kappa	Agreement between two judges beyond chance; 0 is chance, 1 is perfect
Members only	An engagement visible only to its members and admins
Passage (K-number)	One piece of the knowledge base
Plan	A use case being drafted on the Plan page, before it is added to Intake
Routing	Which cards an agent takes (by kind, priority or tier) when a stage has more than one agent
Regression	A golden case that passed before and fails now
Residual risk	Risk left after controls
Single sign-on	Signing in with an organisation's account through its identity provider
Statement of Applicability	Which library controls apply to an engagement, and why
Verifier	An AI that checks drafts against their sources; advisory only